

**Laporan Hasil Penetration Testing Pada
Website/Aplikasi Dinas Komunikasi Informatika
Statistik Dan Persandian Provinsi Sulawesi Selatan**

PENETRATION TESTING



Kelompok 7

GAMA MULTI GROUP

Anggota:

1. Indah Melati
2. Hellen Laurenza
3. Kustina Siska Dewi
4. Juan Diego Febrianto Tozu
5. Muhammad Ariq Mubarak

PROGRAM STUDI INDEPENDENT BERSERTIFIKAT BATCH 7

2024

KATA PENGANTAR

Puji dan syukur ke hadirat Tuhan Yang Maha Esa karena atas rahmat dan hidayahnya penulis dapat menyelesaikan laporan ini dengan baik dan tepat pada waktunya. Adapun judul laporan yang ditulis “Laporan Hasil Penetration Testing Pada Website/Aplikasi Dinas Komunikasi Informatika Statistik Dan Persandian Provinsi Sulawesi Selatan”.

Penyusunan laporan ini tidak terlepas dari dukungan, semangat, dan bimbingan yang telah diberikan pada kami sebagai penulis. Kami ingin menyampaikan terima kasih kepada semua pihak yang terlibat yaitu:

1. PT Gama Multi Usaha Mandiri sebagai mitra *Studi Independent Bersertifikat Batch 7*.
2. Pemerintah Provinsi Sulawesi Selatan sebagai mitra *partner* untuk melakukan *penetration testing* pada *website* yang dimiliki.
3. Pak Josua M. Sinambela sebagai head mentor yang telah memberikan segala arahan dalam memberikan ilmu sampai dengan pengerjaan *final project*.
4. Pak Bagus Setiawan sebagai mentor yang telah memberikan segala arahan dalam memberikan ilmu dalam bentuk teori, praktikum, sampai dengan pengerjaan *final project*.
5. Teman kelompok 7 yang telah berusaha dan bertanggung jawab menyelesaikan tugas *final project* hingga selesai.

Semoga informasi yang kami berikan melalui proses *penetration testing* untuk mengidentifikasi keamanan *website* dapat memberikan manfaat dan solusi bagi pemerintah Provinsi Sulawesi Selatan mengenai pentingnya menjaga keamanan *website* yang dimiliki agar senantiasa terjaga informasi sensitifnya. Kami kelompok 7 menyadari masih adanya kekurangan dalam melakukan pengujian ini, namun dengan hasil yang telah kami temukan dapat memberikan manfaat dan dorongan kepada pihak pengelola untuk melindungi aset digital yang dimiliki.

Terimakasih

Kelompok 7

DAFTAR ISI

KATA PENGANTAR	i
DAFTAR ISI	ii
BAB I PENDAHULUAN	1
1.1. Latar Belakang.....	1
1.2. Tujuan.....	2
1.3. Metodologi.....	2
1.4. Manfaat.....	3
1.5. Tahapan Penetration Testing	3
BAB II HASIL TEMUAN	4
2.1 Pro Ptsp Perizinan Online Balai Sertifikasi Elektronik SipaKatau (http://proptsp.sulselprov.go.id)	4
2.1.1 Informasi Website.....	4
2.1.2 Pengumpulan Informasi Teknologi.....	5
2.1.3 Hasil Scanning Web Vulnerability	7
2.1.4 List Vulnerability (Daftar Kerentanan)	12
2.1.5 Detail Vulnerability.....	13
2.1.6 Vulnerability Assessment (Pengujian Kerentanan)	16
2.2 Sistem Informasi Pembangunan Berbasis Masyarakat (http://sipbm.sulselprov.go.id/site/login).....	23
2.2.1 Informasi Website.....	23
2.2.2 Pengumpulan Informasi Teknologi.....	23
2.2.3 Hasil Scanning Web Vulnerability	25
2.2.4 List Vulnerability (Daftar Kerentanan)	30
2.2.5 Detail Vulnerability.....	31
2.2.6 Vulnerability Assessment (Pengujian Kerentanan).....	33
2.3 Dinas Ketahanan Pangan (http://dkpn.sulselprov.go.id)	41
2.3.1 Informasi Website.....	41
2.3.2 Pengumpulan Informasi Teknologi.....	41
2.3.3 Hasil Scanning Web Vulnerability.....	43
2.3.4 List Vulnerability (Daftar Kerentanan)	47
2.3.5 Detail Vulnerability.....	47

2.3.6	<i>Vulnerability Assessment</i> (Pengujian Kerentanan)	50
2.4	Website Provinsi Sulawesi Selatan (http://sulselprov.go.id).....	58
2.4.1	Informasi <i>Website</i>	58
2.4.2	Pengumpulan Informasi Teknologi.....	58
2.4.3	Hasil Scanning Web <i>Vulnerability</i>	60
2.4.4	<i>List Vulnerability</i> (Daftar Kerentanan)	64
2.4.5	Detail <i>Vulnerability</i>	65
2.4.6	<i>Vulnerability Assessment</i> (Pengujian Kerentanan)	68
2.5	Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu (https://dpmpmsp.sulselprov.go.id/).....	76
2.5.1	Informasi <i>Website</i>	76
2.5.2	Pengumpulan Informasi Teknologi.....	76
2.5.3	Hasil Scanning Web <i>Vulnerability</i>	77
2.5.4	<i>List Vulnerability</i> (Daftar Kerentanan).....	81
2.5.5	Detail <i>Vulnerability</i>	82
2.5.6	<i>Vulnerability Assessment</i> (Pengujian Kerentanan)	85
2.6	Sistem Informasi Pengadaan Barang dan Jasa Pemerintah Provinsi Sulawesi Selatan (http://reviupbj.sulselprov.go.id).....	95
2.6.1	Informasi <i>Website</i>	95
3.1.1	Pengumpulan Informasi Teknologi.....	95
3.1.2	Hasil Scanning Web <i>Vulnerability</i>	97
3.1.3	<i>List Vulnerability</i> (Daftar Kerentanan).....	101
3.1.4	Detail <i>Vulnerability</i>	102
3.1.5	<i>Vulnerability Assessment</i> (Pengujian Kerentanan)	104
BAB III PENUTUP.....		112
3.1	Kesimpulan.....	112
3.2	Rekomendasi	112

BAB I PENDAHULUAN

1.1. Latar Belakang

Di era digital yang semakin maju, keamanan data menjadi salah satu aspek penting dalam pengelolaan sistem teknologi data, khususnya di instansi pemerintah. Dinas Komunikasi, Informatika, Statistik dan Persandian Provinsi Sulawesi Selatan memiliki peran strategis dalam menyediakan layanan teknologi data yang handal dan aman untuk mendukung pelayanan publik dan administrasi pemerintahan. situs web dan aplikasi yang dikelola oleh satuan kerja ini paling banyak digunakan untuk mendistribusikan data, melayani masyarakat, dan mendukung proses kognitif yang lebih tinggi.

Namun, dengan meningkatnya penggunaan teknologi pengetahuan, bahaya serangan siber juga semakin tinggi. Serangan seperti bahaya, pelanggaran pengetahuan, dan eksploitasi kerentanan aplikasi internet akan berdampak signifikan pada kepercayaan amal dan juga kelangsungan operasional lembaga. Oleh karena itu, sangat penting bagi tempat kerja Data Komunikasi, Statistik, dan kriptografi untuk memastikan bahwa unit area sistem mereka bebas dari kerentanan yang dapat dieksploitasi oleh pihak-pihak yang tidak bertanggung jawab.

Salah satu upaya untuk meningkatkan keamanan sistem adalah melalui penetration testing. Pengujian penetrasi dapat berupa metodologi untuk mensimulasikan serangan terhadap situs web atau aplikasi dengan tujuan untuk membedakan dan menganalisis kerentanan yang ada. Hasil dari pengujian ini dapat memberikan gambaran yang transparan mengenai tingkat keamanan sistem dan usulan untuk mitigasi risiko.

Laporan ini disusun untuk mendokumentasikan hasil penetration testing yang dilakukan terhadap situs web dan aplikasi yang dikelola oleh satuan kerja perangkat daerah (SKPD) Dinas Komunikasi, Informatika, Statistik dan Persandian Provinsi Sulawesi Selatan. Laporan ini mencakup strategi yang digunakan, temuan kerentanan, serta rekomendasi perbaikan yang diharapkan dapat membantu instansi dalam meningkatkan keamanan sistem mereka saat ini.

Dengan adanya laporan ini, diharapkan instansi Kominfo, Statistik dan Persandian Provinsi Sulawesi Selatan dapat mengetahui kondisi keamanan sistemnya dan mengambil langkah proaktif untuk menjaga informasi dan layanannya dari potensi ancaman siber.

1.2. Tujuan

Tujuan dilakukannya *penetration testing* pada *website* Pemerintah Provinsi Sulawesi Selatan sebagai berikut:

1. Mengidentifikasi kerentanan keamanan pada *website* yang dikelola Pemerintah Provinsi Sulawesi Selatan.
2. Menguji tingkat kerentanan keamanan *website*.
3. Membuat laporan *penetration testing* yang memberikan gambaran mendalam mengenai kerentanan yang ditemukan.
4. Meningkatkan kesadaran akan pentingnya keamanan informasi dalam tata kelola digital pemerintahan.

1.3. Metodologi

Metodologi yang digunakan dalam kegiatan *penetration testing* sebagai berikut:

1. Perencanaan dan Persiapan
Mengidentifikasi target pengujian dan ruang lingkup.
2. Pengumpulan Informasi
Mengumpulkan data tentang sistem yang akan diuji.
3. Pengujian Kerentanan
Melakukan uji penetrasi untuk mengidentifikasi kelemahan sistem dengan memanfaatkan *tools* pilihan.
4. Analisis dan Evaluasi
Menganalisis hasil pengujian untuk mengidentifikasi dampak kerentanan yang ditemukan.
5. Pelaporan

Menyusun laporan lengkap yang mencakup temuan, analisis, risiko, dan rekomendasi mitigasi.

1.4. Manfaat

Manfaat yang mungkin didapat:

1. Membantu Dinas Komunikasi Informatika Statistik dan Persandian Povinsi Sulawesi Selatan dalam meningkatkan keamanan sistem informasi.
2. Mencegah potensi serangan *cyber* melalui mitigasi kerentanan sejak dini.
3. Meningkatkan kepercayaan masyarakat terhadap layanan digital yang disediakan pemerintah.
4. Memberikan panduan teknis untuk pengelolaan keamanan informasi yang lebih baik.

1.5. Tahapan Penetration Testing

Tahapan yang dilakukan sebagai berikut:

1. Pengumpulan data awal mengenai target *website* yang diberikan.
2. Melakukan *scanning* untuk menemukan celah keamanan pada sistem.
3. Melakukan uji penetrasi untuk mengeksploitasi celah yang ditemukan.
4. Melakukan penyusunan laporan hasil pengujian.

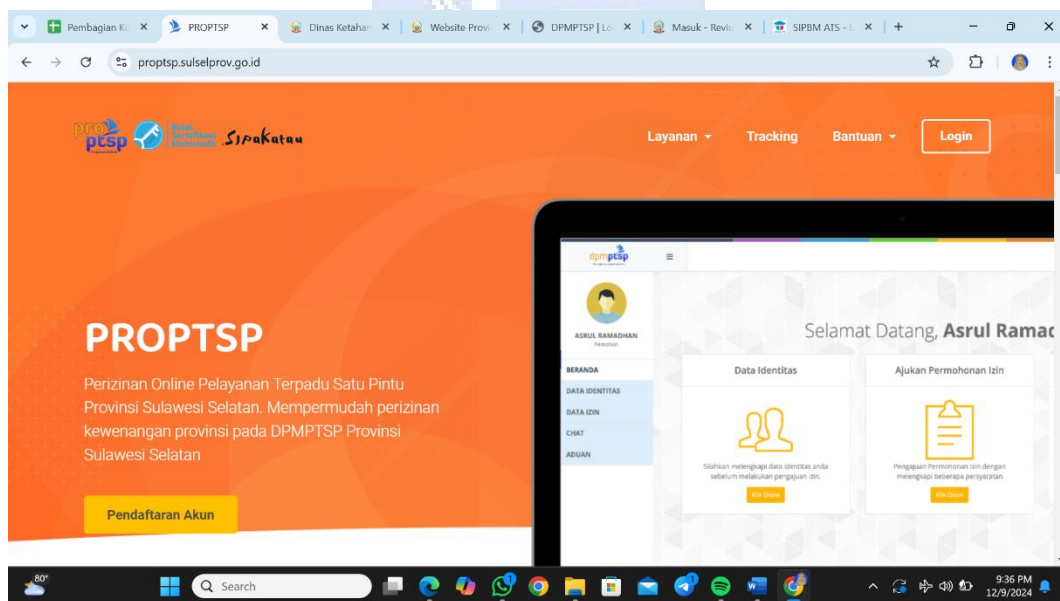
BAB II HASIL TEMUAN

2.1 Pro Ptsp Perizinan Online Balai Sertifikasi Elektronik SipaKatau

(<http://proptsp.sulselprov.go.id>)

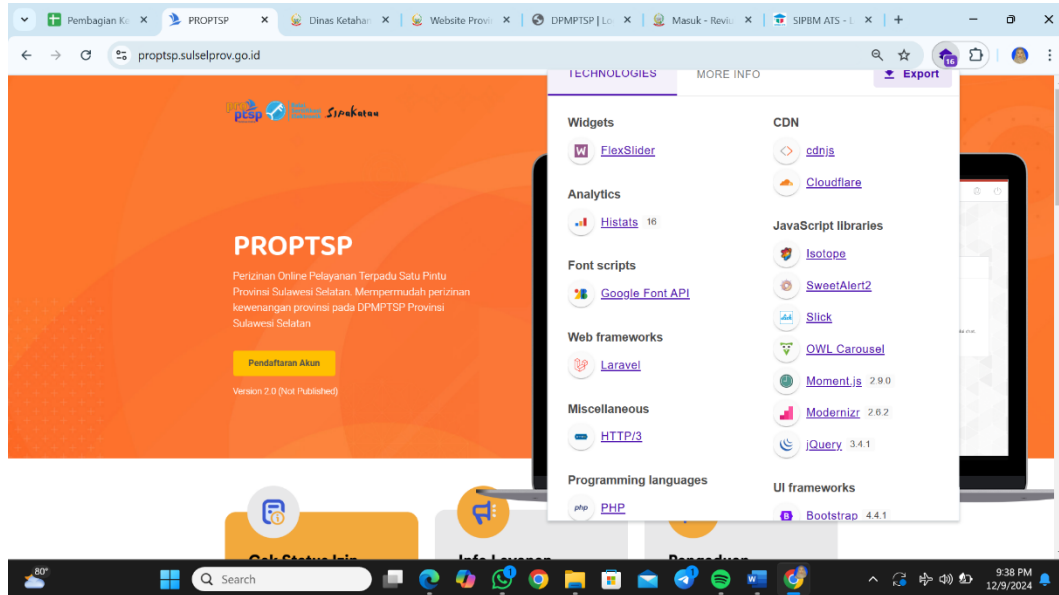
2.1.1 Informasi Website

Situs web ProPTSP Sulawesi Selatan merupakan platform layanan web yang dikelola oleh DPMPTSP untuk memfasilitasi pengajuan dan pengelolaan perizinan, serta tujuh puluh tiga jenis layanan di dua puluh satu sektor usaha. Sistem ini memungkinkan pelaku usaha untuk melacak status perizinan, mentransfer dokumen PDF dengan tanda tangan elektronik dari Badan Sertifikasi Elektronik (BSSN), dan mengakses layanan melalui aplikasi mobile untuk Android dan iOS. Dengan tujuan mendukung transparansi dan potensi, platform ini mengintegrasikan berbagai lembaga yang terhubung untuk menyediakan layanan berbasis teknologi secara mudah dan cepat bagi masyarakat.



2.1.2 Pengumpulan Informasi Teknologi

Wapplyzer adalah sebuah alat yang digunakan untuk mendeteksi teknologi apa saja yang digunakan oleh sebuah situs web.



Berikut adalah hasil pengumpulan informasi mengenai teknologi web yang dianalisis menggunakan Wappalyzer:

1. Widget

- **FlexSlider:** Sebuah slider responsif berbasis jQuery yang digunakan untuk menampilkan galeri gambar atau konten lainnya dalam bentuk slide.

2. Analitik

- **Histats:** Layanan pelacakan statistik kunjungan ke website.
- **Google Analytics (GA4):** Alat analitik dari Google untuk melacak dan melaporkan lalu lintas situs web.

3. Font Script

- **Google Font API:** Digunakan untuk menyematkan font dari Google Fonts ke dalam website.

4. Bingkai Kerja Web

- **Laravel:** Framework PHP untuk pengembangan aplikasi web, terkenal dengan sintaks yang elegan dan fitur yang kuat.

5. **CDN (Content Delivery Network)**

- **Unpkg:** CDN untuk file JavaScript.
- **cdnjs:** CDN untuk memuat pustaka JavaScript dan CSS populer.
- **Cloudflare:** Jaringan distribusi konten yang meningkatkan kinerja dan keamanan situs.

6. **Jaringan Periklanan**

- **DTScout:** Teknologi atau layanan yang terkait dengan pengelolaan iklan atau analisis periklanan.

7. **JavaScript Libraries**

- **Isotope:** Library untuk tata letak dinamis, seperti filter atau sorting elemen.
- **SweetAlert2:** Library untuk menampilkan popup atau pesan yang interaktif.
- **Slick:** Library untuk membuat carousel atau slider konten.

8. **Serba Serbi**

- **Popper (1.12.9):** Library untuk mengatur posisi elemen seperti tooltip, dropdown, atau popover.
- **HTTP/3:** Protokol HTTP generasi terbaru untuk komunikasi lebih cepat dan aman.

9. **Bahasa Pemrograman**

- **PHP:** Bahasa pemrograman sisi server yang digunakan untuk membangun situs web dinamis.

10. **UI Frameworks**

- **Bootstrap (4.4.1):** Framework CSS yang digunakan untuk membuat antarmuka pengguna responsif dan modern.

11. **Library dan Framework Tambahan**

- **OWL Carousel:** Slider atau carousel berbasis JavaScript untuk menampilkan elemen seperti gambar atau teks.

- **Moment.js (2.9.0):** Library untuk memanipulasi dan memformat tanggal dan waktu.
- **Modernizr (2.6.2):** Library untuk mendeteksi fitur HTML5 dan CSS3 yang **didukung** oleh browser.
- **jQuery (3.4.1):** Library JavaScript yang mempermudah **manipulasi DOM**, event handling, dan animasi.

Hasil analisis ini mencakup berbagai teknologi yang digunakan untuk mendukung pengembangan, fungsionalitas, performa, dan desain web.

2.1.3 Hasil Scanning Web Vulnerability

2.1.3.1 Menggunakan Arachni

Tampilan dibawah ini merupakan hasil dari scanning domain <https://proptsp.sulselprov.go.id> berisi:

- High 4 terdiri dari Cross Site Request Forgery 1, dan Blind SQL Injection (timing attack) 3.

Arachni v1.6.1.3 - WebUI v0.6.1.1

Currently auditing: <https://proptsp.sulselprov.go.id/cgcha/ta7H9CvAT>

Pages discovered	Requests performed	Requests per second	Request concurrency
13	6985	3.18	10

Running for	Responses received	Timed out requests	Response times
10:28:22	6984	2315	1.011s

Issues (18)

Issues may be missing some content until the scan is running. You better wait until the scan is over to review them as the meta-analysis phase will flag probable false-positives and other untrusted issues accordingly.

Severity	URL	Input	Element
High	Cross-Site Request Forgery		
High	Blind SQL Injection (timing attack)		
High	Missing 'Strict-Transport-Security' header		
High	Missing 'X-Frame-Options' header		
High	Placed text with auto-complete		
High	Missing cookie		
High	Missing cookie		
High	Missing cookie		

Cross-Site Request Forgery - 1

In the majority of today's web applications, clients are required to submit forms which can perform sensitive operations. An example of such a form being used would be when an administrator wishes to create a new user for the application. In the simplest version of the form, the administrator would fill in:

- Name
- Password
- Role (out of account)

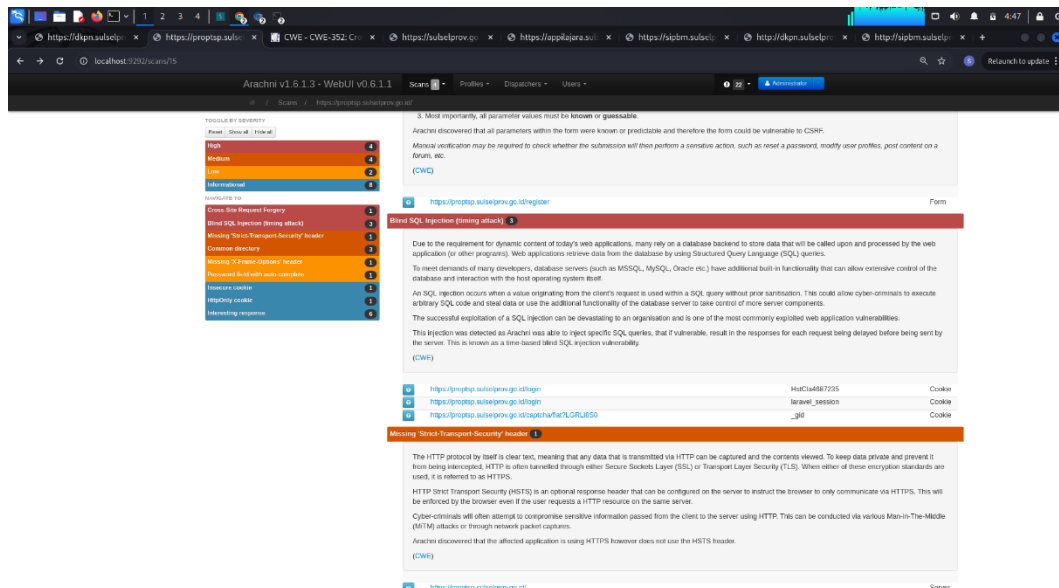
Continuing with this example, Cross Site Request Forgery (CSRF) would occur when the administrator is tricked into clicking on a link, which if logged into the application, would automatically submit the form without any further interaction.

Cyber-criminals will look for sites where sensitive functions are performed in this manner and then craft malicious requests that will be used against clients via a social engineering attack.

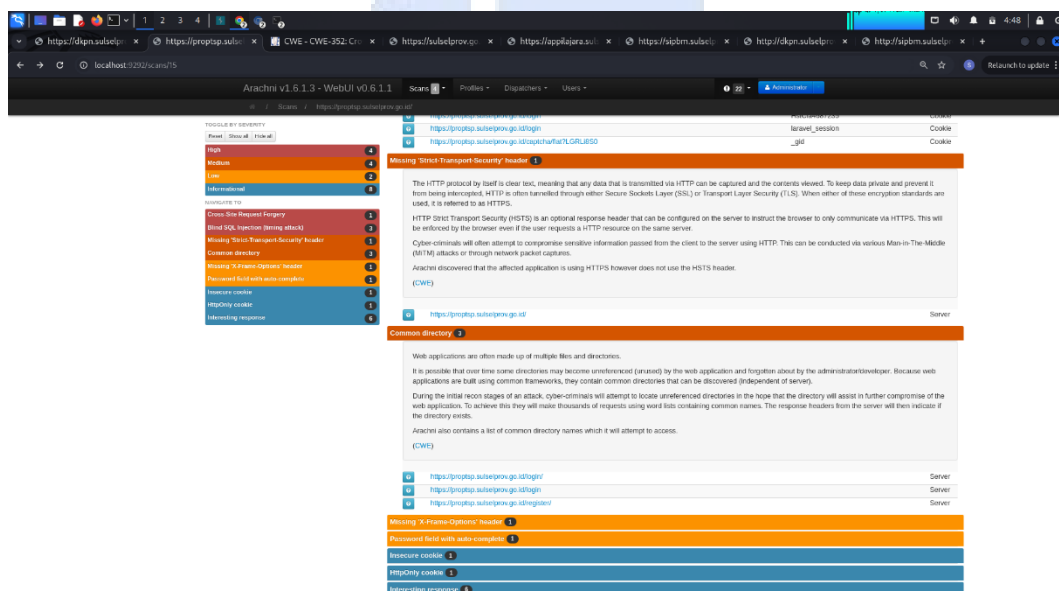
There are 3 things that are required for a CSRF attack to occur:

1. The form must perform some sort of sensitive action.
2. The victim (the administrator the example above) must have an active session.
3. Most importantly, all parameter values must be known or guessable.

- Medium 4 terdiri dari Missing 'Strict-Transport-Security' header 1, dan Common directory 3.

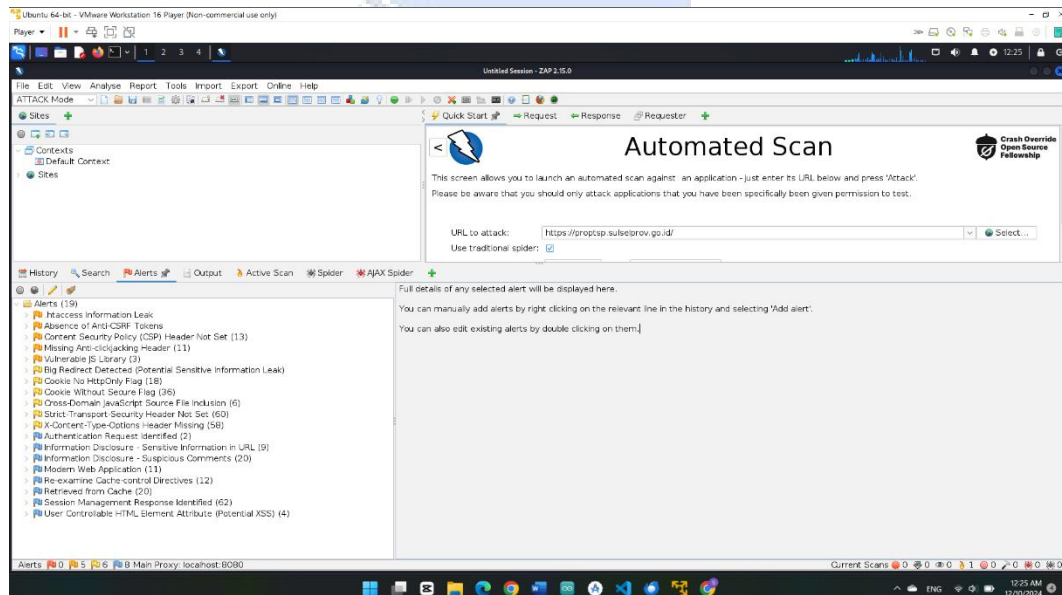


- Low 2 terdiri dari Missing 'X-Frame-Option' header, dan Password field with auto-complete.
- Information 8 yaitu : Insecure cookie, HttpOnly, Interesting response



2.1.3.2 Menggunakan Zap

Pemindaian kerentanan terhadap situs web <https://proptsp.sulselprov.go.id/> mengungkapkan beberapa kelemahan kritis. Situs web ini rentan terhadap serangan clickjacking karena tidak memiliki mekanisme perlindungan yang memadai seperti *header X-Frame-Options* atau *Content Security Policy (CSP)*. Selain itu, kerentanan *Cross-Site Request Forgery (CSRF)* juga terdeteksi akibat kurangnya token CSRF. Lebih lanjut, pemindaian menemukan konfigurasi *Content Security Policy* yang lemah, penggunaan *library JavaScript* yang rentan, serta kelemahan pada pengelolaan cookie. Kerentanan-kerentanan ini berpotensi dieksploitasi oleh penyerang untuk mencuri data sensitif pengguna, mengambil alih akun, atau bahkan menyebarkan malware.



2.1.3.3 Menggunakan Pentest Tools

Berdasarkan hasil scan pada website <https://proptsp.sulselprov.go.id/>, berikut ringkasan temuannya:

Tingkat Risiko Keseluruhan: TINGGI

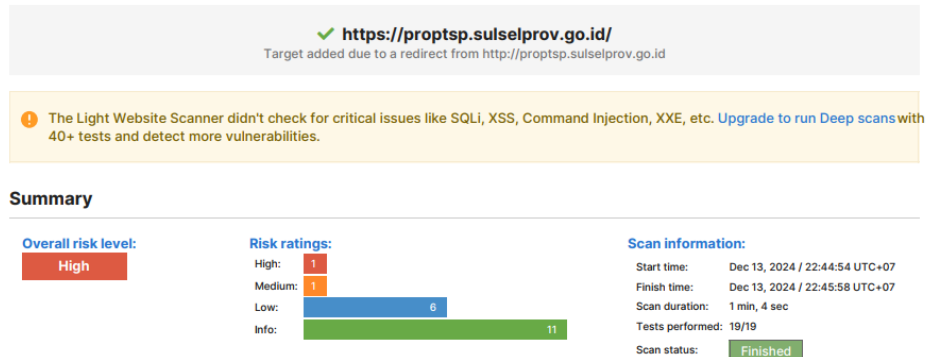
Rincian Risiko:

- Tinggi: 1 temuan
- Menengah: 1 temuan

- Rendah: 6 temuan
- Info: 11 temuan



Website Vulnerability Scanner Report



Masalah Utama yang Ditemukan:

1. Kerentanan Software:

Ditemukan beberapa versi *software* yang memiliki kerentanan keamanan:

- *moment.js* v2.9.0 (CVE-2016-4055, CVE-2017-18214, CVE-2022-24785)
- *jQuery* v3.4.1 (CVE-2020-11023, CVE-2020-11022)

Findings

Vulnerabilities found for server-side software

UNCONFIRMED

Risk Level	CVSS	CVE	Summary	Affected software
High	7.8	CVE-2016-4055	The duration function in the moment package before 2.11.2 for Node.js allows remote attackers to cause a denial of service (CPU consumption) via a long string, aka a "regular expression Denial of Service (ReDoS)."	moment 2.9.0
Medium	5	CVE-2017-18214	The moment module before 2.19.3 for Node.js is prone to a regular expression denial of service via a crafted date string, a different vulnerability than CVE-2016-4055.	moment 2.9.0
Medium	5	CVE-2022-24785	Moment.js is a JavaScript date library for parsing, validating, manipulating, and formatting dates. A path traversal vulnerability impacts npm (server) users of Moment.js between versions 1.0.1 and 2.29.1, especially if a user-provided locale string is directly used to switch moment locale. This problem is patched in 2.29.2, and the patch can be applied to all affected versions. As a workaround, sanitize the user-provided locale name before passing it to Moment.js.	moment 2.9.0
Low	4.3	CVE-2020-11023	In jQuery versions greater than or equal to 1.0.3 and before 3.5.0, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.	jquery 3.4.1
Low	4.3	CVE-2020-11022	In jQuery versions greater than or equal to 1.2 and before 3.5.0, passing HTML from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This problem is patched in jQuery 3.5.0.	jquery 3.4.1

2. Masalah Konfigurasi Keamanan:

- Cookie tidak memiliki *flag 'Secure'*
- Header keamanan yang tidak ada:
 - *Strict-Transport-Security*
 - *Referrer-Policy*
 - *Content-Security-Policy*
 - *X-Content-Type-Options*

Insecure cookie setting: missing Secure flag

CONFIRMED

URL	Cookie Name	Evidence
https://proptsp.sulselprov.go.id/	laravel_session	Set-Cookie: laravel_session=eyJpdil6likhlnXZDcUIBN1J5cniYMTJwYkNqT1E9PSIsInZhbHVlIjoISVRtZm83bUZhZ0hsUjZ0UzN1ZUVJaTN2Y0FzRzZnc044T2Q2ZnM4R3RGbUNyNkQ3WDg3UUUpZcnRrcys3UUdWUE9pbDIHT3R5TkdSUd0TUtlcjUxTVY4aHk2MjZEdDlxOTNlTVR6VHcyN1p3Y3dOMDVZV3doOTgzSXhpNE1QzgiLCJtYWMIQjZDg3NmFkYTAyMjE1NDAwNzc0NGQ1ZmVkZmUwYzJINTFhMzU5MTI2MGYxYzQ2OWRlZDlkYTdlZTk5ZTIkMWU0In0%3D Request / Response

▼ Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : **CWE-614**
 OWASP Top 10 - 2017 : **A6 - Security Misconfiguration**
 OWASP Top 10 - 2021 : **A5 - Security Misconfiguration**

Missing security header: Strict-Transport-Security

CONFIRMED

URL	Evidence
https://proptsp.sulselprov.go.id/	Response headers do not include the HTTP Strict-Transport-Security header Request / Response

▼ Details

Risk description:

The risk is that lack of this header permits an attacker to force a victim user to initiate a clear-text HTTP connection to the server, thus opening the possibility to eavesdrop on the network traffic and extract sensitive information (e.g. session cookies).

Recommendation:

The Strict-Transport-Security HTTP header should be sent with each HTTPS response. The syntax is as follows:

```
Strict-Transport-Security: max-age=<seconds>[; includeSubDomains]
```

The parameter `max-age` gives the time frame for requirement of HTTPS in seconds and should be chosen quite high, e.g. several months. A value below 7776000 is considered as too low by this scanner check.

The flag `includeSubDomains` defines that the policy applies also for sub domains of the sender of the response.

Classification:

CWE : **CWE-693**
 OWASP Top 10 - 2017 : **A6 - Security Misconfiguration**
 OWASP Top 10 - 2021 : **A5 - Security Misconfiguration**

Missing security header: X-Content-Type-Options

CONFIRMED

URL	Evidence
https://proptsp.sulselprov.go.id/	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

Details

Risk description:

The risk is that lack of this header could make possible attacks such as Cross-Site Scripting or phishing in Internet Explorer browsers.

Recommendation:

We recommend setting the X-Content-Type-Options header such as `X-Content-Type-Options: nosniff`.

References:

<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>

Classification:

CWE : CWE-693

OWASP Top 10 - 2017 : A6 - Security Misconfiguration

OWASP Top 10 - 2021 : A5 - Security Misconfiguration

Rekomendasi Utama:

1. Upgrade software yang memiliki kerentanan ke versi terbaru
2. Implementasi header keamanan yang hilang
3. Perbaiki konfigurasi cookie dengan menambahkan flag secure
4. Tinjau dan tingkatkan konfigurasi keamanan secara keseluruhan

Scan dilakukan pada 13 December 2024 dan membutuhkan waktu sekitar 1 menit 4 detik untuk menyelesaikan 19 tes keamanan.

2.1.4 List Vulnerability (Daftar Kerentanan)

No	Kerentanan	Tingkat Kerentanan
1.	Cross-Site Request Forgery	Hight
2.	Blind SQL Injection (timing attack)	
3.	htaccess Information Leak	Medium
4.	Absence of Anti-CSRF Tokens	
5.	Content Security Policy (CSP) Header Not Set	
6.	Missing Anti-clickjacking Header	
7.	Vulnerable JS Library	Low
8.	Big Redirect Detected	
9.	Cookie No HttpOnly Flag	

10.	<i>Cookie Without Secure Flag</i>	
11.	<i>Cross-Domain JavaScript Source File Inclusion</i>	
12.	<i>Strict-Transport-Security Header Not Set</i>	
13.	<i>X-Content-Type-Options Header Missing</i>	
14.	<i>Authentication Request Identified</i>	Informational
15.	<i>Information Disclosure - Sensitive Information in URL</i>	
16.	<i>Information Disclosure - Suspicious Comments</i>	
17.	<i>Modern Web Application</i>	
18.	<i>Re-examine Cache-control Directives</i>	
19.	<i>Retrieved from Cache</i>	
20.	<i>Session Management Response Identified</i>	
21.	<i>User Controllable HTML Element Attribute (Potential XSS)</i>	

2.1.5 Detail Vulnerability

a) High Severity (Tingkat Kerentanan Tinggi)

1. Cross-Site Request Forgery

CSRF memungkinkan penyerang mengirimkan permintaan berbahaya atas nama pengguna yang sudah diautentikasi.

Solusi: Gunakan token CSRF untuk setiap permintaan penting dan validasi token di sisi server. Hindari menerima permintaan yang tidak sah dari domain asing.

2. Blind SQL Injection (timing attack)

Blind SQL Injection memanfaatkan waktu respons server untuk mengekstrak data sensitif dari database.

Solusi: Gunakan parameterized queries atau prepared statements untuk mencegah penyisipan SQL. Validasi dan sanitasi semua input pengguna.

b) Medium Severity (Tingkat Kerentanan Sedang)

1. htaccess Information Leak

File .htaccess yang terekspos dapat memberikan informasi sensitif tentang konfigurasi server, yang dapat dimanfaatkan oleh penyerang.

Solusi: Konfigurasikan server untuk mencegah akses ke file .htaccess.

2. Absence of Anti-CSRF Tokens

Tidak adanya token CSRF memungkinkan penyerang mengirimkan permintaan berbahaya atas nama pengguna yang sudah diautentikasi, menyebabkan **Cross-Site Request Forgery (CSRF)**.

Solusi: Implementasikan token CSRF pada semua formulir dan permintaan penting. Pastikan server memvalidasi token sebelum memproses permintaan. Banyak framework modern seperti Laravel atau Django memiliki fitur bawaan untuk melindungi dari CSRF.

3. Content Security Policy (CSP) Header Not Set

Ketiadaan header **Content Security Policy (CSP)** memungkinkan penyerang memuat skrip berbahaya dari sumber tidak terpercaya, meningkatkan risiko serangan **Cross-Site Scripting (XSS)**.

Solusi: Tambahkan header CSP di konfigurasi server untuk membatasi sumber skrip, gambar, dan konten lainnya.

4. Missing Anti-clickjacking Header

Tanpa header seperti X-Frame-Options, aplikasi web rentan terhadap serangan **clickjacking**, di mana pengguna diarahkan untuk mengklik elemen yang tidak terlihat.

Solusi: Tambahkan header berikut pada konfigurasi server untuk mencegah elemen iframe yang tidak diizinkan: X-Frame-Options: DENY

5. *Vulnerable JS Library*

Penggunaan library JavaScript yang memiliki kerentanan dapat dimanfaatkan untuk menjalankan skrip berbahaya atau mencuri data pengguna.

Solusi: Audit library secara rutin menggunakan tools seperti **Retire.js** atau **npm audit**. Gunakan versi terbaru dari library, atau pertimbangkan untuk mengganti library dengan alternatif yang lebih aman.

c) *Low Severity* (Tingkat Kerentanan Rendah)

1. ***Big Redirect Detected (Low)***

Respons pengalihan yang besar dapat secara tidak sengaja menyertakan informasi sensitif, seperti detail pribadi atau data rahasia, dalam konten respons.

Solusi: Pastikan respons pengalihan tidak menyertakan konten sensitif dan hanya memuat informasi minimal.

2. ***Cookie No HttpOnly Flag (Low)***

Cookie yang tidak memiliki *flag HttpOnly* dapat diakses oleh JavaScript, meningkatkan risiko pencurian cookie dan sesi pengguna.

Solusi: Tambahkan *flag HttpOnly* pada semua cookie untuk mencegah akses melalui JavaScript.

3. ***Cookie Without Secure Flag (Low)***

Cookie tanpa *flag Secure* dapat dikirim melalui koneksi tidak terenkripsi, sehingga berisiko bocor pada serangan *man-in-the-middle*.

Solusi: Tetapkan *flag Secure* untuk memastikan cookie hanya dikirim melalui koneksi HTTPS.

4. ***Cross-Domain JavaScript Source File Inclusion (Low)***

Memuat *JavaScript* dari domain pihak ketiga yang tidak diverifikasi dapat membuka aplikasi terhadap serangan injeksi skrip berbahaya.

Solusi: Pastikan *file JavaScript* hanya dimuat dari sumber terpercaya.

5. ***Strict-Transport-Security Header Not Set (Low)***

Ketiadaan *header HTTP Strict Transport Security (HSTS)* memungkinkan koneksi tidak aman, seperti HTTP, atau serangan *downgrade*.

Solusi: Tambahkan *header Strict-Transport-Security* untuk memastikan komunikasi hanya melalui HTTPS.

6. ***X-Content-Type-Options Header Missing (Low)***

Tanpa *header X-Content-Type-Options*, browser dapat melakukan *MIME-sniffing* pada isi respons, berpotensi menginterpretasikan konten sebagai tipe yang berbeda dari yang diharapkan.

Solusi: Tetapkan *header X-Content-Type-Options: nosniff* pada semua respons untuk mencegah *MIME-sniffing*.

2.1.6 ***Vulnerability Assessment (Pengujian Kerentanan)***

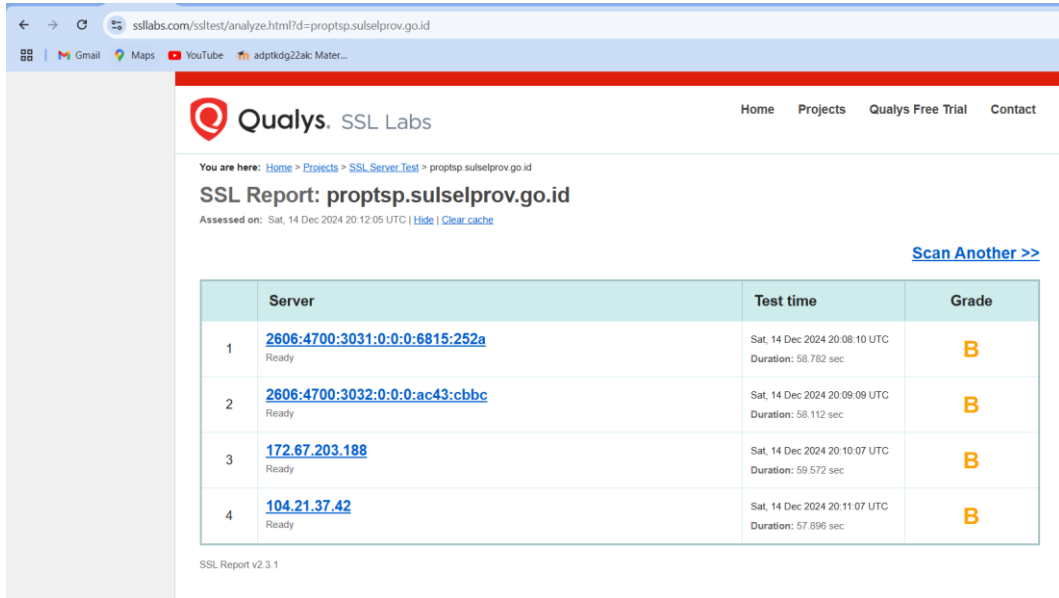
a) ***SSL Report***

Gambar dibawah ini menunjukkan hasil *SSL Report* dari *Qualys SSL Labs* untuk domain *proptsp.sulselprov.go.id* yang diuji pada 14 December 2024. Laporan menunjukkan, ada 4 server yang diuji dengan hasil:

- Server 1 (2606:4700:3031:0:0:0:6815:252a) - Grade B
- Server 2 (2606:4700:3032:0:0:0:ac43:cbbc) - Grade B
- Server 3 (172.67.203.188) - Grade B
- Server 4 (104.21.37.42) - Grade B

Semua server mendapatkan nilai B dalam pengujian SSL dengan durasi tes sekitar 57-59 detik untuk masing-masing server. Status

semua server adalah "Ready" yang menunjukkan pengujian telah selesai dilakukan. Grade B mengindikasikan bahwa konfigurasi SSL pada server cukup baik namun masih ada ruang untuk peningkatan keamanan.



	Server	Test time	Grade
1	2606:4700:3031:0:0:6815:252a Ready	Sat, 14 Dec 2024 20:08:10 UTC Duration: 58.782 sec	B
2	2606:4700:3032:0:0:ac43:cbbc Ready	Sat, 14 Dec 2024 20:09:09 UTC Duration: 58.112 sec	B
3	172.67.203.188 Ready	Sat, 14 Dec 2024 20:10:07 UTC Duration: 59.572 sec	B
4	104.21.37.42 Ready	Sat, 14 Dec 2024 20:11:07 UTC Duration: 57.896 sec	B

SSL Report v2.3.1

b) ClickJacking

Clickjacking adalah serangan berbasis antarmuka di mana pengguna ditipu agar mengklik konten yang dapat ditindaklanjuti di situs web tersembunyi dengan mengklik beberapa konten lain di situs web tipuan.

1. Deskripsi/Penjelasan:

Clickjacking adalah gabungan dari dua kata 'klik' dan 'pembajakan'. Ini mengacu pada pembajakan klik pengguna untuk tujuan jahat. Di dalamnya, penyerang menyematkan situs yang rentan dalam iframe transparan di situs web penyerang dan melapisinya dengan objek seperti tombol menggunakan keterampilan CSS. Ini menipu pengguna untuk melakukan tindakan yang tidak diinginkan di situs web yang rentan, mengira mereka melakukan tindakan tersebut di situs web penyerang. Clickjacking, juga dikenal sebagai "serangan ganti rugi UI".

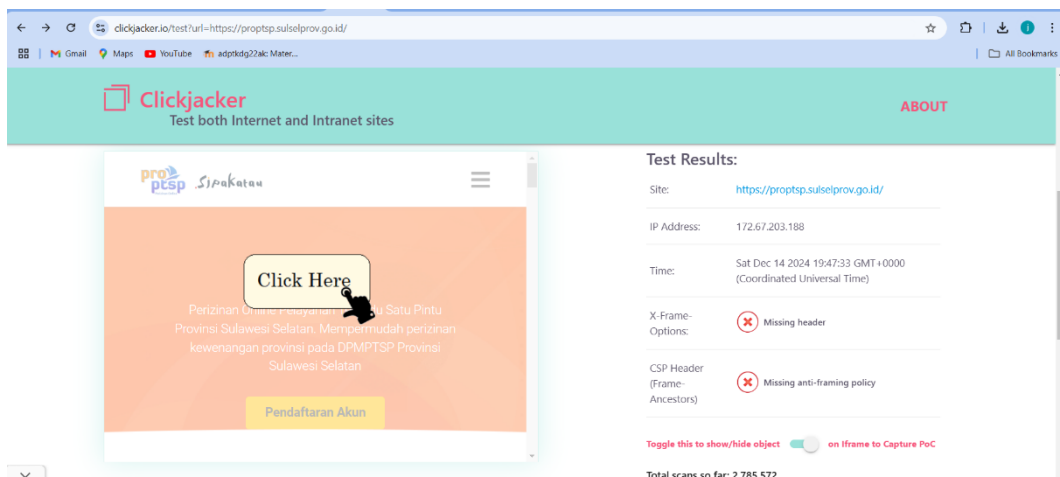
2. Dampak:

Pengguna tertipu untuk melakukan segala macam tindakan yang tidak diinginkan seperti mengetikkan kata sandi, mengklik tombol 'Hapus akun saya', menyukai postingan, menghapus postingan, mengomentari blog. Dengan kata lain semua tindakan yang dapat dilakukan pengguna biasa di situs web yang sah dapat dilakukan dengan menggunakan clickjacking.

Gambar dibawah ini menunjukkan hasil pengujian keamanan *website* menggunakan *tools "Clickjacker"* yang digunakan untuk menguji kerentanan clickjacking pada situs internet dan intranet. Dari hasil test tersebut menunjukkan:

1. *Website* yang diuji: <https://proptsp.sulselprov.go.id/>
2. *IP Address*: 172.67.203.188
3. Waktu pengujian: Sat Dec 14 2024 19:47:13 GMT+0000
4. Ditemukan 2 masalah keamanan:
 - *Missing header* (Header yang hilang)
 - *Missing anti-framing policy* (Kebijakan *anti-framing* yang hilang)

Total pemindaian yang telah dilakukan oleh *tools* ini adalah 2,785,572 kali. Tool ini berguna untuk mengidentifikasi potensi kerentanan *clickjacking* pada sebuah *website*, yang bisa dimanfaatkan penyerang untuk mengelabui pengguna melakukan klik yang tidak diinginkan.



Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://proptsp.sulselprov.go.id/site/login</title>
  <script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
      alert("Warning: hak akses dari kelompok 7");
      // Menampilkan pesan di dalam elemen dengan id "warning-message"
      document.getElementById("warning-message").innerText = "Website
ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
  </script>
  <style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
      height: 100%;
      margin: 0;
      padding: 0;
      overflow: hidden;
    }

    /* Menyusun iframe untuk mengisi seluruh layar */
    iframe {
      width: 100%;
      height: 100%;
      border: none;
```

```
opacity: 15;
}

/* Menyusun pesan peringatan */
#warning-message {
    position: absolute;
    top: 20px;
    left: 20px;
    background-color: rgba(19, 18, 18, 0.7);
    color: white;
    padding: 10px;
    border-radius: 5px;
    z-index: 10;
}
```

```
/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
    z-index: 10;
    position: absolute;
    top: 100px;
    left: 20px;
    padding: 10px 20px;
    background-color: #100f0f;
    color: white;
    border: none;
    cursor: pointer;
    font-size: 16px;
}
```

```
/* Efek hover pada tombol */
input[type="button"]:hover {
    background-color: #426043;
```

```

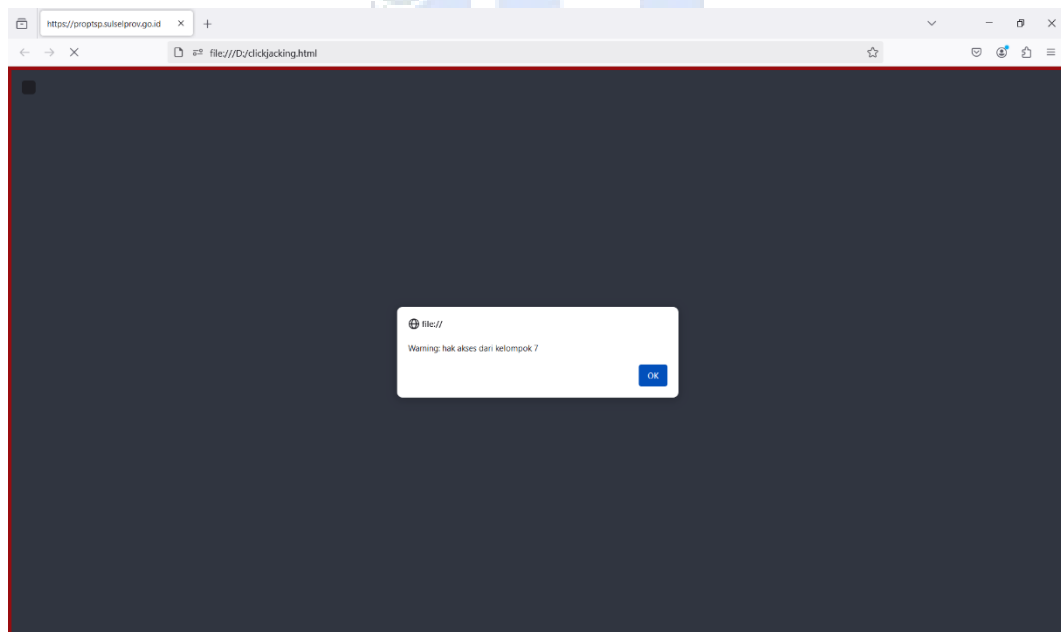
    }
  </style>
</head>

<body>
  <div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->
  <iframe src="https://proptsp.sulselprov.go.id/"></iframe>
</body>

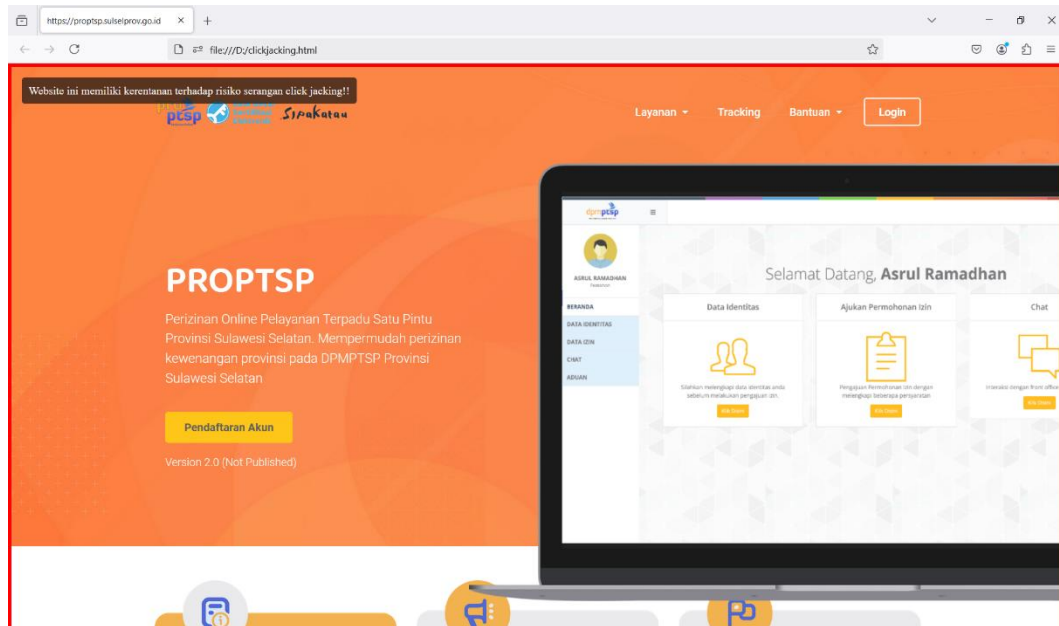
</html>

```

Setelah selesai simpan file di Visual StudioCodanya contoh: **euybchc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul *Warning* dalam bentuk *PopUp* dengan tulisan “**Warning: hak akses dari kelompok 7**”



Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <https://proptsp.sulselprov.go.id> yang mana pada bagian pojok kiri menunjukkan adanya peringatan : ***“Website ini memiliki kerentanan terhadap risiko serangan click jacking!!”***

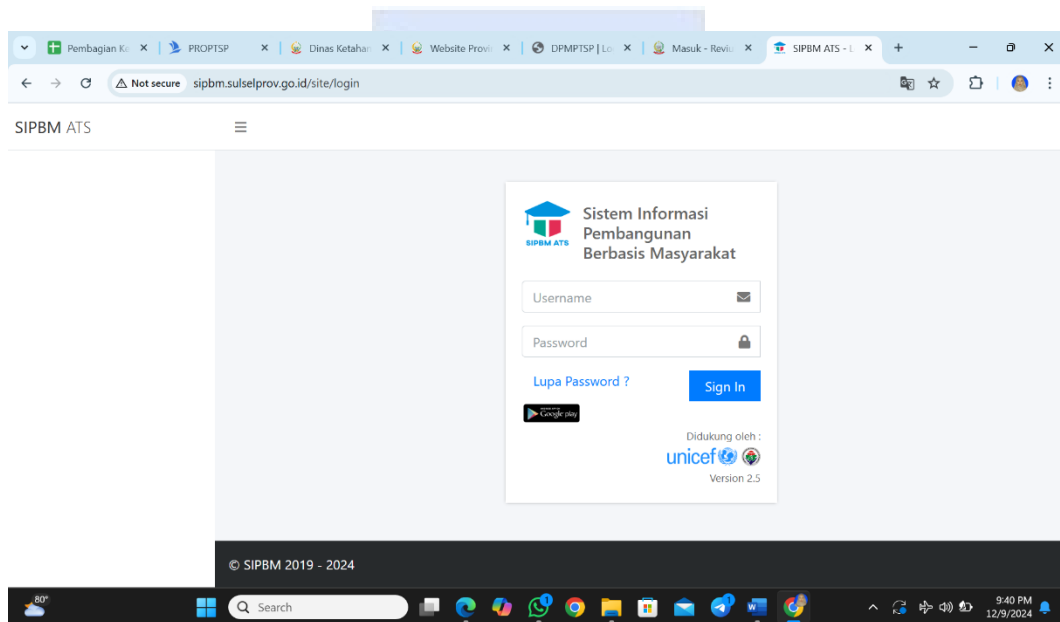


GAMA MULTI GROUP

2.2 Sistem Informasi Pembangunan Berbasis Masyarakat (<http://sipbm.sulselprov.go.id/site/login>)

2.2.1 Informasi Website

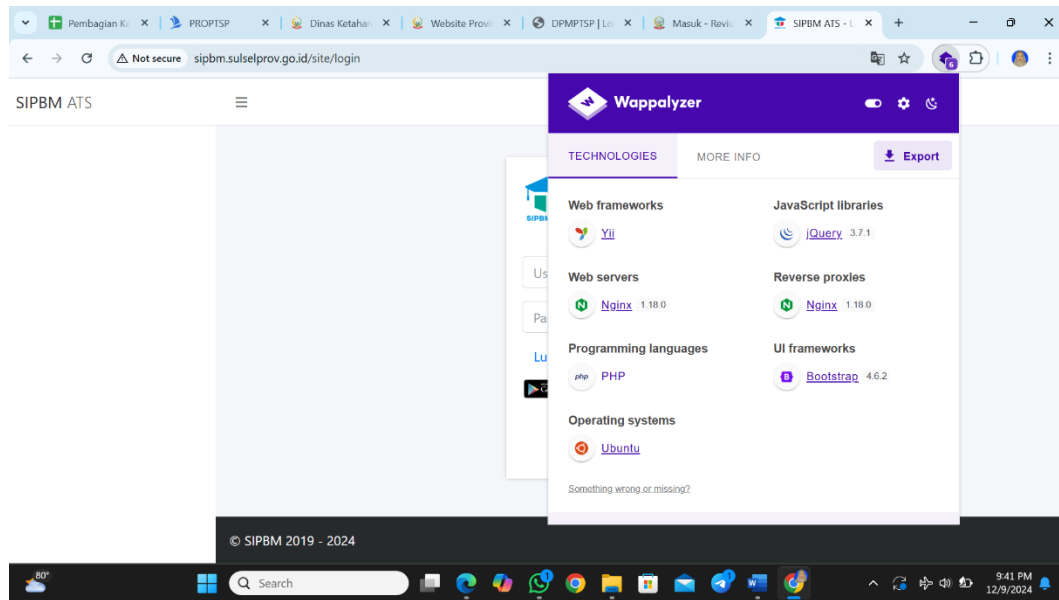
Sistem Informasi Pembangunan Berbasis Masyarakat (SIPBM) di Provinsi Sulawesi Selatan dapat menjadi platform digital yang mendukung pengumpulan, pengolahan, dan pemanfaatan informasi berbasis partisipasi masyarakat. Sistem ini bertujuan untuk meningkatkan kinerja pembangunan melalui keterlibatan masyarakat dalam proses perancangan, pelaksanaan, dan pemantauan pembangunan. Dengan SIPBM, pemerintah daerah dapat lebih akurat dalam menentukan kebutuhan dan permasalahan masyarakat, seperti mencegah angka putus sekolah atau meningkatkan pelayanan publik, dengan memanfaatkan informasi yang terintegrasi dalam kurun waktu tertentu.



2.2.2 Pengumpulan Informasi Teknologi

a) Wapplyzer

Wapplyzer adalah sebuah alat yang digunakan untuk mendeteksi teknologi apa saja yang digunakan oleh sebuah situs web.



Teknologi yang Digunakan pada Situs Web:

Berdasarkan hasil pemindaian Wappalyzer, situs web tersebut menggunakan teknologi-teknologi berikut:

- **PHP dengan Framework Yii:** Ini adalah bahasa pemrograman utama dan kerangka kerja yang digunakan untuk membangun situs web.
- **jQuery:** Sebuah library JavaScript yang populer untuk membuat situs web lebih interaktif.
- **Nginx:** Server web yang digunakan untuk menyajikan konten situs web.
- **Bootstrap:** Framework CSS yang digunakan untuk membuat tampilan situs web menjadi lebih menarik dan responsif.
- **Ubuntu:** Sistem operasi yang digunakan untuk menjalankan server situs web.

Secara sederhana, situs web ini dibangun menggunakan kombinasi teknologi populer yang umum digunakan untuk membuat situs web modern dan dinamis.

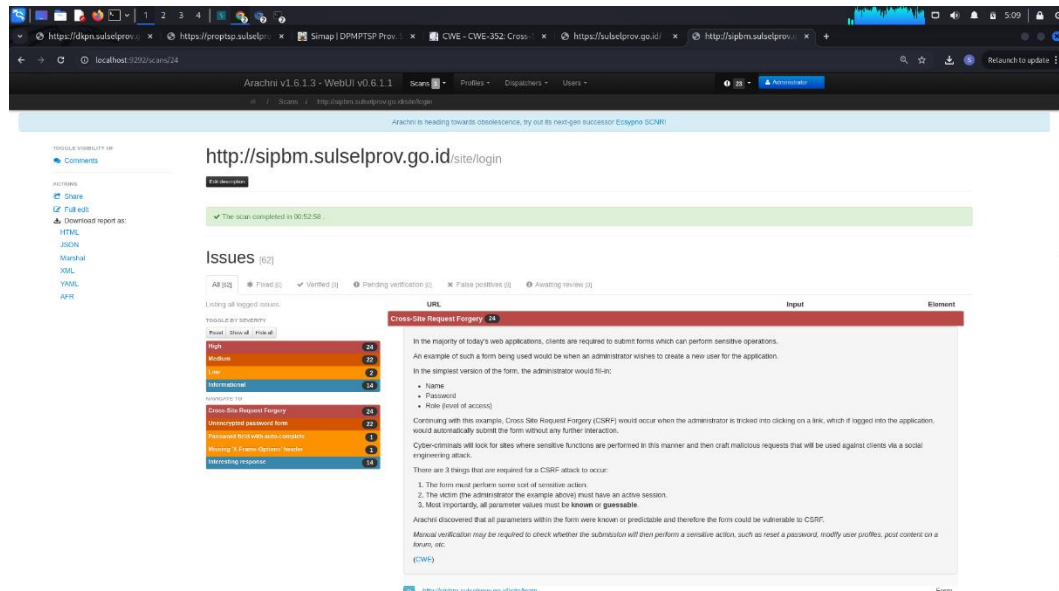
b) WhatWeb

WhatWeb adalah alat open-source yang digunakan untuk mendeteksi dan mengidentifikasi teknologi yang digunakan oleh situs web. Hasil yang didapatkan yaitu:

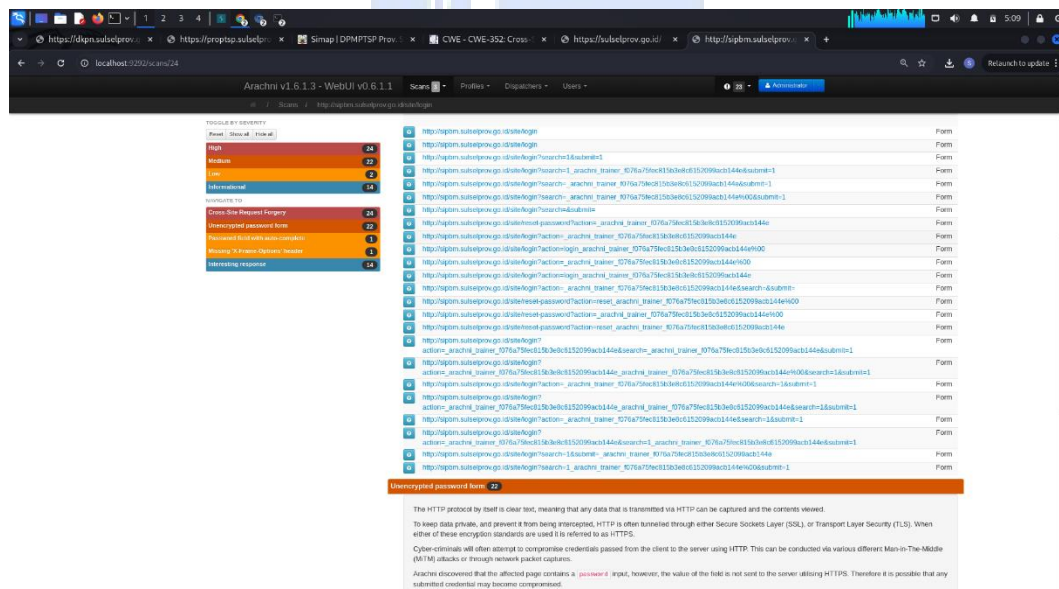
- [illegible]

<http://sipbm.sulselprov.go.id/site/login> berisi:

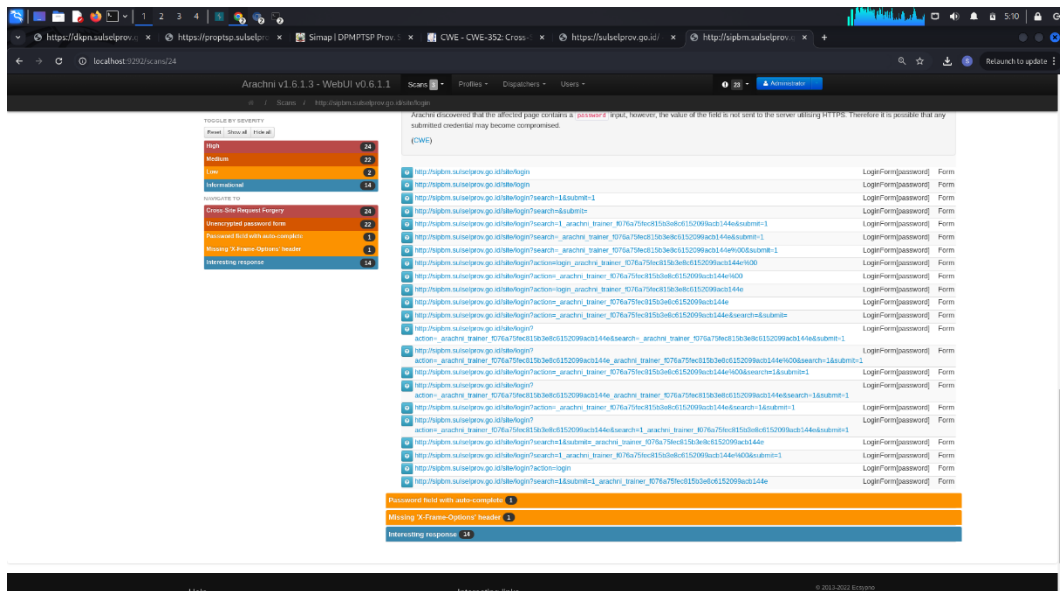
▫ High 24 yaitu *Cross Site Request Forgery*



▫ Medium 22 yaitu *Unencrypted password form*



- Low 2 terdiri dari Missing 'X-Frame-Option' header, dan Password field with auto-complete.
- Information 14 yaitu Interesting respons



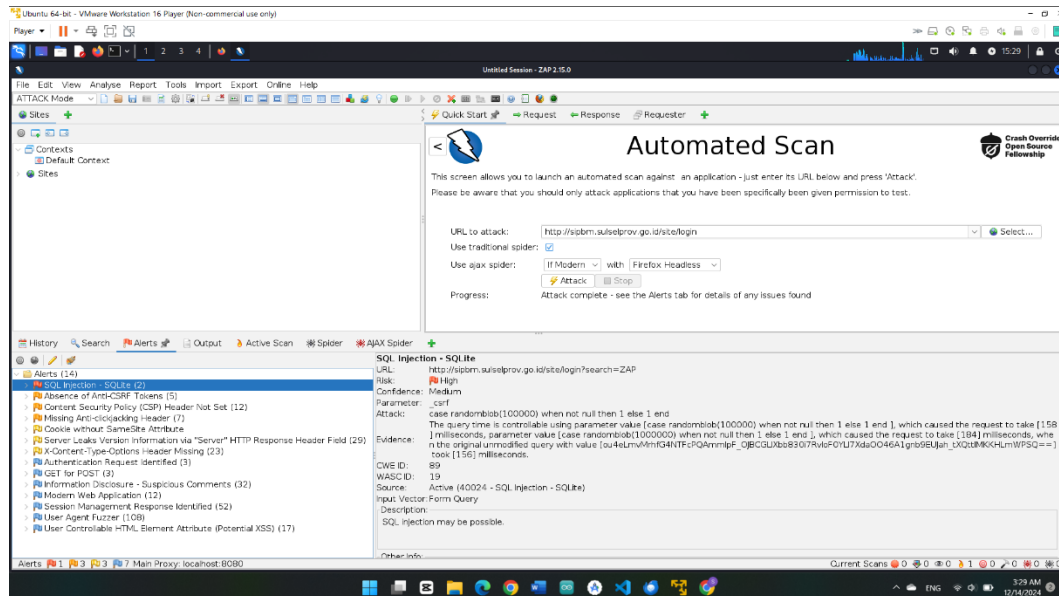
2.2.3.2 Menggunakan Zap

Gambar yang disajikan menunjukkan hasil pemindaian keamanan menggunakan **ZAP (Zed Attack Proxy)** pada situs web <http://sipbm.sulselprov.go.id/site/login>.

ZAP adalah alat yang digunakan untuk mendeteksi potensi kerentanan pada aplikasi web secara otomatis. Berikut adalah poin-poin utama dari pemindaian:

- **Pemindaian:** ZAP melakukan analisis otomatis terhadap situs target.
- **Temuan Kerentanan:** Beberapa kerentanan keamanan teridentifikasi, yang membutuhkan perhatian lebih lanjut.
- **Jenis Kerentanan:** Kerentanan mencakup SQL Injection, absennya header keamanan penting, dan masalah terkait lainnya.

Temuan ini memberikan wawasan penting untuk meningkatkan keamanan situs web dengan memperbaiki kelemahan yang teridentifikasi.



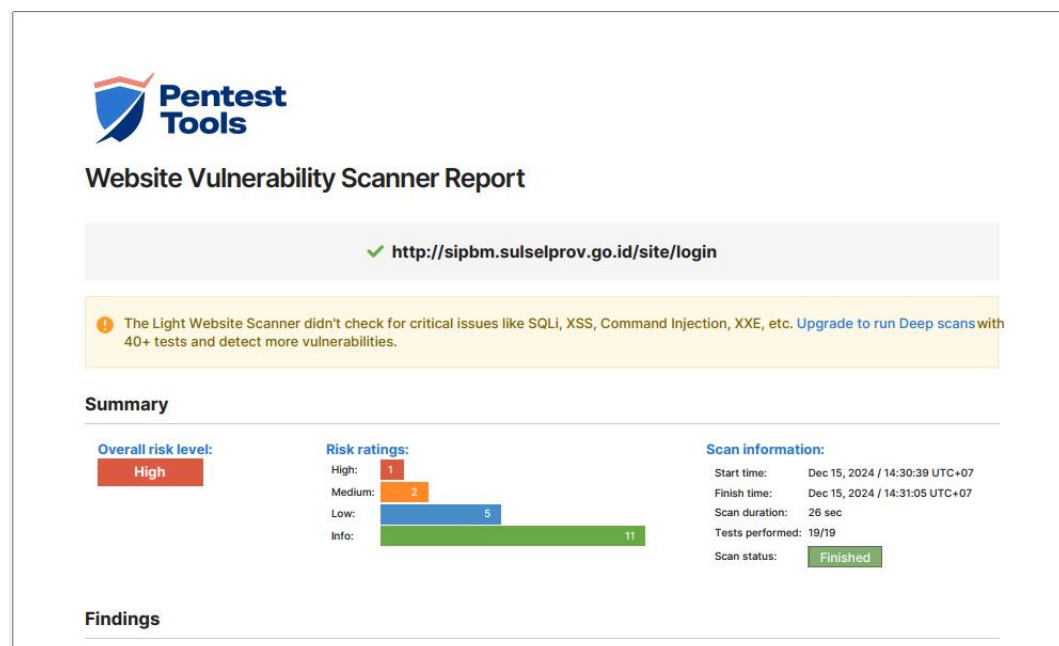
2.2.3.3 Menggunakan Pentest Tools

Berdasarkan hasil pemindaian keamanan website <http://sipbm.sulselprov.go.id/site/login>, berikut ringkasan temuannya:

Tingkat Risiko Keseluruhan: **TINGGI**

Rincian Risiko:

- Tinggi: 1 temuan
- Menengah: 2 temuan
- Rendah: 5 temuan
- Info: 11 temuan



Masalah Utama yang Ditemukan:

1. Kerentanan Software Server (NGINX 1.18.0):

- Memiliki beberapa CVE (kerentanan) dengan skor CVSS tinggi
- CVE-2022-41741 (skor 7.8)
- CVE-2023-44487 (skor 7.5)
- CVE-2022-41742 (skor 7.1)
- CVE-2021-23017 (skor 6.8)
- CVE-2021-3618 (skor 5.8)

analyzer-https... Website_Scanner-https... Website_Scanner-https... Website_Scanner-https... Website_Scanner-h... X

Vulnerabilities found for server-side software UNCONFIRMED

Risk Level	CVSS	CVE	Summary	Affected software
●	7.8	CVE-2022-41741	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a specially crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.18.0
●	7.5	CVE-2023-44487	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.	nginx 1.18.0
●	7.1	CVE-2022-41742	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.18.0
●	6.8	CVE-2021-23017	A security issue in nginx resolver was identified, which might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.	nginx 1.18.0
●	5.8	CVE-2021-3618	ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MITM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.	nginx 1.18.0

2. Masalah Keamanan Komunikasi:

- Website menggunakan HTTP (tidak terenkripsi) bukan HTTPS
- Cookie tidak memiliki flag "Secure"
- Beberapa security header penting tidak ada:
 - Content-Security-Policy
 - X-Content-Type-Options
 - Referrer-Policy

anner-https... Website_Scanner-https... Website_Scanner-https... Website_Scanner-https... Website_Scanner-h... x

▼ Details

Risk description:
The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

1 / 6

Recommendation:
In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:
CWE : [CWE-1026](#)
OWASP Top 10 - 2017 : [A9 - Using Components with Known Vulnerabilities](#)
OWASP Top 10 - 2021 : [A6 - Vulnerable and Outdated Components](#)

🚩 **Communication is not secure** CONFIRMED

URL	Response URL	Evidence
http://sipbm.sulselprov.go.id/site/login	http://sipbm.sulselprov.go.id/site/login	Communication is made over unsecure, unencrypted HTTP.

▼ Details

Risk description:
The risk is that an attacker who manages to intercept the communication at the network level can read and modify the data transmitted (including passwords, secret tokens, credit card information and other sensitive data).

Recommendation:
We recommend you to reconfigure the web server to use HTTPS - which encrypts the communication between the web browser and the server.

Classification:
CWE : [CWE-311](#)
OWASP Top 10 - 2017 : [A3 - Sensitive Data Exposure](#)
OWASP Top 10 - 2021 : [A4 - Insecure Design](#)

Rekomendasi Utama:

1. Upgrade NGINX ke versi terbaru untuk mengatasi kerentanan
2. Implementasi HTTPS untuk mengamankan komunikasi
3. Perbaiki konfigurasi cookie dan security header
4. Tambahkan file security.txt untuk pelaporan masalah keamanan

2.2.4 List Vulnerability (Daftar Kerentanan)

No	Kerentanan	Tingkat Kerentanan
1.	SQL Injection - SQLite	High
2.	Cross-Site Request Forgery	
3.	Unencrypted password form	Medium
4.	Absence of Anti-CSRF Tokens	
5.	Content Security Policy (CSP) Header Not Set	
6.	Missing Anti-clickjacking Header	
7.	Password Field with auto-complete	Low

8.	Missing 'X-Frame-Options' header	
9.	Cookie without SameSite Attribute	
10.	Server Leaks Version Information via HTTP Header	
11.	X-Content-Type-Options Header Missing	
12.	Authentication Request Identified	Informational
13.	Information Disclosure - Suspicious Comments	
14.	Modern Web Application	
15.	Session Management Response Identified	
16.	User Controllable HTML Element Attribute (Potential XSS)	

2.2.5 Detail Vulnerability

a. **High Severity (Tingkat Kerentanan Tinggi)**

1. *SQL Injection – SQLite*

Kerentanan ini memungkinkan penyerang menyisipkan perintah SQL berbahaya melalui input pengguna.

Solusi: Gunakan parameterized query atau prepared statement untuk semua interaksi database. Hindari menggunakan query SQL dinamis berbasis input langsung.

2. *Cross-Site Request Forgery*

Penyerang dapat mengelabui pengguna untuk melakukan tindakan tidak sah di aplikasi.

Solusi: Implementasikan token CSRF untuk setiap permintaan sensitif. Gunakan framework yang mendukung proteksi CSRF.

b. **Medium Severity (Tingkat Kerentanan Sedang)**

1. *Unencrypted password form*

Formulir kata sandi tidak dienkripsi, sehingga rentan terhadap serangan sniffing.

Solusi: Selalu gunakan HTTPS untuk semua komunikasi, terutama untuk data sensitif seperti kata sandi.

2. *Absence of Anti-CSRF Tokens*

Tidak adanya token anti-CSRF membuat aplikasi rentan terhadap serangan CSRF. **Solusi:** Tambahkan token CSRF yang unik pada setiap permintaan form dan verifikasi token tersebut di server.

3. *Content Security Policy (CSP) Header Not Set*

Tidak adanya header CSP memungkinkan injeksi konten berbahaya seperti XSS.

Solusi: Set header Content-Security-Policy untuk membatasi sumber daya yang dapat dimuat oleh aplikasi.

4. *Missing Anti-clickjacking Header*

Tanpa header ini, aplikasi dapat dibingkai oleh situs jahat, memungkinkan serangan clickjacking.

Solusi: Set header X-Frame-Options ke "DENY" atau "SAMEORIGIN".

c. **Low Severity (Tingkat Kerentanan Rendah)**

1. *Cookie without SameSite Attribute*

Cookie ditetapkan tanpa atribut *SameSite*, memungkinkan pengiriman cookie lintas situs yang dapat dieksploitasi untuk serangan CSRF atau XSS.

Solusi : Tetapkan atribut *SameSite* ke 'lax' atau 'strict' untuk semua cookie.

2. *Server Leaks Version Information via HTTP Header*

Informasi versi server dibocorkan melalui header HTTP "Server", memudahkan penyerang untuk menemukan kerentanan lain.

Solusi : Hapus header "Server" atau ubah untuk memberikan informasi umum saja.

3. *X-Content-Type-Options Header Missing*

Header X-Content-Type-Options tidak disetel ke '*nosniff*', memungkinkan browser melakukan *MIME-sniffing* yang dapat menyebabkan interpretasi konten salah.

Solusi : Tetapkan *header X-Content-Type-Options* ke '*nosniff*' untuk semua halaman web.

2.2.6 Vulnerability Assessment (Pengujian Kerentanan)

a) SSL Report

Hasil dari SSL Report untuk domain sipbm.sulselprov.go.id menunjukkan beberapa masalah utama:

1. Penilaian gagal (Assessment failed) karena tidak dapat terhubung ke server
2. IP server: 103.151.191.85
3. Waktu penilaian: Sabtu, 14 Desember 2024

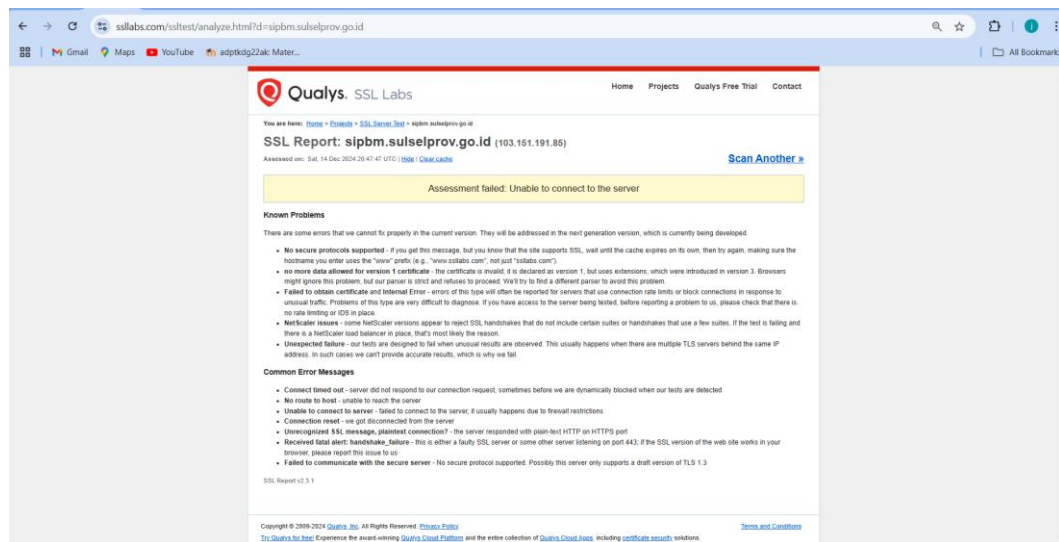
Beberapa masalah yang teridentifikasi:

- Tidak ada protokol secure yang didukung
- Masalah sertifikat data versi 1
- Gagal mendapatkan sertifikat dan error internal
- Masalah NetScaler
- Kegagalan tidak terduga

Pesan error umum yang muncul termasuk:

- Connection timeout
- No route to host
- Tidak dapat terhubung ke server
- Connection reset
- Pesan SSL tidak dikenali
- Fatal alert handshake failure

Secara keseluruhan, laporan menunjukkan ada masalah serius dengan konfigurasi SSL/TLS pada server tersebut yang perlu diperbaiki untuk mengamankan koneksi.



Server ini tidak mendukung protokol SSL/TLS apa pun, yang berarti tidak ada komunikasi terenkripsi melalui HTTPS di port 80 maupun port 3306

```
(muhammadariqni@kali) - [~/testssl.sh]
$ ./testssl.sh --protocols 103.151.191.85:80

#####
testssl.sh version 3.2rc3 from https://testssl.sh/dev/
(701c606 2024-11-27 11:39:25)

This program is free software. Distribution and modification under
GPLv2 permitted. USAGE w/o ANY WARRANTY. USE IT AT YOUR OWN RISK!

Please file bugs @ https://testssl.sh/bugs/

#####

Using OpenSSL 1.0.2-bad [~183 ciphers]
on kali:./bin/openssl.Linux.x86_64

Start 2024-12-17 23:36:34 → 103.151.191.85:80 (103.151.191.85) ←

rDNS (103.151.191.85): --

103.151.191.85:80 doesn't seem to be a TLS/SSL enabled server
The results might look ok but they could be nonsense. Really proceed? ("yes" to continue) → yes
Service detected: Couldn't determine what's running on port 80, assuming no HTTP service ⇒ skipping all HTTP checks

Testing protocols via sockets except NPN+ALPN

SSLv2    not offered (OK)
SSLv3    not offered (OK)
TLS 1     not offered
TLS 1.1   not offered
TLS 1.2   not offered
TLS 1.3   not offered

You should not proceed as no protocol was detected. If you still really really want to, say "YES" → yes
```

b) ClickJacking

Clickjacking adalah serangan berbasis antarmuka di mana pengguna ditipu agar mengklik konten yang dapat ditindaklanjuti di situs web tersembunyi dengan mengklik beberapa konten lain di situs web tipuan.

1. Deskripsi/Penjelasan:

Clickjacking adalah gabungan dari dua kata 'klik' dan 'pembajakan'. Ini mengacu pada pembajakan klik pengguna untuk tujuan jahat. Di dalamnya, penyerang menyematkan situs yang rentan dalam iframe transparan di situs web penyerang dan melapisinya dengan objek seperti tombol menggunakan keterampilan CSS. Ini menipu pengguna untuk melakukan tindakan yang tidak diinginkan di situs web yang rentan, mengira mereka melakukan tindakan tersebut di situs web penyerang. Clickjacking, juga dikenal sebagai "serangan ganti rugi UI".

2. Dampak:

Pengguna tertipu untuk melakukan segala macam tindakan yang tidak diinginkan seperti mengetikkan kata sandi, mengklik tombol 'Hapus akun saya', menyukai postingan, menghapus postingan, mengomentari blog. Dengan kata lain semua tindakan yang dapat dilakukan pengguna biasa di situs web yang sah dapat dilakukan dengan menggunakan clickjacking.

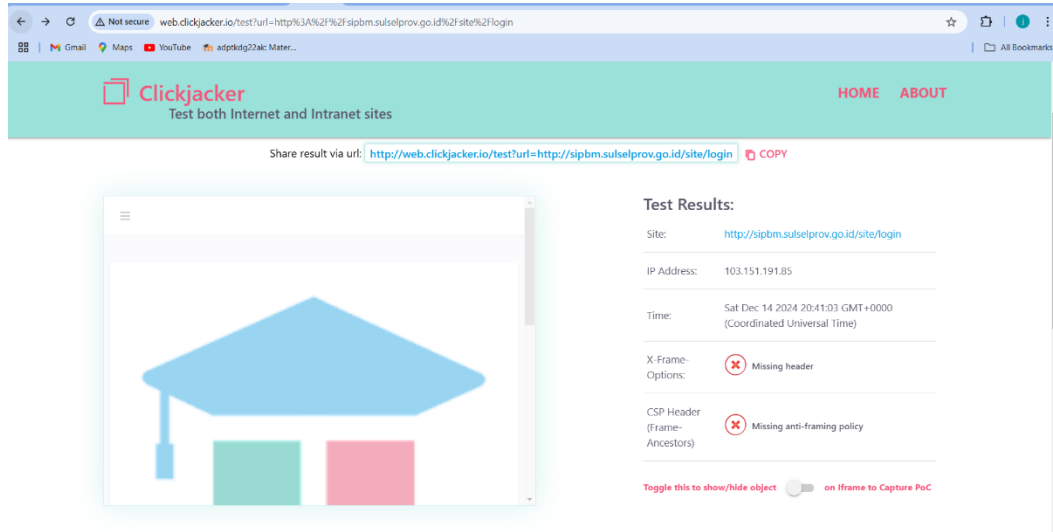
Hasil tes dari Clickjacking menunjukkan:

1. Website yang diuji: <http://sipbm.sulselprov.go.id/site/login>
2. IP Address: 103.151.191.85
3. Waktu pengujian: 14 Dec 2024 20:41:03 GMT

Ditemukan 2 masalah keamanan:

- X-Frame-Options header tidak ada
- CSP Header (Frame-Ancestors) tidak memiliki kebijakan anti-framing

Ini menunjukkan bahwa website tersebut berpotensi rentan terhadap serangan clickjacking karena tidak memiliki proteksi frame yang memadai.



Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://sipbm.sulselprov.go.id/site/login</title>
  <script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
      alert("Warning: hak akses dari kelompok 7");
      // Menampilkan pesan di dalam elemen dengan id "warning-message"
      document.getElementById("warning-message").innerText = "Website
ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
  </script>
  <style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
      height: 100%;
```

```
margin: 0;
padding: 0;
overflow: hidden;
}

/* Menyusun iframe untuk mengisi seluruh layar */
iframe {
width: 100%;
height: 100%;
border: none;
opacity: 15;
}

/* Menyusun pesan peringatan */
#warning-message {
position: absolute;
top: 20px;
left: 20px;
background-color: rgba(19, 18, 18, 0.7);
color: white;
padding: 10px;
border-radius: 5px;
z-index: 10;
}

/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
z-index: 10;
position: absolute;
top: 100px;
left: 20px;
padding: 10px 20px;
```

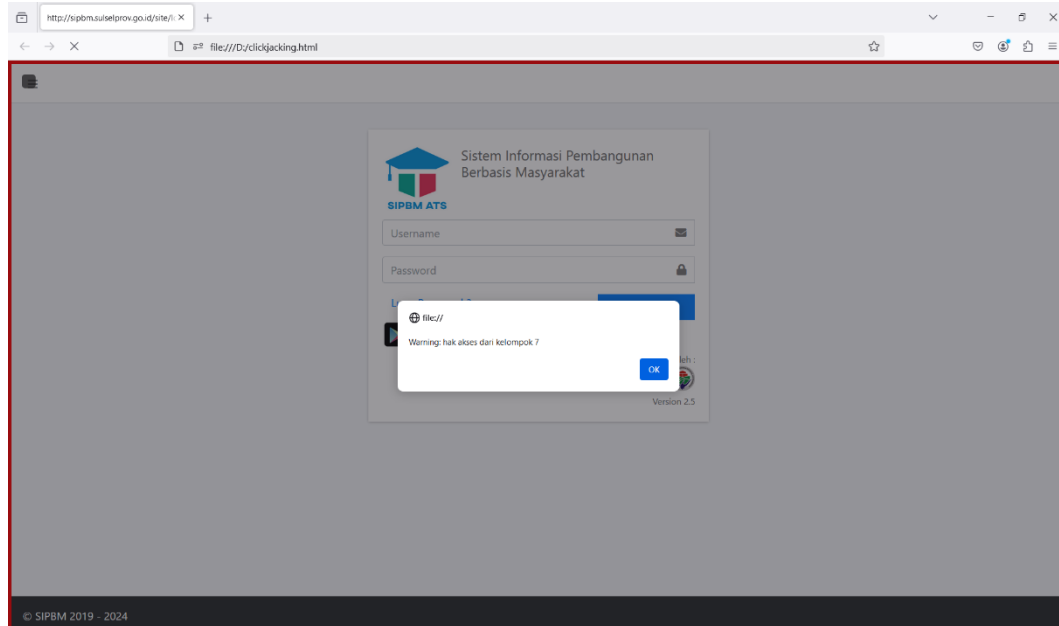
```
background-color: #100f0f;
color: white;
border: none;
cursor: pointer;
font-size: 16px;
}

/* Efek hover pada tombol */
input[type="button"]:hover {
background-color: #426043;
}
</style>
</head>

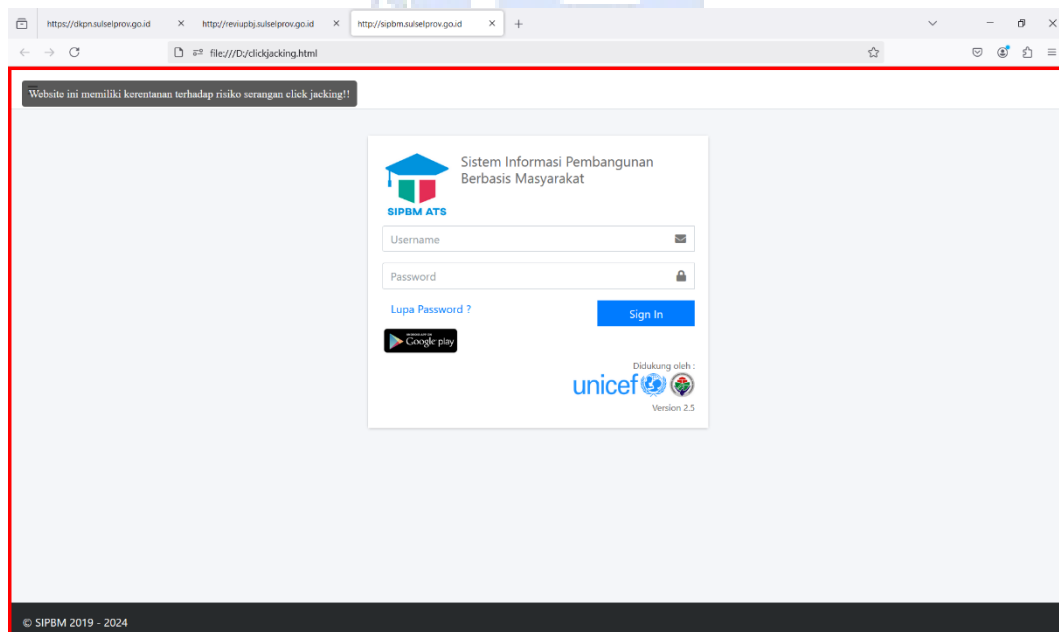
<body>
<div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->
<iframe src="https://sipbm.sulselprov.go.id/"></iframe>
</body>

</html>
```

Setelah selesai simpan file di Visual StudioCodanya contoh:**euybchc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul *Warning* dalam bentuk *PopUp* dengan tulisan “**Warning: hak akses dari kelompok 7**”



Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <https://sipbm.sulselprov.go.id/site/login> yang mana pada bagian pojok kiri menunjukkan adanya peringatan : ***“Website ini memiliki kerentanan terhadap risiko serangan click jacking!!”***

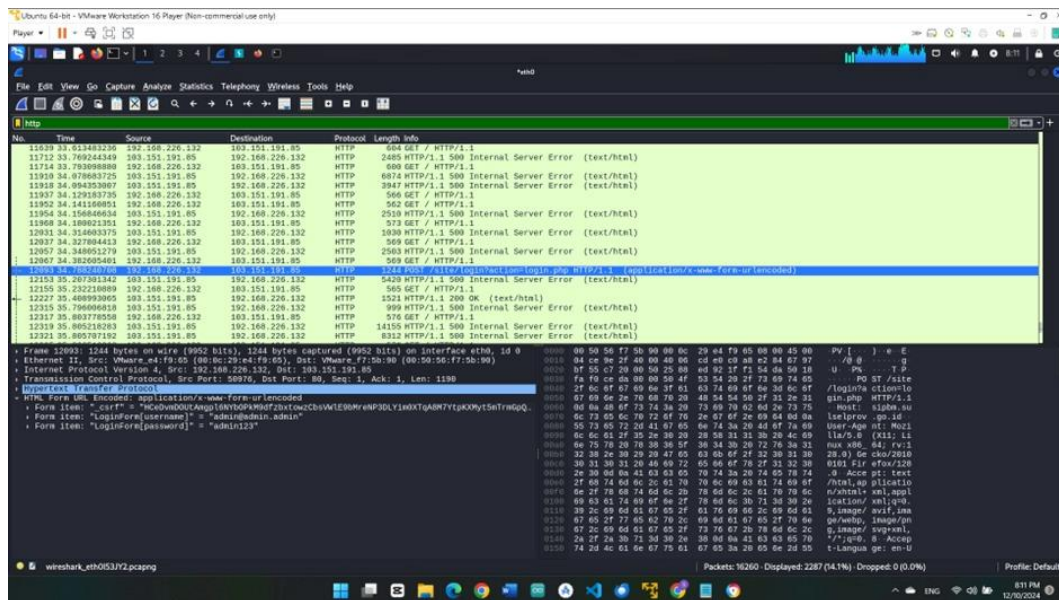


c) Wireshark

Wireshark adalah **network protocol analyzer** yang digunakan untuk menangkap, menganalisis, dan memantau lalu lintas jaringan secara

real-time. POC kali ini menggunakan teknik Man-in-the-Middle (MITM) adalah jenis serangan siber di mana penyerang menyusup di antara dua pihak yang berkomunikasi, memungkinkan mereka untuk mencegat, memanipulasi, atau mencuri data yang dikirimkan.

Jadi jika user melakukan login yang menggunakan protokol HTTP, maka dapat dilihat *User* dan *Password*nya. Seperti pada gambar dibawah ini terlihat *usern*nya menggunakan [admin@admin.admin](#) dan *passworn*nya adalah **admin123**.

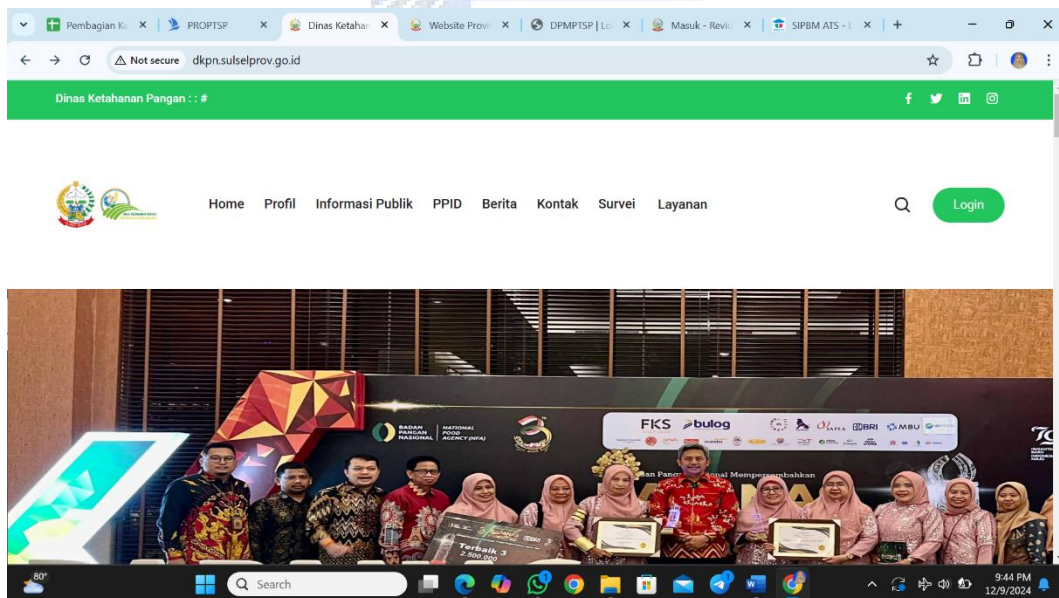


GAMA MULTI GROUP

2.3 Dinas Ketahanan Pangan (<http://dkpn.sulselprov.go.id>)

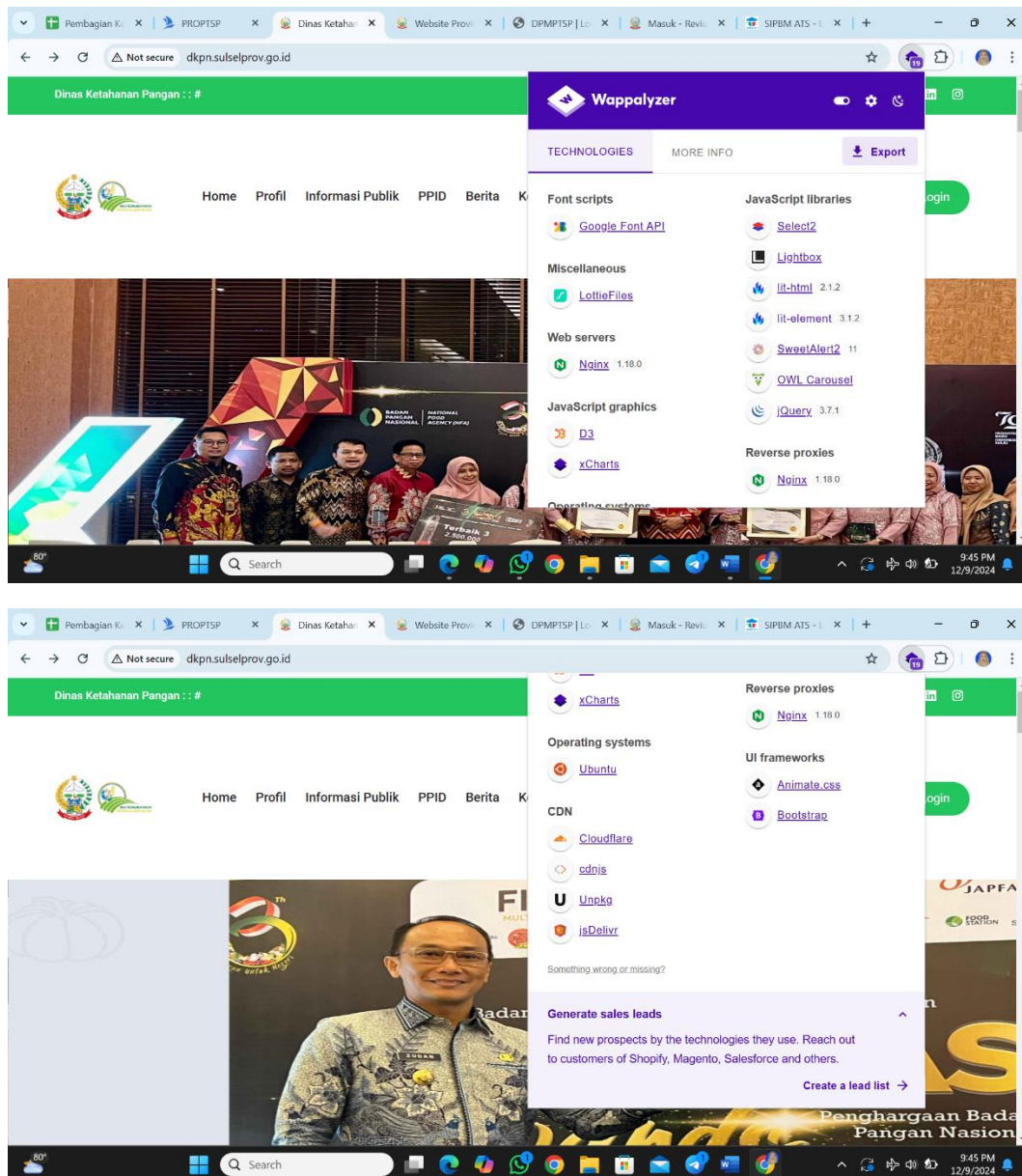
2.3.1 Informasi Website

Situs web Badan Ketahanan Pangan Provinsi Sulawesi Selatan dimaksudkan untuk mendukung ketahanan pangan melalui berbagai program strategis. situs ini menyediakan informasi mengenai kebijakan, layanan digital seperti e-SOLID untuk memantau kinerja lapangan secara berkala, serta program-program seperti SWEET (Sistem Informasi Penyediaan dan Distribusi Pangan) yang membantu distribusi pangan. selain itu, terdapat pula kegiatan-kegiatan yang bersifat umum, seperti pengarahan teknis mengenai pengelolaan pangan dan pengetahuan yang berkaitan dengan penanganan rawan pangan bagi masyarakat. situs web ini juga bertujuan untuk meningkatkan transparansi dan potensi melalui teknologi dalam pelaporan dan program-program ketahanan pangan yang dominan di Provinsi Sulawesi Selatan.



2.3.2 Pengumpulan Informasi Teknologi

Teknologi yang digunakan dalam situs web <http://dkpn.sulselprov.go.id/> berdasarkan informasi yang didapatkan dari Wappalyzer. Situs web ini menggunakan berbagai teknologi modern untuk membangun tampilan yang menarik dan interaktif, serta memastikan kinerja yang baik.



- **Tampilan dan Interaksi:** Situs web ini menggunakan library-library seperti Google Fonts, Goober, lit-html, lit-element, SweetAlert2, Animate.css, dan Bootstrap untuk membuat tampilan yang menarik dan responsif. Library-library ini memungkinkan pengembang untuk dengan mudah membuat desain yang custom, animasi, dan interaksi pengguna yang kaya.
- **Kinerja:** Penggunaan CDN seperti Unpkg dan jsDelivr membantu mempercepat waktu **loading** situs web dengan mendistribusikan file statis secara lebih efisien.

- **Infrastruktur:** Situs web ini kemungkinan besar dijalankan di atas sistem operasi Ubuntu menggunakan web server Nginx. Kombinasi ini memberikan platform yang stabil dan efisien untuk menjalankan aplikasi web.

Secara keseluruhan, situs web ini dibangun dengan menggunakan teknologi-teknologi yang populer dan modern, sehingga menghasilkan tampilan yang menarik, performa yang baik, dan pengalaman pengguna yang positif. Teknologi-teknologi yang digunakan ini memungkinkan situs web untuk:

- Menampilkan **berbagai jenis font:** Berkat Google Fonts API.
- **Membuat tampilan yang custom:** Dengan menggunakan library-library seperti Goober, lit-html, dan lit-element.
- Menampilkan notifikasi yang menarik: Menggunakan SweetAlert2.
- Menambahkan animasi: Dengan menggunakan Animate.css.
- Membuat tampilan yang responsif: Dengan menggunakan Bootstrap.
- Mempercepat waktu loading: Dengan menggunakan CDN.

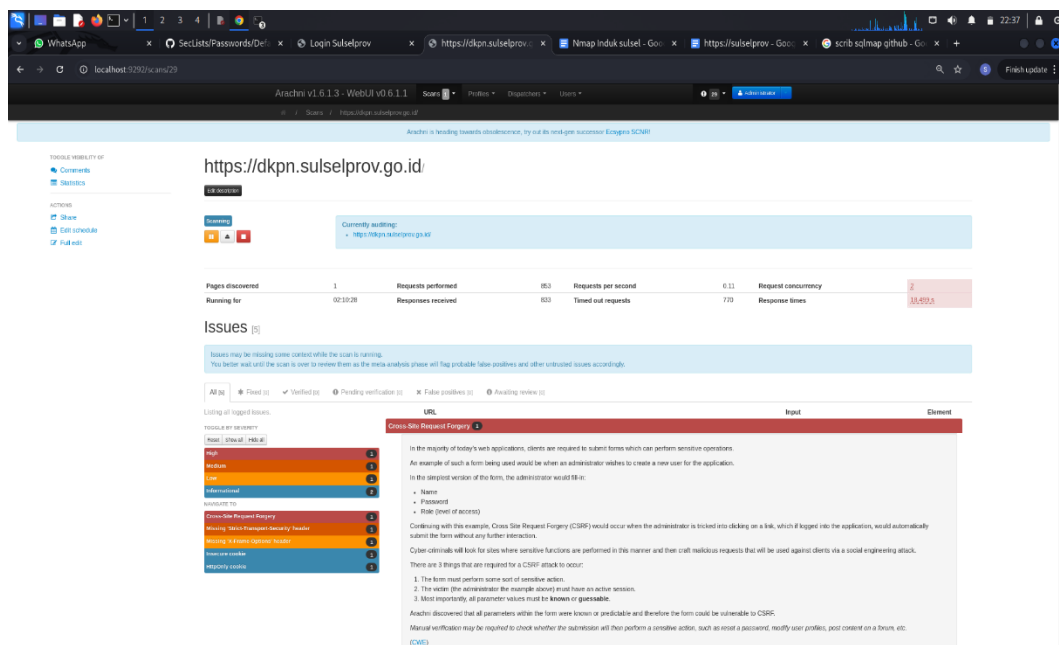
2.3.3 Hasil Scanning Web Vulnerability

2.3.3.1 Menggunakan Arachni

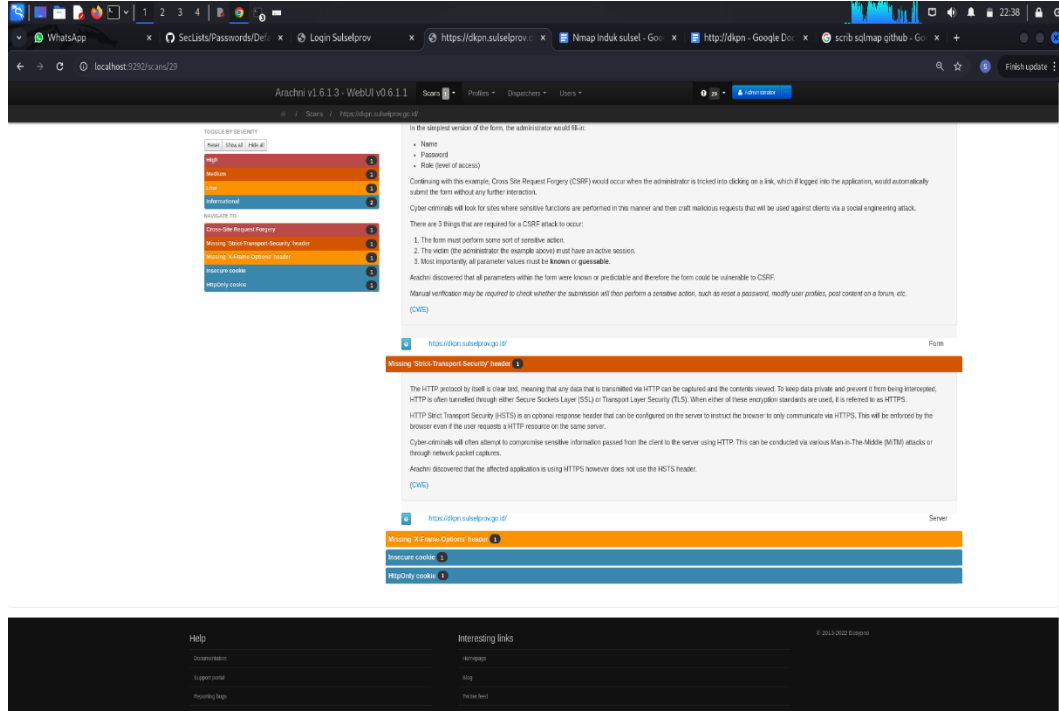
Tampilan dibawah ini merupakan hasil dari scanning domain

<https://proptsp.sulselprov.go.id> berisi:

- High terdapat Cross Site Request Forgery.

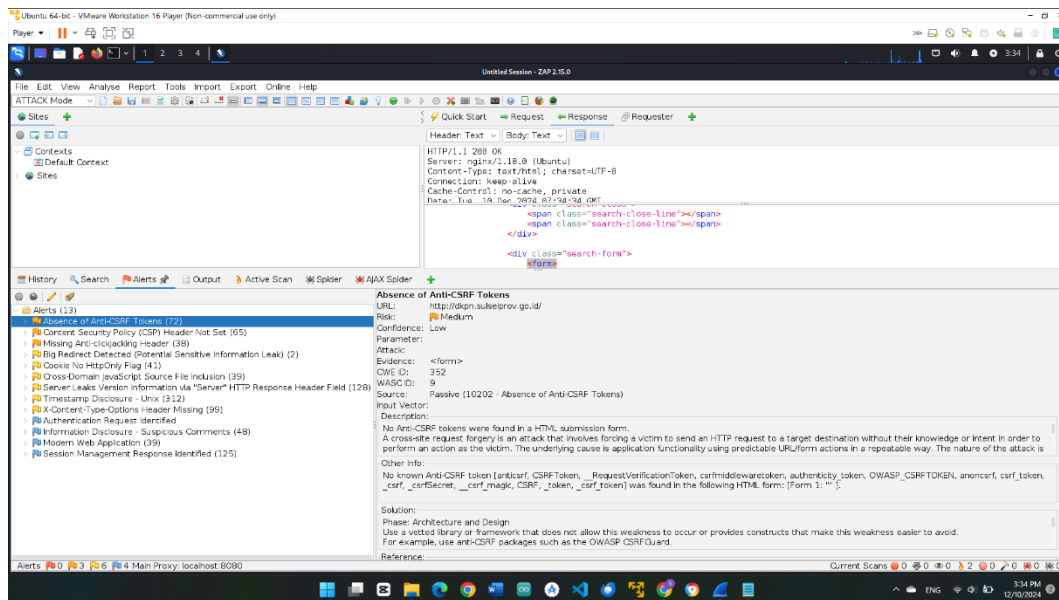


- Medium terdapat Missing 'Strict-Transport-Security' header.
- Low terdapat Missing 'X-Frame-Options' header
- Information 2 yaitu : Insecure cookie, HttpOnly cookie.



2.3.3.2 Menggunakan Zap

Pemindaian keamanan menggunakan ZAP mengidentifikasi beberapa kelemahan kritis pada situs web <http://dkpn.sulselprov.go.id/>. Situs ini rentan terhadap serangan seperti Cross-Site Request Forgery (CSRF) karena tidak memiliki token CSRF yang memadai. Selain itu, kurangnya kebijakan Content Security Policy (CSP) membuat situs ini terbuka terhadap injeksi skrip berbahaya. Masalah lain yang ditemukan adalah kurangnya header X-Frame-Options, yang dapat memungkinkan situs web ini ditampilkan dalam iframe di situs lain. Jika tidak segera diperbaiki, kerentanan-kerentanan ini dapat dimanfaatkan oleh penyerang untuk mencuri data pengguna, mengambil alih akun, atau bahkan menyebarkan malware.



2.3.3.3 Menggunakan Pentest Tools

Berdasarkan hasil pemindaian keamanan website <http://dkpn.sulselprov.go.id/site/login>, berikut ringkasan temuannya:

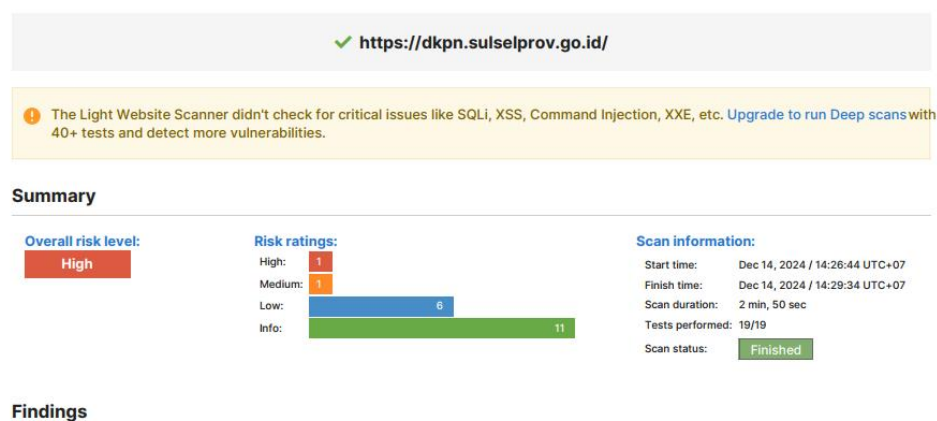
Tingkat Risiko Keseluruhan: TINGGI

Rincian Risiko:

- Tinggi: 1 temuan
- Menengah: 1 temuan
- Rendah: 6 temuan
- Info: 11 temuan



Website Vulnerability Scanner Report



Temuan Utama:

1. Kerentanan Software Server (nginx 1.18.0):
 - Memiliki beberapa CVE (Common Vulnerabilities and Exposures) dengan skor CVSS hingga 7.8
 - Perlu upgrade ke versi terbaru untuk mengatasi kerentanan
2. Masalah Konfigurasi Keamanan:
 - Cookie tidak memiliki flag 'Secure'
 - Tidak ada header keamanan penting seperti:
 - X-Content-Type-Options
 - Strict-Transport-Security
 - Content-Security-Policy
 - Referrer-Policy

Vulnerabilities found for server-side software

UNCONFIRMED

Risk Level	CVSS	CVE	Summary	Affected software
	7.8	CVE-2022-41741	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a specially crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.18.0
	7.5	CVE-2023-44487	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.	nginx 1.18.0
	7.1	CVE-2022-41742	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.18.0
	6.8	CVE-2021-23017	A security issue in nginx resolver was identified, which might allow an attacker who is able to forge UDP packets from the DNS server to cause 1-byte memory overwrite, resulting in worker process crash or potential other impact.	nginx 1.18.0
	5.8	CVE-2021-3618	ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MITM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.	nginx 1.18.0

[Details](#)

Rekomendasi Utama:

1. Upgrade Nginx ke versi terbaru
2. Implementasi header keamanan yang hilang
3. Perbaiki konfigurasi cookie dengan menambahkan flag Secure
4. Implementasi file security.txt untuk pelaporan masalah keamanan

Pemindaian dilakukan pada 14 Desember 2024 dengan durasi sekitar 2 menit 50 detik dan menjalankan 19 jenis tes keamanan.

2.3.4 List Vulnerability (Daftar Kerentanan)

No	Kerentanan	Tingkat Kerentanan
1.	Cross-Site Request Forgery	High
2.	Missing 'Strict-Transport-Security' header	Medium
3.	Absence of Anti-CSRF Tokens	
4.	Content Security Policy (CSP) Header Not Set	
5.	Missing Anti-clickjacking Header	
6.	Big Redirect Detected	Low
7.	Cookie No HttpOnly Flag	
8.	Cross-Domain JavaScript Source File Inclusion	
9.	Server Leaks Version Information	
10.	Timestamp Disclosure - Unix	
11.	X-Content-Type-Options Header Missing	
12.	Authentication Request Identified	Informational
13.	Information Disclosure - Suspicious Comments	
14.	Modern Web Application	
15.	Session Management Response Identified	

2.3.5 Detail Vulnerability

a. High Severity (Tingkat Kerentanan Sedang)

1. Cross-Site Request Forgery

Penyerang dapat mengelabui pengguna untuk melakukan tindakan tidak sah di aplikasi.

Solusi: Implementasikan token CSRF untuk setiap permintaan sensitif. Gunakan framework yang mendukung proteksi CSRF.

b. *Medium Severity* (Tingkat **Kerentanan** Sedang)

1. *Missing 'Strict-Transport-Security' header*

Tanpa header ini, aplikasi tidak dapat memaksa koneksi HTTPS, meningkatkan risiko serangan Man-in-the-Middle (MITM).

Solusi: Set header Strict-Transport-Security ke max-age=31536000; includeSubDomains; preload.

2. *Absence of Anti-CSRF Tokens*

Tanpa token Anti-CSRF, aplikasi rentan terhadap serangan CSRF.

Solusi: Tambahkan token CSRF di setiap formulir dan validasi di sisi server.

3. *Content Security Policy (CSP) Header Not Set*

Tanpa header CSP, aplikasi rentan terhadap injeksi skrip berbahaya seperti XSS.

Solusi: Set header Content-Security-Policy untuk membatasi sumber daya yang dapat dimuat.

4. *Missing Anti-clickjacking Header*

Tanpa header ini, aplikasi dapat dibingkai oleh situs jahat untuk serangan clickjacking.

Solusi: Set header X-Frame-Options ke "DENY" atau "SAMEORIGIN".

c. *Low Severity* (Tingkat Kerentanan **Rendah**)

1. *Big Redirect Detected (low)*

Server merespons dengan pengalihan besar yang dapat mengandung informasi sensitif, seperti PII.

Solusi: Pastikan respons pengalihan hanya berisi sedikit atau tidak ada konten, dan pastikan tidak ada informasi sensitif yang bocor.

2. **Cookie No HttpOnly Flag (low)**

Cookie disetel tanpa tanda HttpOnly, sehingga dapat diakses oleh JavaScript, yang membuka peluang pembajakan sesi jika skrip berbahaya dijalankan.

Solusi: Tetapkan tanda HttpOnly pada semua cookie untuk mencegah akses oleh JavaScript.

3. **Cross-Domain JavaScript Source File Inclusion (low)**

Halaman memuat file JavaScript dari domain pihak ketiga. Jika sumbernya tidak terpercaya, ini berpotensi berbahaya.

Solusi: Pastikan file JavaScript hanya dimuat dari sumber yang terpercaya dan tidak dapat dikontrol oleh pengguna aplikasi.

4. **Server Leaks Version Information via "Server" HTTP**

Response Header Field (low)

Server web/aplikasi membocorkan informasi versi melalui header "Server", yang dapat membantu penyerang menemukan kerentanan spesifik.

Solusi: Konfigurasi server untuk menghapus atau mengaburkan informasi header "Server".

5. **Timestamp Disclosure - Unix (low)**

Stempel waktu diungkapkan oleh aplikasi atau server web, yang dapat digunakan untuk serangan berbasis waktu.

Solusi: Hindari mengungkapkan stempel waktu di dalam respons HTTP.

6. **X-Content-Type-Options Header Missing (low)**

Header X-Content-Type-Options tidak disetel ke 'nosniff', yang memungkinkan MIME-sniffing pada respons oleh browser.

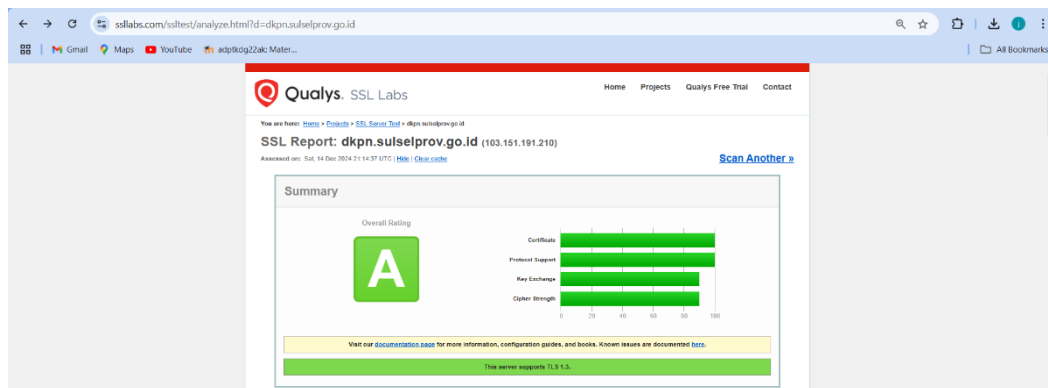
Solusi: Pastikan semua halaman web menetapkan header X-Content-Type-Options ke 'nosniff' untuk mencegah MIME-sniffing.

2.3.6 Vulnerability Assessment (Pengujian Kerentanan)

a) SSL Report

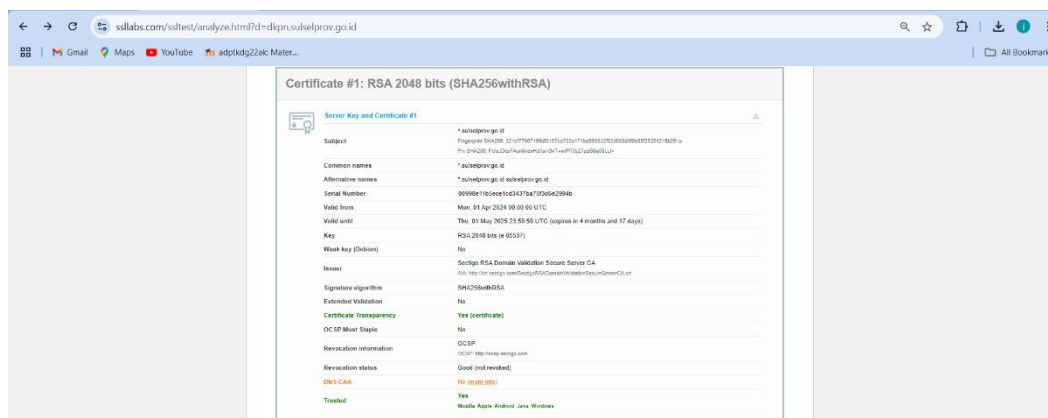
1. Hasil Penilaian Keamanan:

- Website mendapatkan grade "A" dalam penilaian keamanan SSL
- Memiliki protokol keamanan yang baik
- Support protocol TLS
- Memiliki cipher strength (kekuatan enkripsi) yang baik



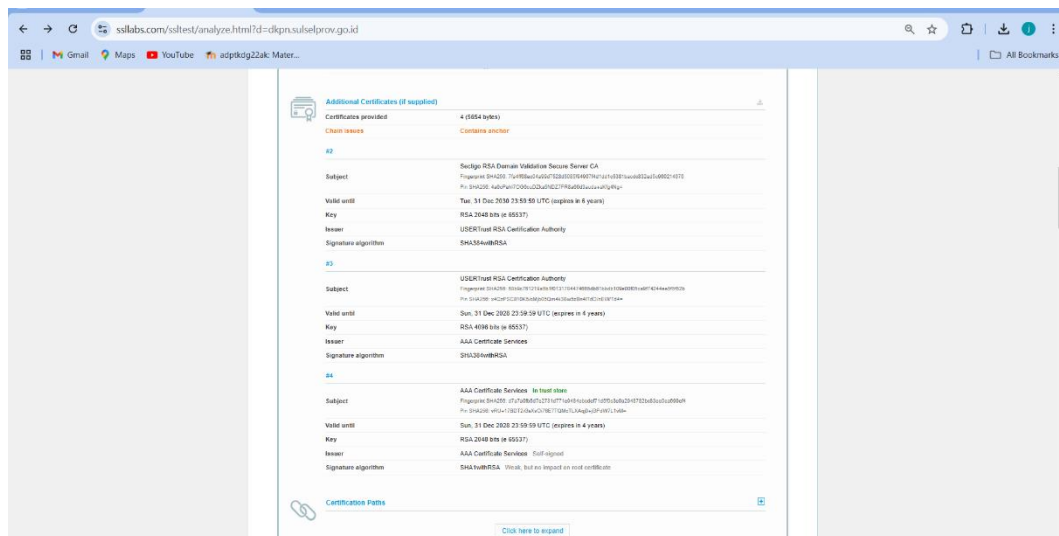
2. Sertifikat SSL:

- Terdapat beberapa sertifikat dalam rantai (certificate chain)
- Sertifikat utama dikeluarkan oleh Sectigo RSA Domain Validation Secure Server CA
- Menggunakan algoritma SHA384withRSA
- Key size RSA 2048 bits
- Masa berlaku sertifikat hingga 31 December 2028 (expires in 6 years)



3. Informasi Tambahan:

- Issuer (Penerbit): USERTrust RSA Certification Authority dan AAA Certificate Services
- Terdapat 4 sertifikat dalam rantai (chain)
- Salah satu sertifikat menggunakan self-signed certificate dengan SHA1withRSA (ditandai sebagai "weak, but no impact on root certificate")

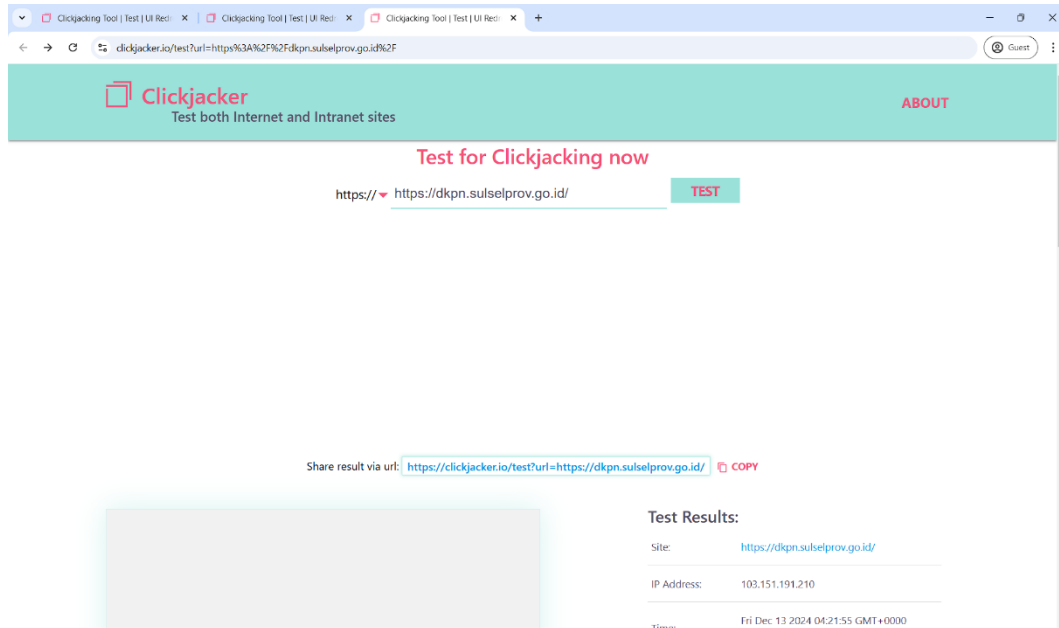


Overall, hasil pemeriksaan menunjukkan bahwa implementasi SSL pada website tersebut sudah cukup baik dan aman dengan grade A, menggunakan **sertifikat** yang valid dari authority yang terpercaya, serta menggunakan protokol keamanan yang kuat.

b) ClickJacking

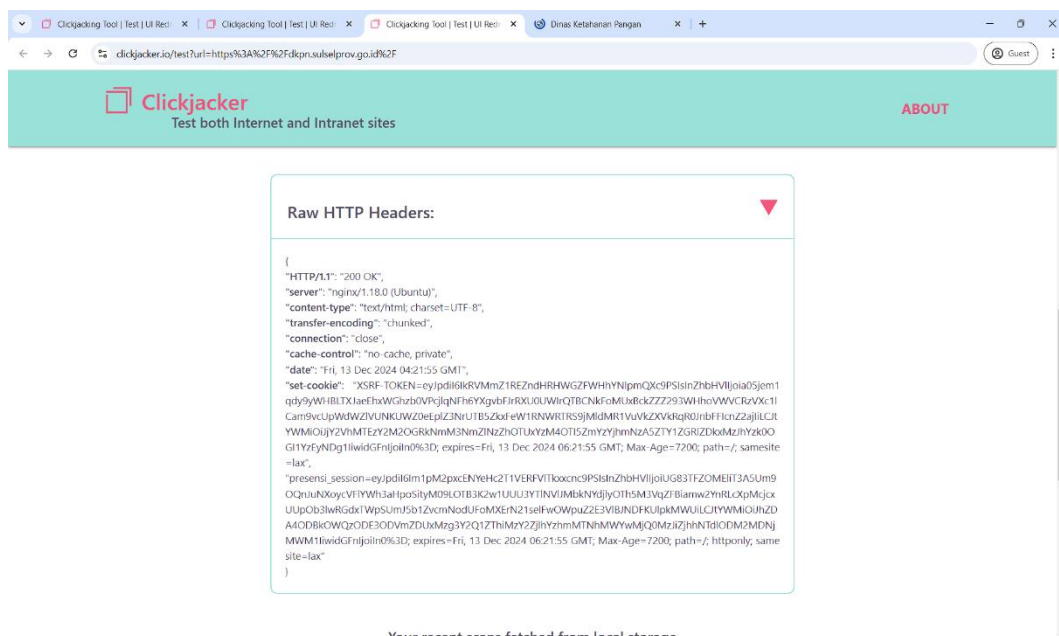
Gambardibawah ini menunjukkan hasil pengujian clickjacking pada sebuah website menggunakan tool "Clickjacker". Berikut detail yang ditampilkan:

- URL yang diuji: <https://dkpn.sulselprov.go.id/>
- Informasi hasil tes:
 - Site: <https://dkpn.sulselprov.go.id/>
 - IP Address: 103.151.191.210
 - Time: Fri Dec 13 2024 04:21:55 GMT+0000



c) Raw HTTP Headers yang menunjukkan respons server:

- HTTP/1.1 200 OK
- Server: nginx/1.18.0 (Ubuntu)
- Content-Type: text/html; charset=UTF-8
- Transfer-Encoding: chunked
- Connection: close
- Cache-Control: no-cache, private
- Set-Cookie: beberapa token session dan XSRF yang panjang
- Present-Session: token session yang panjang



Berdasarkan informasi yang ditampilkan, ini merupakan hasil pengujian keamanan website untuk mendeteksi kerentanan clickjacking. Clickjacking sendiri adalah teknik serangan yang bisa membuat pengguna tanpa sadar mengklik sesuatu yang berbeda dari yang mereka lihat di layar.

Tool ini biasanya digunakan oleh tim keamanan untuk memastikan apakah sebuah website memiliki proteksi yang cukup terhadap serangan clickjacking, seperti implementasi header X-Frame-Options atau Content-Security-Policy yang tepat.

Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://dkpn.sulselprov.go.id/site/login</title>
  <script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
      alert("Warning: hak akses dari kelompok 7");
      // Menampilkan pesan di dalam elemen dengan id "warning-message"
      document.getElementById("warning-message").innerText = "Website
ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
  </script>
  <style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
      height: 100%;
      margin: 0;
```

```
padding: 0;
overflow: hidden;
}

/* Menyusun iframe untuk mengisi seluruh layar */
iframe {
    width: 100%;
    height: 100%;
    border: none;
    opacity: 15;
}

/* Menyusun pesan peringatan */
#warning-message {
    position: absolute;
    top: 20px;
    left: 20px;
    background-color: rgba(19, 18, 18, 0.7);
    color: white;
    padding: 10px;
    border-radius: 5px;
    z-index: 10;
}

/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
    z-index: 10;
    position: absolute;
    top: 100px;
    left: 20px;
    padding: 10px 20px;
    background-color: #100f0f;
```

```

        color: white;
        border: none;
        cursor: pointer;
        font-size: 16px;
    }

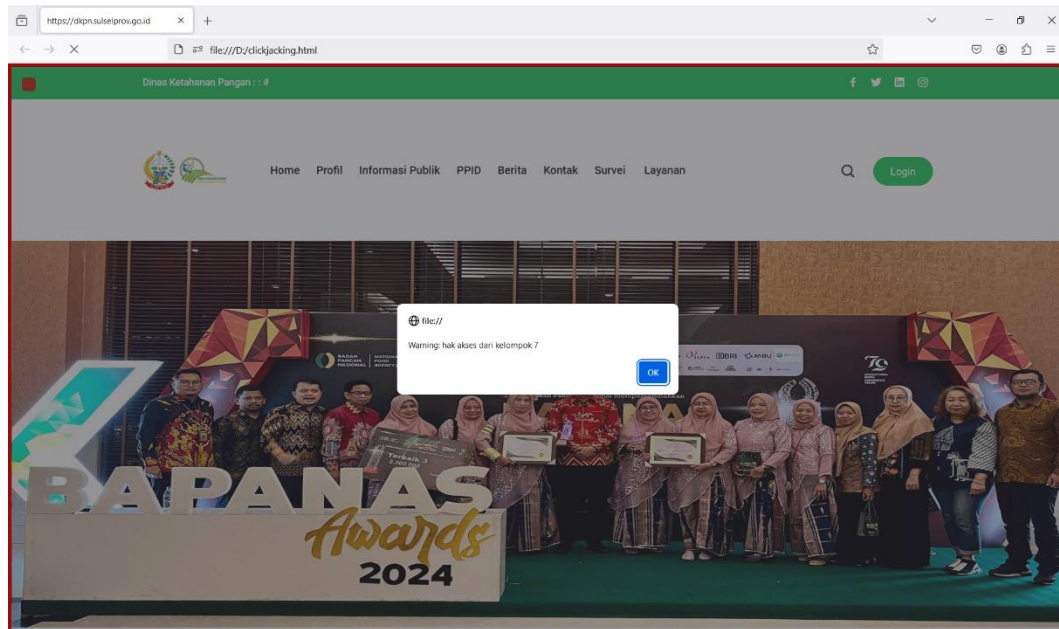
    /* Efek hover pada tombol */
    input[type="button"]:hover {
        background-color: #426043;
    }
</style>
</head>

<body>
    <div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->
    <iframe src="https://dkpn.sulselprov.go.id/"></iframe>
</body>

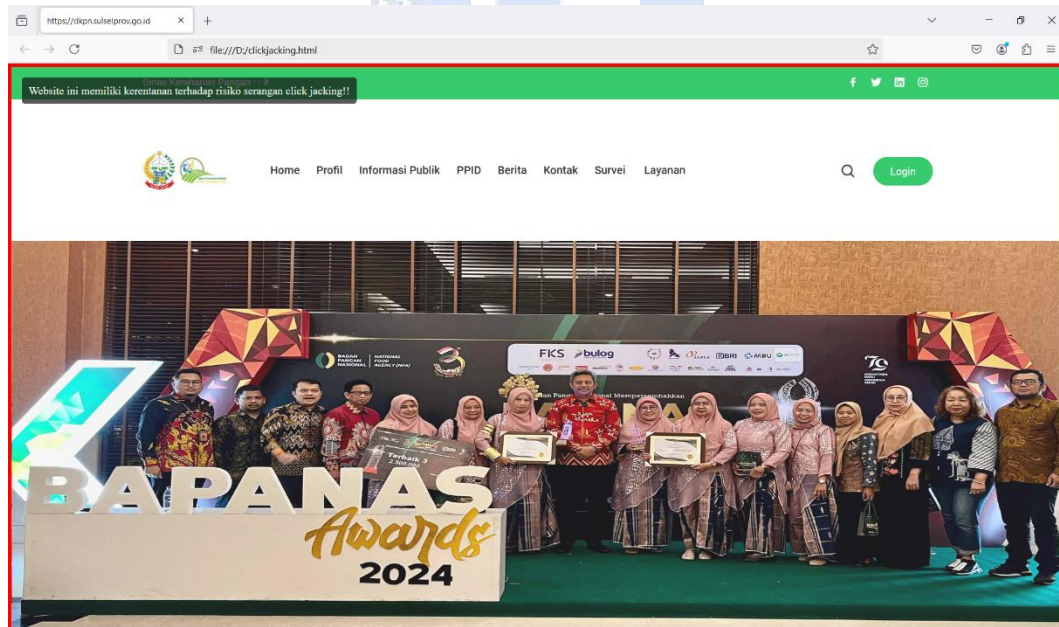
</html>

```

Setelah selesai simpan file di Visual StudioCodanya contoh:**euybchc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul Warning dalam bentuk PopUp dengan tulisan “**Warning: hak akses dari kelompok 7**”



Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <https://dkpn.sulselprov.go.id> yang mana pada bagian pojok kiri menunjukkan adanya peringatan : **“Website ini memiliki kerentanan terhadap risiko serangan click jacking!!”**



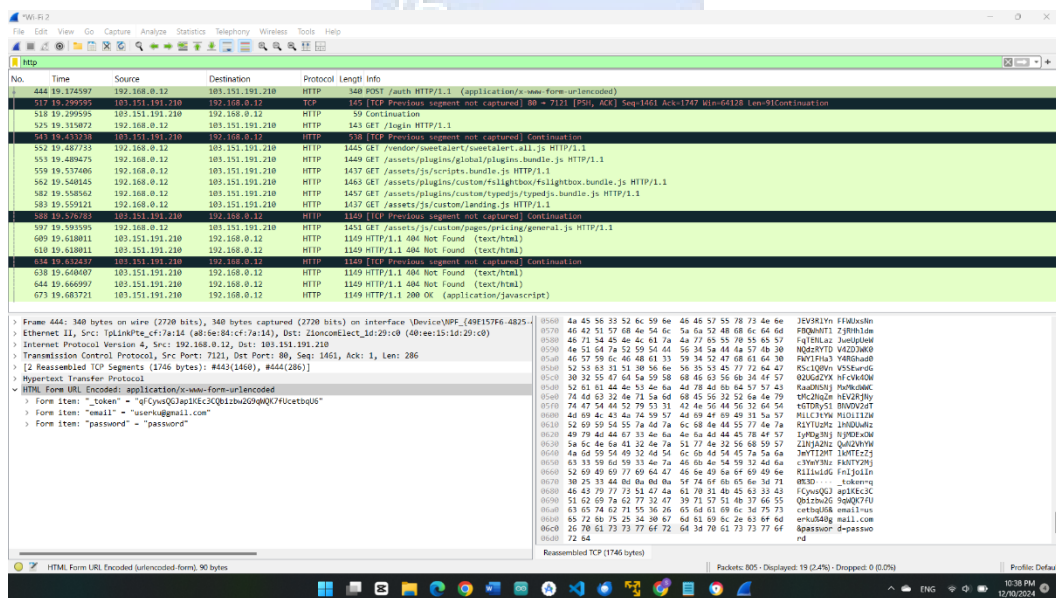
c) Wireshark

Wireshark adalah **network protocol analyzer** yang digunakan untuk menangkap, menganalisis, dan memantau lalu lintas jaringan

secara real-time. POC kali ini menggunakan teknik Man-in-the-Middle (MITM) adalah jenis serangan siber di mana penyerang menyusup di antara dua pihak yang berkomunikasi, memungkinkan mereka untuk mencegat, memanipulasi, atau mencuri data yang dikirimkan.

Jadi jika user melakukan login yang menggunakan protokol HTTP, maka dapat dilihat User dan Passwordnya. Seperti pada gambar dibawah ini terlihat usernya menggunakan userku@gmail.com dan passwordnya adalah **password**. Gambar ini menunjukkan proses login di mana:

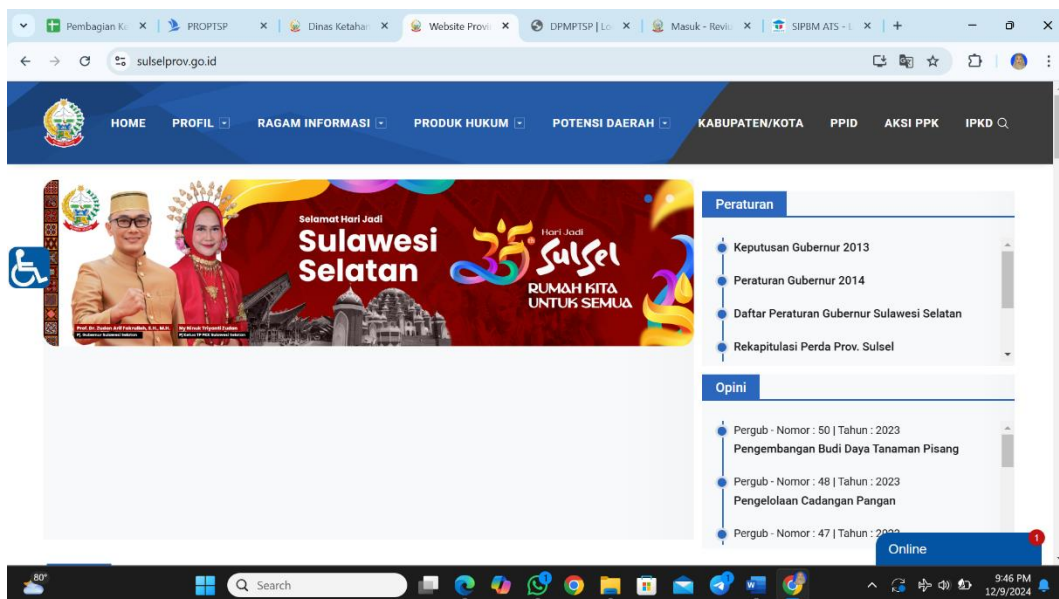
- User mencoba mengakses halaman login
- Wireshark menangkap traffic data saat proses login tersebut berlangsung
- Request HTTP dan data form yang dikirim dapat dilihat detailnya di Wireshark.



2.4 Website Provinsi Sulawesi Selatan (<http://sulselprov.go.id>)

2.4.1 Informasi Website

Situs resmi Provinsi Sulawesi Selatan (sulselprov.go.id) dapat menjadi platform digital yang menjadi pusat pengetahuan bagi pemerintah daerah Sulawesi Selatan. situs ini berisi berbagai layanan dan data seperti berita terkini, profil provinsi, produk hukum, dan potensi daerah seperti sektor perkebunan, kehutanan, perikanan, dan pertanian. selain itu, terdapat pula informasi matematika terapan, data pembangunan infrastruktur, dan ruang lingkup pemerintah provinsi yang memiliki struktur hingga kebijakan terbaru.



2.4.2 Pengumpulan Informasi Teknologi

a) Wappalyzer

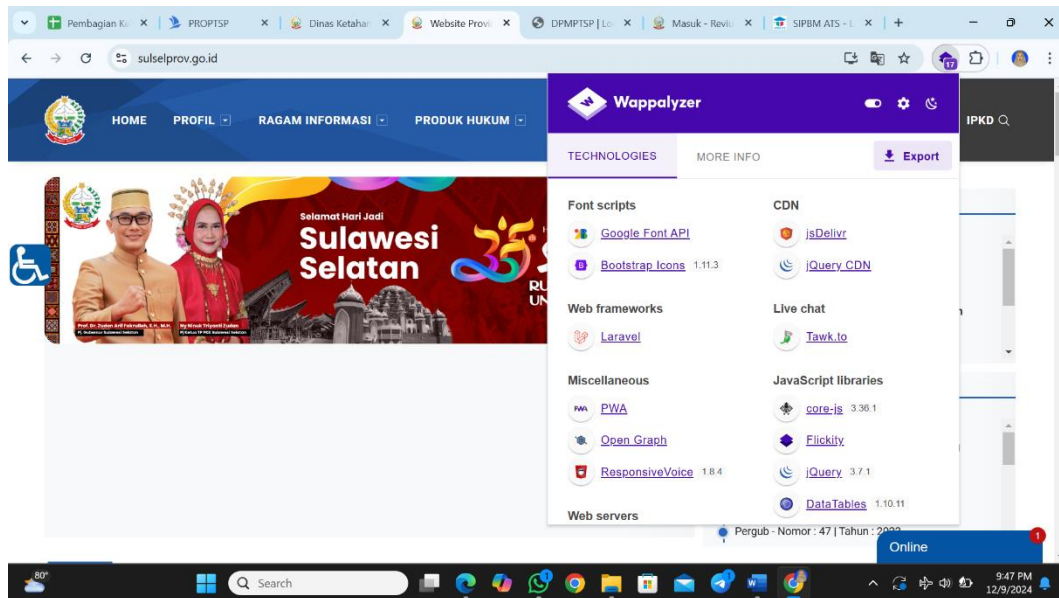
Analisis teknologi situs <https://sulselprov.go.id/> berdasarkan Wappalyzer:

1. **Font dan CDN:** Menggunakan **Google Font API** untuk tampilan font menarik, serta **jsDelivr** dan **jQuery CDN** untuk distribusi file statis yang mempercepat loading.
2. **Web Framework dan Live Chat:**
 - **Laravel** sebagai framework PHP untuk pengembangan web.
 - **Tawk.to** untuk layanan live chat dengan pengunjung.
3. **Miscellaneous:**

- **PWA** untuk pengalaman mirip aplikasi native.
- **Open Graph** untuk metadata berbagi ke jejaring sosial.
- **ResponsiveVoice** untuk teks ke suara.
- Library seperti **Goober**, **Flickity**, **core-js**, **jQuery**, dan **DataTables** untuk fitur interaktif.

4. Web Server dan Bahasa Pemrograman:

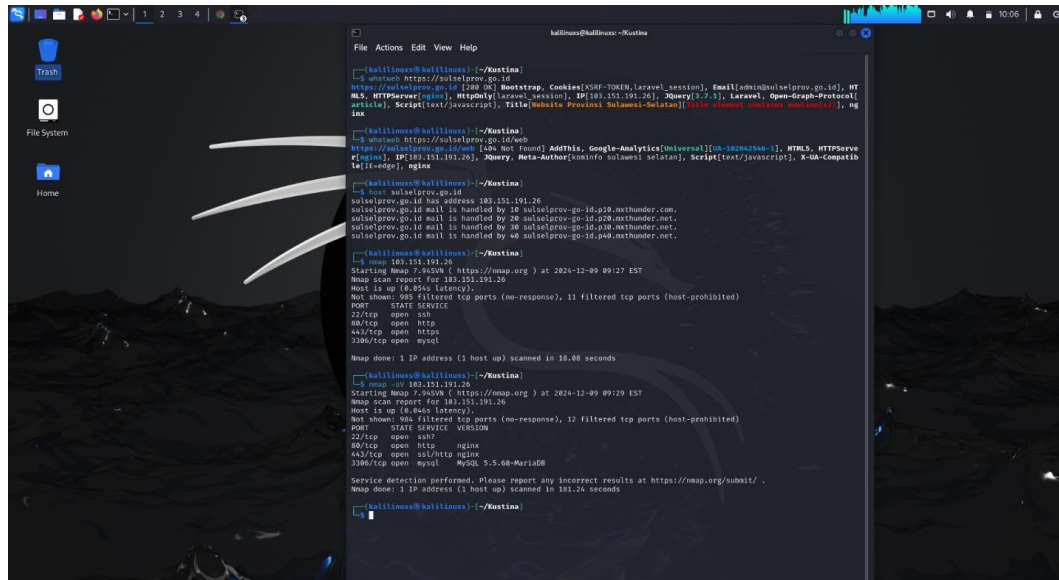
- **Nginx** sebagai web server.
- **PHP** sebagai bahasa pemrograman utama (melalui Laravel).



b) Whatweb

WhatWeb adalah alat open-source yang digunakan untuk mendeteksi dan mengidentifikasi teknologi yang digunakan oleh situs web. Hasil yang didapatkan yaitu:

- ketika sintak **whatweb** <https://sulselprov.go.id> di panggil maka akan menampilkan Bootstrap, Email, serta jenis server apa yang digunakan seperti gambar diatas yaitu menggunakan HTML5, Laravel, JQuery dan sebagainya.
- Dengan menggunakan whatweb juga dapat mengetahui IP dari domain tersebut yaitu : 103.151.191.26
- Setelah itu dapat dilakukan nmap untuk mengetahui PORT apa saja yang terdapat pada domain tersebut.



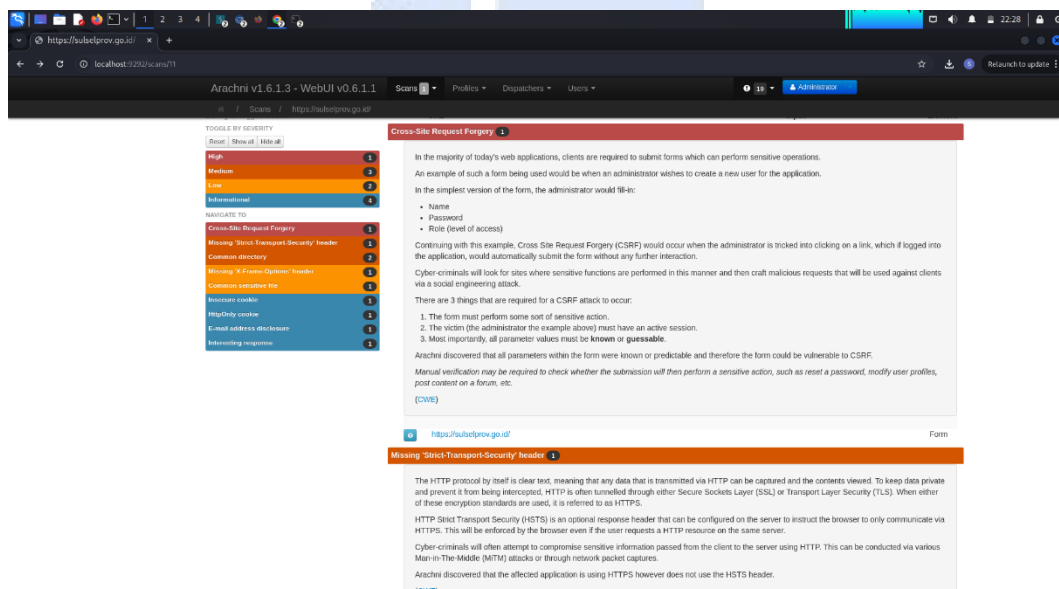
2.4.3 Hasil Scanning Web Vulnerability

2.4.3.1 Menggunakan Arachni

Tampilan dibawah ini merupakan hasil dari scanning domain

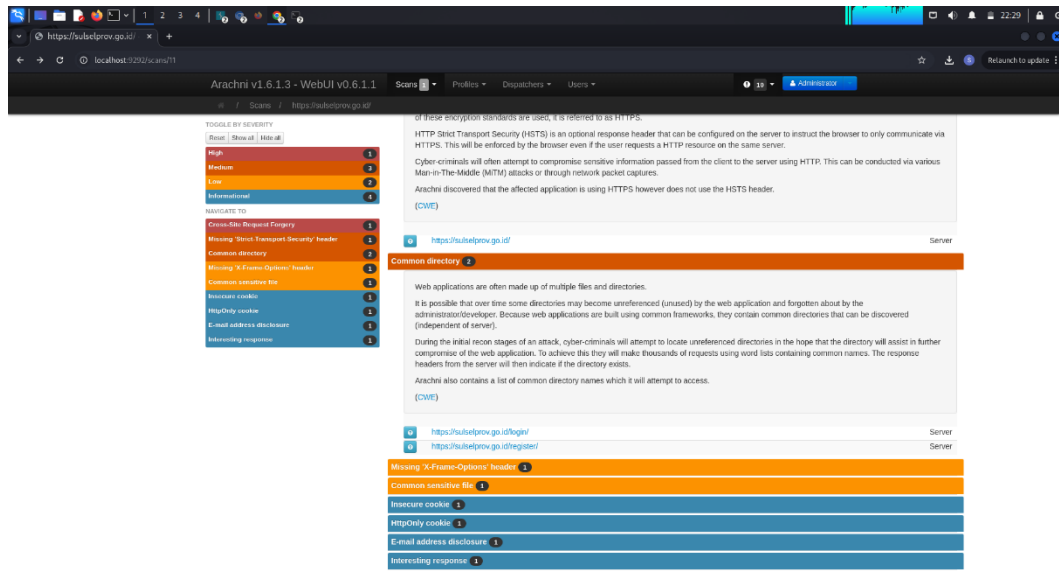
<https://sulselprov.go.id> berisi:

- High terdapat 1 Cross Site Request Forgery.



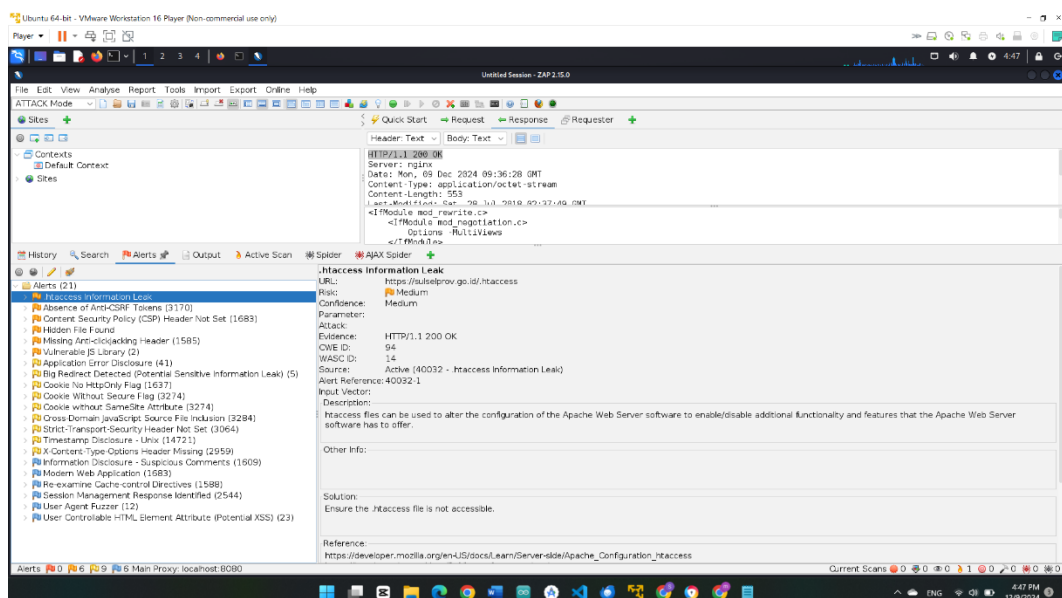
- Medium 3 terdiri dari Missing 'Strict-Transport-Security' header 1, dan Common directory 2.

- Low 2 terdiri dari Missing 'X-Frame-Option' header, dan Common sensitive file 1.
- Information 4 yaitu : Insecure cookie, HttpOnly cookie 1, E-mail address disclosure 1, dan Interesting response 1.



2.4.3.2 Menggunakan Zap

Hasil analisis dari OWASP ZAP menunjukkan kebocoran informasi file .htaccess di situs <https://sulselprov.go.id> dengan risiko Medium. File .htaccess, yang berisi konfigurasi penting server Apache, terdeteksi dapat diakses publik, sehingga berpotensi dimanfaatkan untuk serangan.

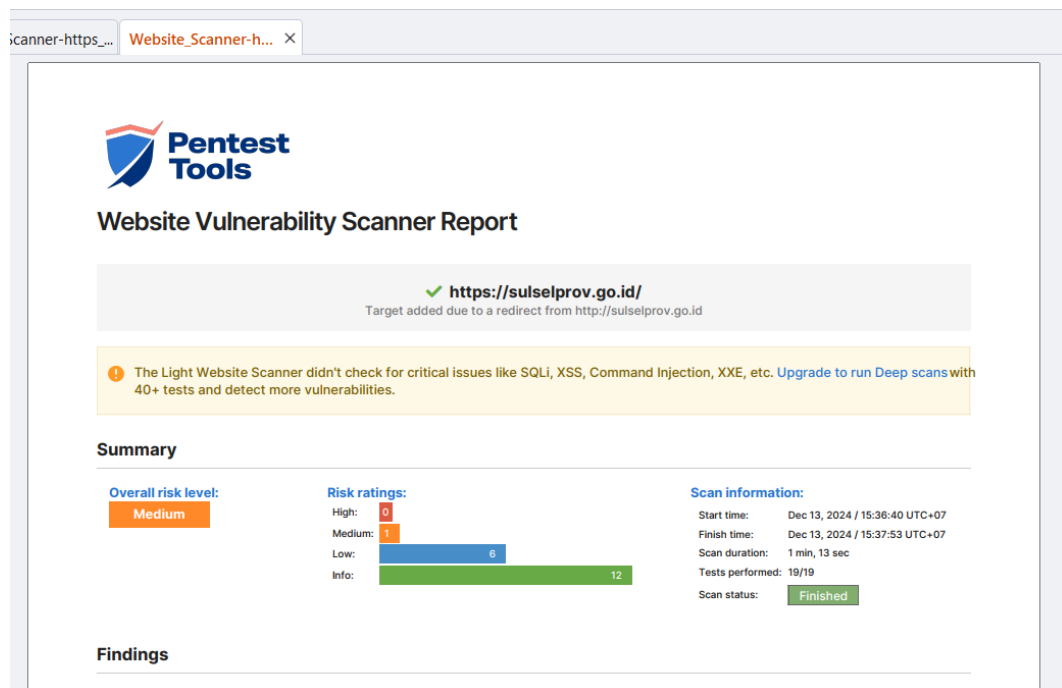


2.4.3.3 Menggunakan Pentest Tools

Berdasarkan hasil pemindaian keamanan website sulselprov.go.id, berikut ringkasan temuannya:

Tingkat Risiko Keseluruhan: Medium

- Risiko Tinggi: 0
- Risiko Menengah: 1
- Risiko Rendah: 6
- Info: 12



Temuan Utama:

1. Masalah Konfigurasi Cookie (Risiko Menengah)
 - Cookie laravel_session tidak memiliki flag Secure
 - Berisiko terhadap pencurian cookie melalui koneksi tidak terenkripsi
2. Header Keamanan yang Hilang (Risiko Rendah):
 - X-Content-Type-Options
 - Content-Security-Policy
 - Referrer-Policy
 - Strict-Transport-Security
4. File robots.txt ditemukan

- Perlu review manual untuk memastikan tidak ada informasi sensitif
5. File security.txt tidak ditemukan
- Disarankan untuk mengimplementasikan file ini sebagai saluran pelaporan masalah keamanan

Statistik Pemindaian:

- Injection Points yang Terdeteksi: 141
- URL yang Dipindai: 2
- Total Request HTTP: 11
- Rata-rata Waktu Respons: 772ms

 Insecure cookie setting: missing Secure flag

CONFIRMED

URL	Cookie Name	Evidence
https://sulselprov.go.id/	laravel_session	Set-Cookie: laravel_session=eyJpdil6InpkbW9qOE5rY0ILZWZJU28zdTNsYWc9PSIsInZhbHVlIjoicTNJS2dndlwvd0x6blV2dGVEV0Q5NjFqS1NieVhrQWxqT3hsUVFOEFtQitUZ0s3Z2VLZXVvQWxzY1BHZFFCTkUxNGYwcUxHRXJhYms3TEJ0VEx6SGJ3PT0iLCJrYWMI0i3ZTUyZmU5NmIxOGQ5NGYwMWFmYWI0M2VjMjZjMzY0MjAzZTZhZmUyNTFiODc2NzhiZTk4YjZmMTFjZjg3ZTYwIn0%3D Request / Response

Details

Risk description:

The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:

Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:

https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:

CWE : CWE-614
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration

 Missing security header: X-Content-Type-Options

CONFIRMED

URL	Evidence
https://sulselprov.go.id/	Response headers do not include the X-Content-Type-Options HTTP security header Request / Response

Rekomendasi Utama:

1. Mengaktifkan flag Secure pada cookie
2. Menambahkan header keamanan yang hilang
3. Mengimplementasikan file security.txt
4. Mereview konten robots.txt
5. Mengurangi informasi teknologi yang terekspos

2.4.4 List Vulnerability (Daftar Kerentanan)

No	Kerentanan	Tingkat Kerentanan
1.	Cross-Site Request Forgery	High
2.	Missing 'Strict-Transport-Security' header	Medium
3.	Common directory	
4.	.htaccess Information Leak	
5.	Absence of Anti-CSRF Tokens	
6.	Content Security Policy (CSP) Header Not Set	
7.	Hidden File Found	
8.	Missing Anti-clickjacking Header	
9.	Vulnerable JS Library	
10.	Common sensitive file	Low
11.	Application Error Disclosure	
12.	Big Redirect Detected	
13.	Cookie No HttpOnly Flag	
14.	Cookie Without Secure Flag	
15.	Cookie without SameSite Attribute	
16.	Cross-Domain JavaScript Source File Inclusion	
17.	Strict-Transport-Security Header Not Set	
18.	Timestamp Disclosure - Unix	
19.	X-Content-Type-Options Header Missing	
20.	Information Disclosure - Suspicious Comments	Informational
21.	Modern Web Application	
22.	Re-examine Cache-control Directives	
23.	Session Management Response Identified	
24.	User Agent Fuzzer	
25.	User Controllable HTML Element Attribute (Potential XSS)	

2.4.5 Detail Vulnerability

a. High Severity (Tingkat Kerentanan Tinggi)

1. *Cross-Site Request Forger*

CSRF memungkinkan penyerang membuat pengguna melakukan tindakan yang tidak diinginkan tanpa persetujuan mereka.

Solusi: Gunakan token CSRF unik untuk setiap permintaan dan verifikasi di server.

b. Medium Severity (Tingkat Kerentanan Sedang)

1. *Missing 'Strict-Transport-Security' header*

Tanpa header ini, aplikasi tidak memaksa koneksi HTTPS, meningkatkan risiko serangan Man-in-the-Middle (MITM).

Solusi: Set header Strict-Transport-Security ke max-age=31536000; includeSubDomains; preload.

2. *Common directory*

Direktori umum dapat memberikan informasi sensitif yang memudahkan serangan.

Solusi: Hapus atau lindungi direktori sensitif dengan autentikasi atau konfigurasi akses.

3. *htaccess Information Leak*

File .htaccess yang terbuka dapat mengungkapkan konfigurasi server yang sensitif.

Solusi: Konfigurasikan server untuk memblokir akses ke file .htaccess dari luar.

4. *Absence of Anti-CSRF Tokens*

Tanpa token Anti-CSRF, aplikasi rentan terhadap serangan CSRF.

Solusi: Tambahkan token CSRF di setiap formulir dan validasi di sisi server.

5. *Content Security Policy (CSP) Header Not Set*

Tanpa header CSP, aplikasi rentan terhadap injeksi skrip berbahaya seperti XSS.

Solusi: Set header Content-Security-Policy untuk membatasi sumber daya yang dapat dimuat.

6. *Hidden File Found*

File tersembunyi dapat mengandung informasi sensitif atau konfigurasi penting.

Solusi: Hapus file tersembunyi yang tidak diperlukan atau batasi aksesnya dengan aturan server.

7. *Missing Anti-clickjacking Header*

Tanpa header ini, aplikasi dapat dibingkai oleh situs jahat untuk serangan clickjacking.

Solusi: Set header X-Frame-Options ke "DENY" atau "SAMEORIGIN".

8. *Vulnerable JS Library*

Perpustakaan JavaScript yang rentan dapat dieksploitasi untuk berbagai serangan, termasuk XSS.

Solusi: Perbarui pustaka JavaScript ke versi terbaru yang aman.

c. *Low Severity (Tingkat Kerentanan Rendah)*

1. *Common Sensitive File*

File sensitif seperti backup atau konfigurasi dapat mengandung informasi yang dapat disalahgunakan.

Solusi: Hapus file sensitif yang tidak diperlukan atau pindahkan ke lokasi yang lebih aman dengan akses terbatas.

2. *Application Error Disclosure*

Halaman mengungkapkan pesan kesalahan yang berpotensi memuat informasi sensitif, seperti lokasi file atau detail teknis lainnya.

Solusi: Terapkan halaman kesalahan khusus yang menyembunyikan detail kesalahan dari pengguna. Catat detail kesalahan di sisi server untuk keperluan debugging.

3. *Big Redirect Detected*

Server merespons dengan pengalihan yang besar, yang mungkin membocorkan informasi sensitif.

Solusi: Pastikan tidak ada informasi sensitif yang bocor melalui respons pengalihan.

4. *Cookie No HttpOnly Flag*

Cookie tidak memiliki flag HttpOnly, sehingga dapat diakses oleh JavaScript, meningkatkan risiko pembajakan sesi.

Solusi: Pastikan semua cookie memiliki flag HttpOnly untuk mencegah akses JavaScript.

5. *Cookie Without Secure Flag*

Cookie tidak memiliki flag Secure, sehingga dapat dikirim melalui koneksi tidak terenkripsi.

Solusi: Tetapkan flag Secure pada semua cookie sensitif untuk memastikan transmisi melalui koneksi HTTPS.

6. *Cookie without SameSite Attribute*

Cookie tidak memiliki atribut SameSite, memungkinkan pengiriman dalam permintaan lintas situs yang berpotensi disalahgunakan.

Solusi: Tetapkan atribut SameSite ke lax atau idealnya strict untuk semua cookie.

7. *Cross-Domain JavaScript Source File Inclusion*

Halaman memuat skrip dari domain pihak ketiga, yang berpotensi berisiko jika sumber tidak tepercaya.

Solusi: Pastikan hanya memuat skrip dari sumber tepercaya yang tidak dapat dimanipulasi oleh pengguna akhir.

8. *Strict-Transport-Security Header Not Set*

Tidak ada header HSTS (HTTP Strict Transport Security), memungkinkan koneksi HTTP yang tidak aman.

Solusi: Konfigurasi server untuk menggunakan HSTS agar hanya menggunakan koneksi HTTPS yang aman.

9. *Timestamp Disclosure – Unix*

Server mengungkapkan stempel waktu, yang dapat membantu penyerang mengidentifikasi pola atau informasi sensitif.

Solusi: Verifikasi bahwa data stempel waktu tidak sensitif dan tidak dapat dieksploitasi.

10. *X-Content-Type-Options Header Missing*

Header X-Content-Type-Options tidak disetel ke nosniff, memungkinkan browser untuk melakukan MIME-sniffing.

Solusi: Tetapkan header X-Content-Type-Options ke nosniff untuk mencegah MIME-sniffing.

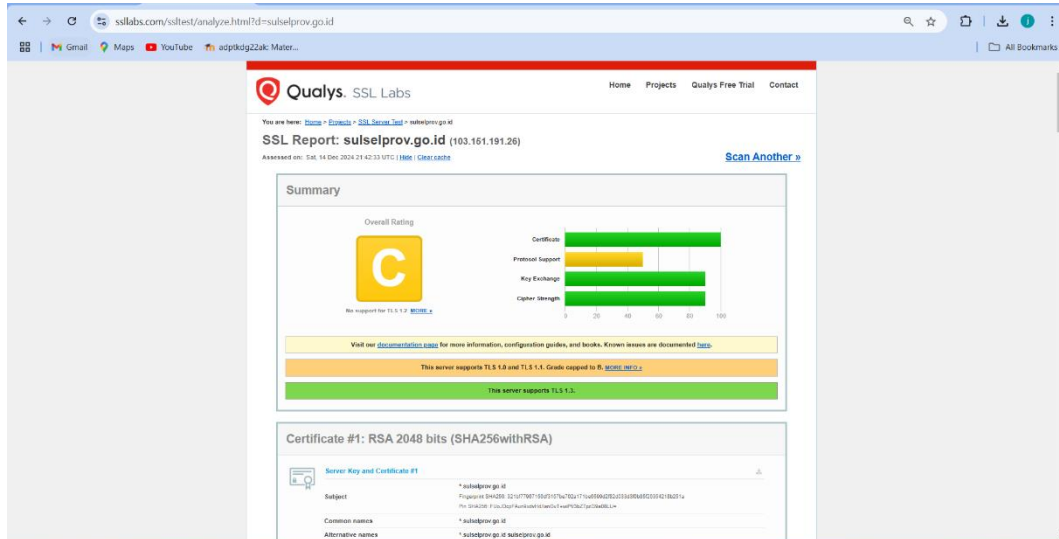
2.4.6 Vulnerability Assessment (Pengujian Kerentanan)

a) *SSL Report*

Dari gambar tersebut, saya melihat hasil pemindaian SSL (SSL Report) untuk domain sulseleprov.go.id dengan detail sebagai berikut:

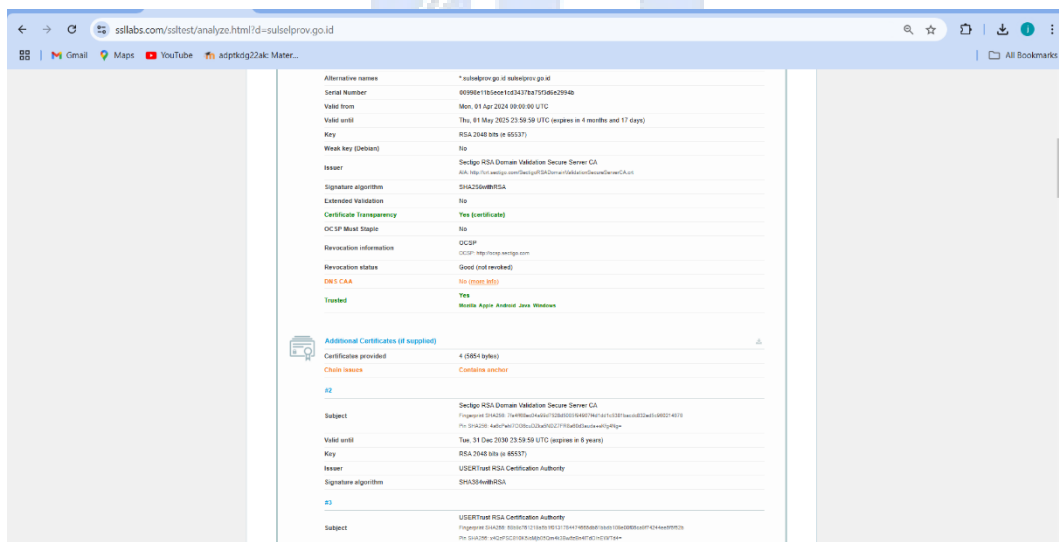
1. Overall Rating: C

- Penilaian keseluruhan menunjukkan grade C
- Terdapat beberapa parameter yang dinilai:
 - Certificate: Rating cukup baik (bar hijau)
 - Protocol Support: Rating sedang (bar kuning)
 - Key Exchange: Rating baik (bar hijau)
 - Cipher Strength: Rating baik (bar hijau)



2. Detail Sertifikat:

- Menggunakan RSA 2048 bits dengan SHA256withRSA
- Valid dari: 14 Juni 2024
- Valid hingga: 31 Des 2025 (berlaku 6 bulan)
- Dikeluarkan oleh DigiCert EV Domain Validation Secure Server CA

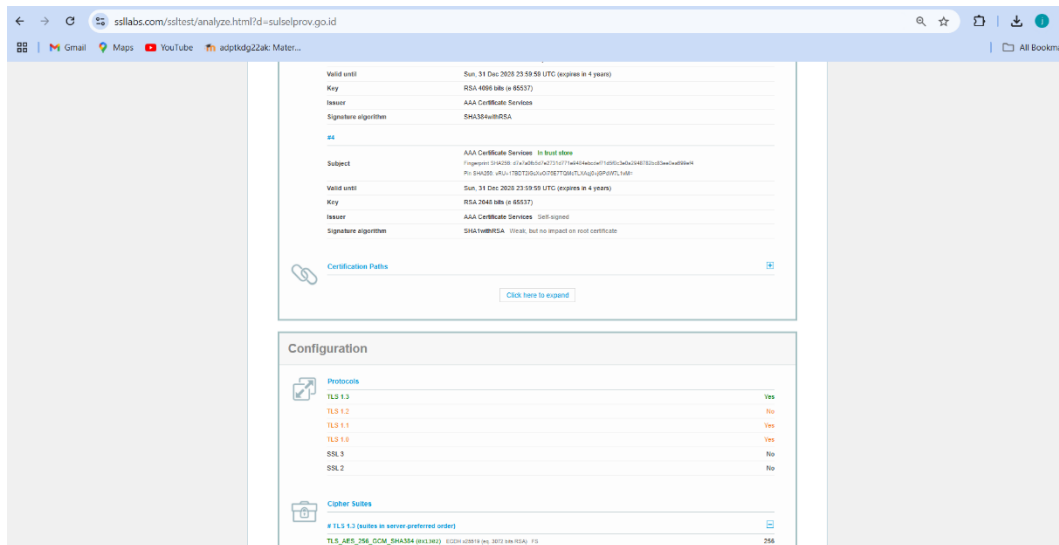


3. Konfigurasi Protocol:

- TLS 1.3: Yes (Didukung)
- TLS 1.2: No (Tidak didukung)
- TLS 1.1: No (Tidak didukung)
- TLS 1.0: No (Tidak didukung)
- SSL 3: No (Tidak didukung)
- SSL 2: No (Tidak didukung)

4. Informasi Tambahan:

- Certificate Transparency: Yes (diterapkan)
- OCSP Must Staple: No
- OCSP: No
- Revocation status: Good (not revoked)

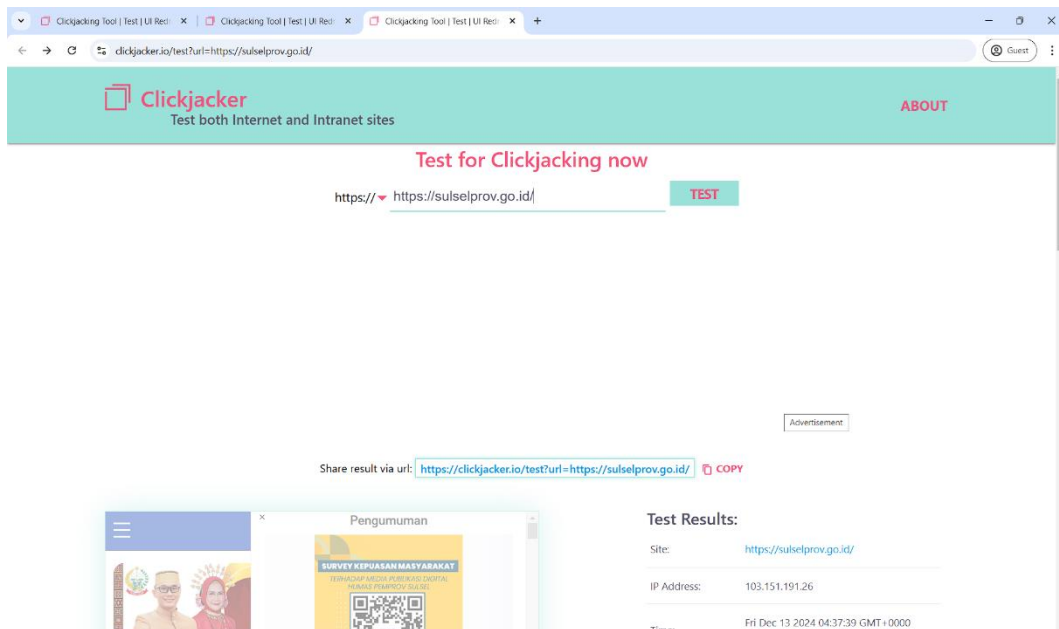


Rating C yang diperoleh kemungkinan disebabkan oleh beberapa faktor seperti protocol support yang terbatas (hanya TLS 1.3) dan beberapa aspek keamanan yang belum diimplementasikan secara optimal. Meski begitu, sertifikat masih valid dan menggunakan enkripsi yang cukup kuat.

b) ClickJacking

Berdasarkan gambar dibawah ini menunjukkan hasil pengujian Clickjacking Tool terhadap sebuah website. Berikut detail yang dapat dilihat:

1. Website yang diuji: <https://sulselprov.go.id/>
2. IP Address website: 103.151.191.26
3. Waktu pengujian: Fri Dec 13 2024 04:37:39 GMT+0000



Hasil pengujian menunjukkan adanya peringatan "It is vulnerable to clickjacking attack" yang berarti website tersebut rentan terhadap serangan clickjacking. Di bagian bawah terdapat Raw HTTP Headers yang menampilkan header respons dari server, termasuk:

- HTTP status 200 OK
- Server menggunakan nginx
- Content type: text/html dengan charset UTF-8
- Beberapa cookie session dan token keamanan
- Cache control settings
- Transfer encoding: chunked

Kerentanan clickjacking ini berarti website tersebut bisa dijadikan target untuk serangan yang memungkinkan penyerang

membuat pengguna mengklik elemen yang tidak terlihat atau tersamarkan di halaman web. Ini biasanya terjadi karena tidak adanya header keamanan X-Frame-Options atau Content-Security-Policy yang tepat.

Untuk meningkatkan keamanan, administrator website perlu mengimplementasikan header keamanan yang sesuai untuk mencegah website dibuka dalam iframe oleh domain yang tidak dipercaya.

Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://sulselprov.go.id/site/login</title>
  <script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
      alert("Warning: hak akses dari kelompok 7");
      // Menampilkan pesan di dalam elemen dengan id "warning-message"
      document.getElementById("warning-message").innerText = "Website
      ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
  </script>
  <style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
      height: 100%;
      margin: 0;
      padding: 0;
      overflow: hidden;
```



```

}

/* Menyusun iframe untuk mengisi seluruh layar */
iframe {
    width: 100%;
    height: 100%;
    border: none;
    opacity: 15;
}

/* Menyusun pesan peringatan */
#warning-message {
    position: absolute;
    top: 20px;
    left: 20px;
    background-color: rgba(19, 18, 18, 0.7);
    color: white;
    padding: 10px;
    border-radius: 5px;
    z-index: 10;
}

/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
    z-index: 10;
    position: absolute;
    top: 100px;
    left: 20px;
    padding: 10px 20px;
    background-color: #100f0f;
    color: white;
    border: none;

```

```

        cursor: pointer;
        font-size: 16px;
    }

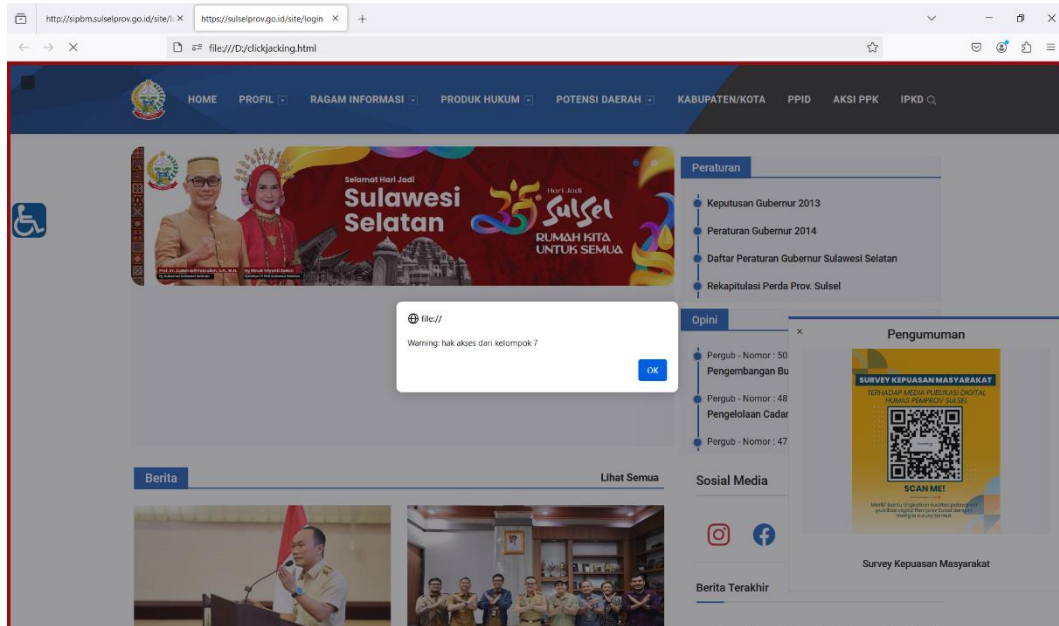
    /* Efek hover pada tombol */
    input[type="button"]:hover {
        background-color: #426043;
    }
</style>
</head>

<body>
    <div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->
    <iframe src="https://sulselprov.go.id/"></iframe>
</body>

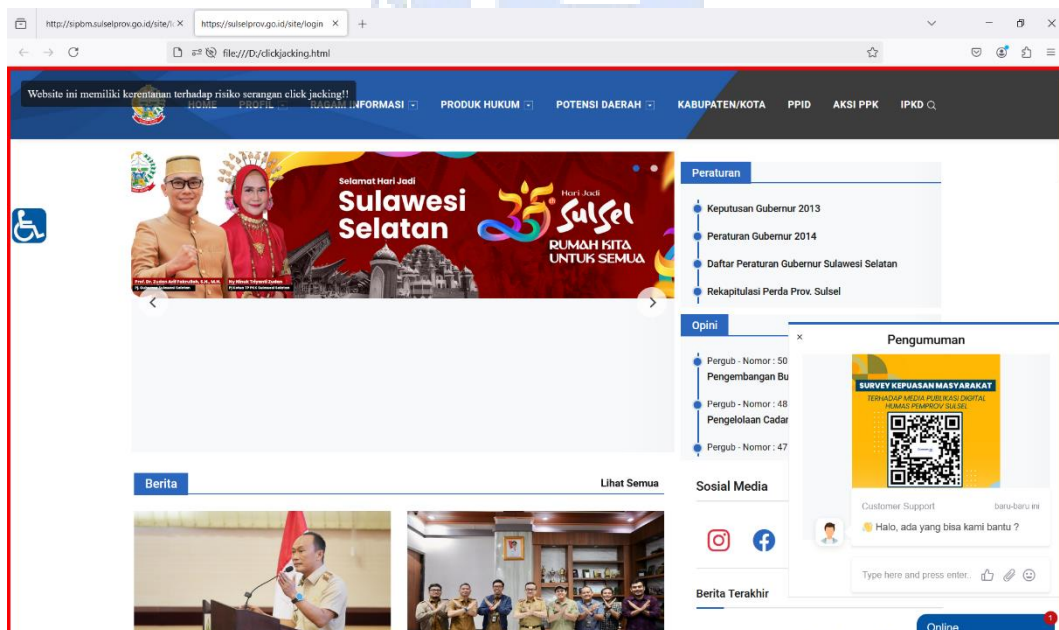
</html>

```

Setelah selesai simpan file di Visual StudioCodanya contoh: **euybchc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul *Warning* dalam bentuk *PopUp* dengan tulisan “**Warning: hak akses dari kelompok 7**”



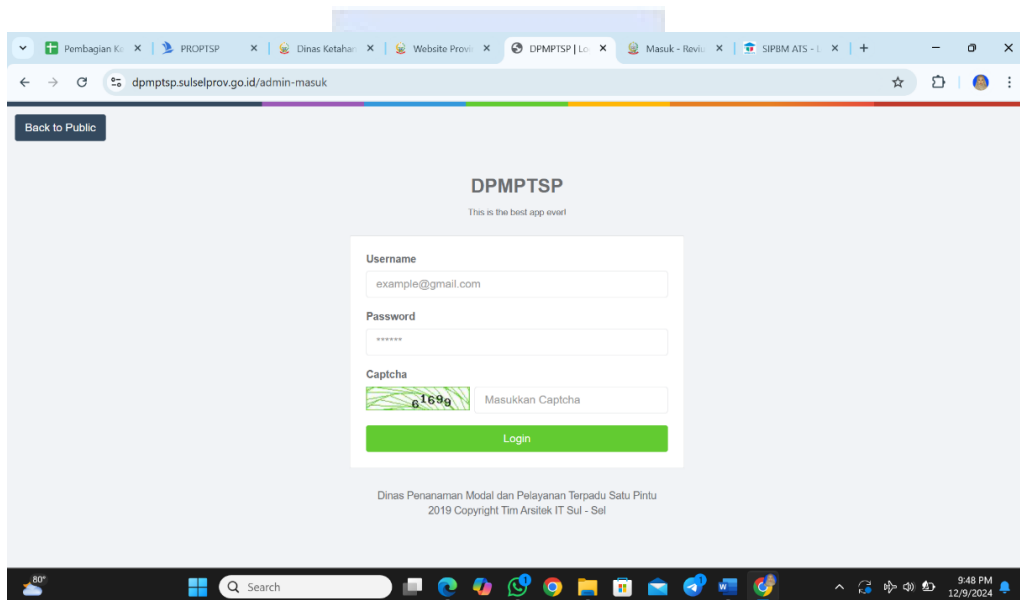
Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <https://sulselprov.go.id> yang mana pada bagian pojok kiri menunjukkan adanya peringatan: ***"Website ini memiliki kerentanan terhadap risiko serangan click jacking!!"***



2.5 Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu (<https://dpmpstp.sulselprov.go.id/>)

2.5.1 Informasi Website

Situs web Dinas Penanaman Modal dan Pelayanan Terpadu Satu Pintu (DPMPTSP) Provinsi Sulawesi Selatan merupakan pusat informasi dan layanan yang terkait dengan investasi dan perizinan terpadu. positioning ini menyediakan akses ke berbagai layanan seperti peluang investasi, tahapan proses perizinan, info proyek strategis, dan profil ekonomi daerah. Dalam mendukung kepentingan investasi, DPMPTSP Sulawesi Selatan secara bersamaan mengoperasikan Mal Pelayanan Publik, yang mengintegrasikan dua puluh tiga organisasi perangkat daerah, kementerian/lembaga, dan asosiasi untuk mempercepat proses perizinan dan mendukung pemulihan ekonomi.



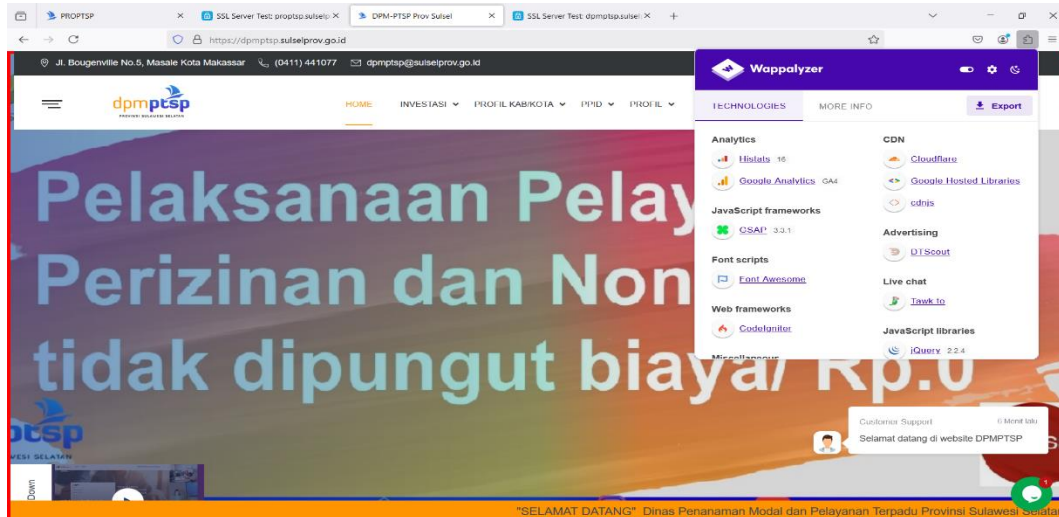
2.5.2 Pengumpulan Informasi Teknologi

Situs web dpmpstp.sulselprov.go.id menggunakan teknologi-teknologi modern untuk membangun situsnya.

- **Framework:** Kemungkinan besar menggunakan Laravel atau CodeIgniter untuk struktur dan kemudahan pengembangan.
- **Database:** Mungkin menggunakan MySQL atau PostgreSQL untuk menyimpan data.
- **Web Server:** Nginx digunakan untuk menyajikan konten situs web.

- **CDN:** Google CDN digunakan untuk mempercepat loading situs.
- **Fitur Tambahan:** Menggunakan JavaScript, Google Fonts, live chat, dan mungkin Google Analytics.

Secara garis besar, situs ini dibangun dengan teknologi yang populer dan dirancang untuk memberikan pengalaman pengguna yang baik.



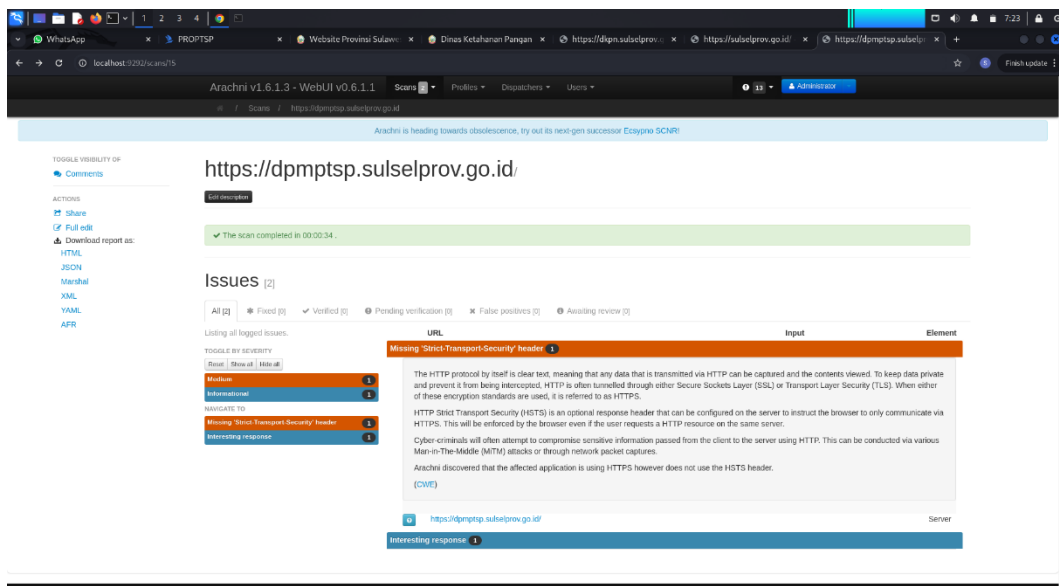
2.5.3 Hasil Scanning Web Vulnerability

2.5.3.1 Menggunakan Arachni

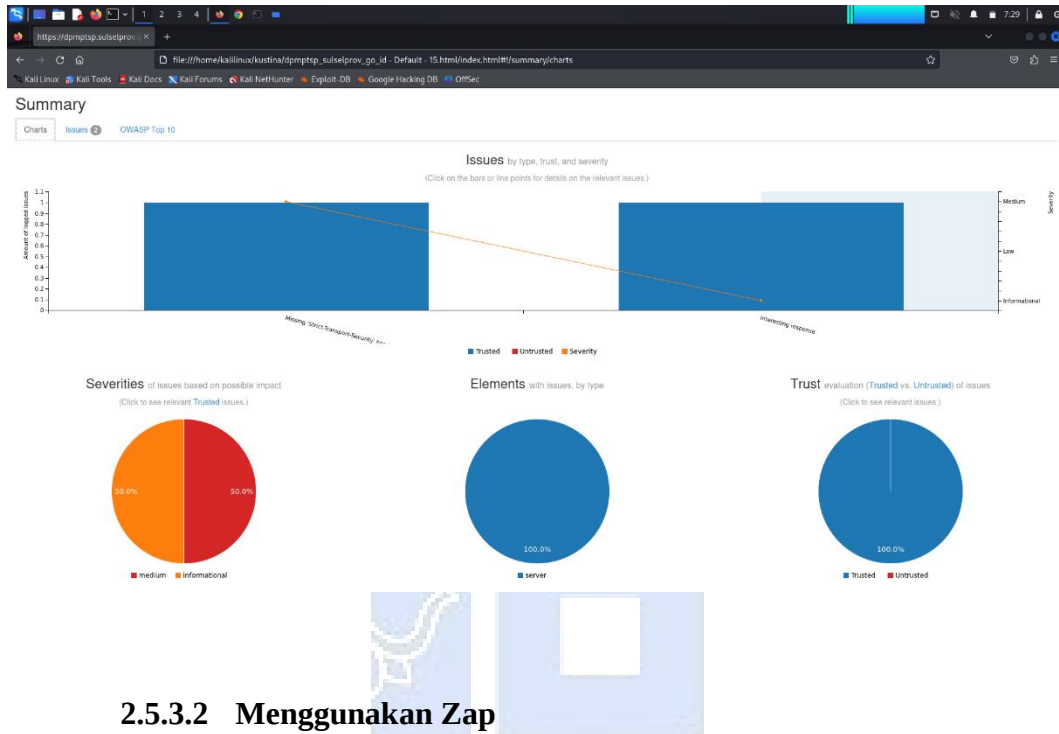
Tampilan dibawah ini merupakan hasil dari scanning domain

<https://dpmpts.sulselprov.go.id> berisi:

- **Medium 1** yaitu **Missing 'Strict-Transport-Security' header**, dan **Information 1** yaitu **Interesting response**.



Pada tampilan dibawah menunjukkan Summary Chart hasil dari scanning arachni yang telah dilakukan. Gambar diatas menunjukkan Issues bewarna biru atau Information, Medium dan Infromation untuk Severities masing-masing 50%, untuk element 100% serever, untuk Trust 100%.



2.5.3.2 Menggunakan Zap

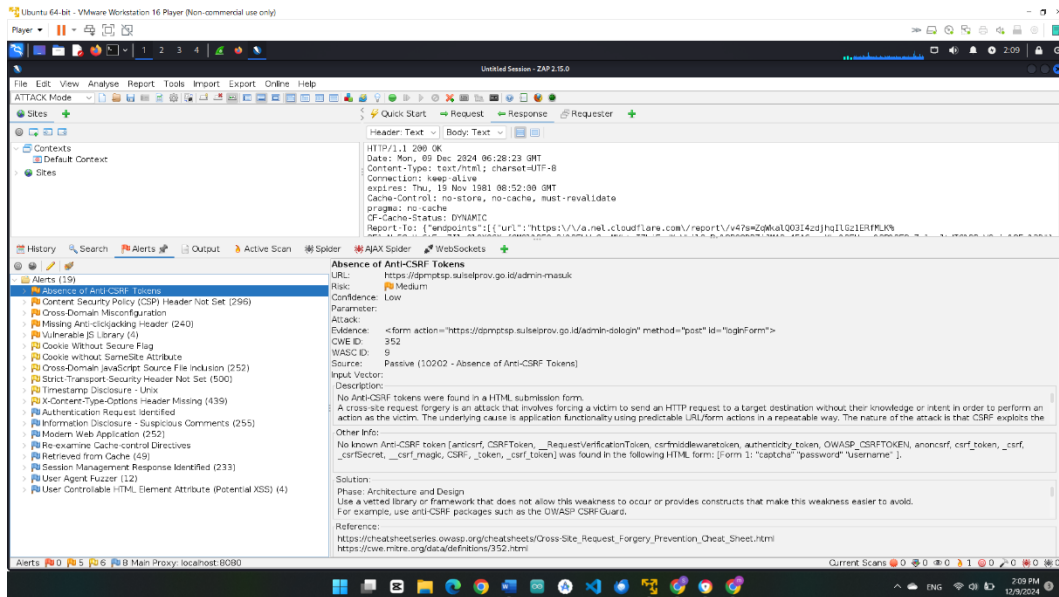
Hasil pemindaian ZAP menunjukkan bahwa situs web `dpmptsp.sulselprov.go.id` memiliki beberapa kelemahan keamanan yang serius.

- **Kurangnya perlindungan dasar:** Situs ini tidak memiliki header keamanan yang penting seperti CSP, X-Frame-Options, dan HSTS.
- **Rentan terhadap serangan:** Situs ini rentan terhadap serangan seperti XSS, CSRF, dan pencurian cookie.
- **Informasi sensitif terekspos:** Ada kemungkinan informasi sensitif terpapar dalam kode sumber.

Akibatnya, situs ini berisiko:

- **Dibobol:** Penyerang dapat mengambil alih situs atau mencuri data pengguna.

- **Disalahgunakan:** Situs ini bisa digunakan untuk menyebarkan malware atau melakukan serangan ke situs lain.
- **Merusak reputasi:** Kejadian keamanan dapat merusak kepercayaan pengguna terhadap situs.



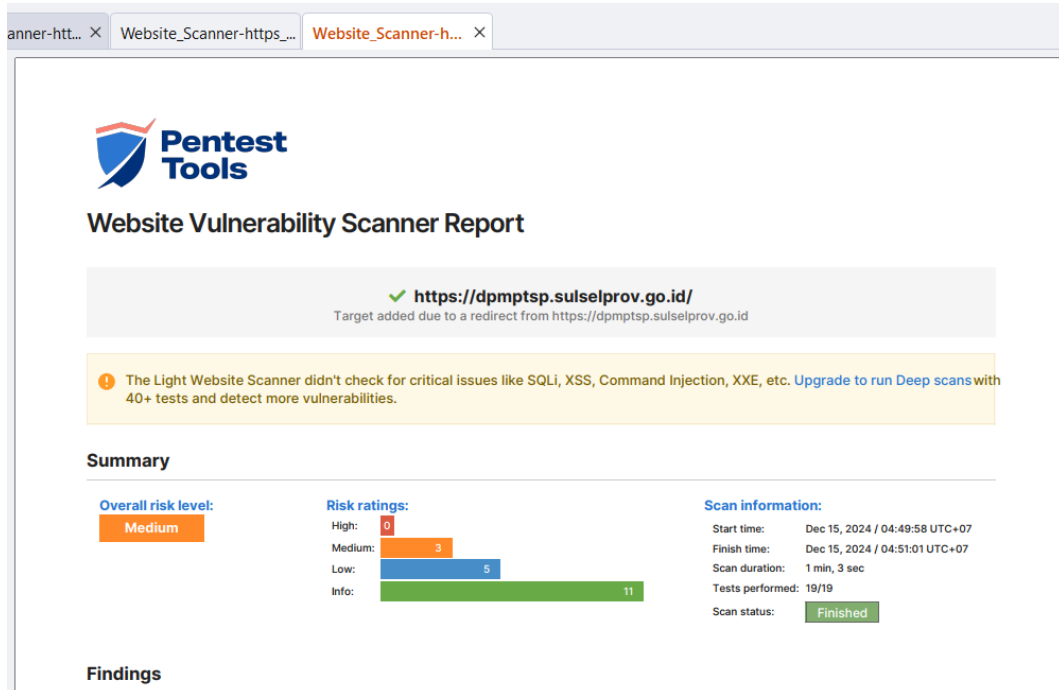
2.5.3.3 Menggunakan Pentest Tools

Berdasarkan dokumen scan tersebut, berikut ringkasan hasil pemindaian keamanan website <https://dpmptsp.sulselprov.go.id/>:

Tingkat Risiko Keseluruhan: Medium

Statistik Risiko:

- High: 0
- Medium: 3
- Low: 5
- Info: 11



Temuan Utama:

1. Masalah Cookie yang Tidak Aman:
 - Cookie tidak memiliki flag "Secure"
 - Cookie tidak memiliki flag "HttpOnly"
 - Ini dapat membuat cookie rentan terhadap pencurian dan serangan XSS
2. Kerentanan Software Server:
 - Menggunakan jQuery versi 2.2.4 yang memiliki beberapa CVE (kerentanan):
 - CVE-2015-9251: Rentan terhadap XSS
 - CVE-2019-11358: Masalah Object.prototype pollution
 - CVE-2020-11023 & CVE-2020-11022: Potensi eksekusi kode tidak terpercaya
3. Header Keamanan yang Hilang:
 - X-Content-Type-Options
 - Strict-Transport-Security (HSTS)
 - Content-Security-Policy
 - Referrer-Policy

4. File security.txt tidak ditemukan:

- Tidak ada jalur resmi untuk melaporkan masalah keamanan

Findings

 **Insecure cookie setting: missing Secure flag** CONFIRMED

URL	Cookie Name	Evidence
https://dpmpstps.sulseiprov.go.id/	TS0178b9b4, TS1ba82554027, ci_session	Set-Cookie: TS0178b9b4=0173969af080e088320f5e841831b15abe92af9359238731fdf59bb0c5b57f0216cfe48b8ade663d38ca39c9e13bc32910de4ba0689c564bc587ec6064d4d38a2331a38d4c Set-Cookie: TS1ba82554027=08c58026a5ab200075ea62743642c425f7ee96bd6cc6d06573d168ada43f1e84935434e22cd8d569084abe2f6a113000982f62f9e3e26967d6926eeca993e35ef8f7ecc70b8f95b9c4544ebafe9bb60d7bce24b81def8f51543ad36b268 Set-Cookie: ci_session=ab0339e400ae750a628ba4a1ccbb56f23670f974 Request / Response

[Details](#)

Risk description:
The risk exists that an attacker will intercept the clear-text communication between the browser and the server and he will steal the cookie of the user. If this is a session cookie, the attacker could gain unauthorized access to the victim's web session.

Recommendation:
Whenever a cookie contains sensitive information or is a session token, then it should always be passed using an encrypted channel. Ensure that the secure flag is set for cookies containing such sensitive information.

References:
https://owasp.org/www-project-web-security-testing-guide/stable/4-Web_Application_Security_Testing/06-Session_Management_Testing/02-Testing_for_Cookies_Attributes.html

Classification:
CWE : CWE-614
OWASP Top 10 - 2017 : A6 - Security Misconfiguration
OWASP Top 10 - 2021 : A5 - Security Misconfiguration

Rekomendasi Utama:

1. Mengaktifkan flag Secure dan HttpOnly pada cookie
2. Memperbarui jQuery ke versi terbaru
3. Mengimplementasikan header keamanan yang hilang
4. Membuat file security.txt untuk pelaporan masalah keamanan
5. Mengurangi informasi teknologi yang terekspos

Pemindaian dilakukan pada 15 Desember 2024 dan membutuhkan waktu 1 menit 3 detik untuk menyelesaikan 19 tes keamanan.

2.5.4 List Vulnerability (Daftar Kerentanan)

No	kerentanan	Tingkat Kerentanan
1.	Strict-Transport-Security	
2.	Absence of Anti-CSRF Tokens	

3.	Content Security Policy (CSP) Header Not Set	Medium
4.	Cross-Domain Misconfiguration	
5.	Missing Anti-clickjacking Header	
6.	Vulnerable JS Library	
7.	Cookie Without Secure Flag	Low
8.	Cookie Without SameSite Attribute	
9.	Cross-Domain JavaScript Source File Inclusion	
10.	Strict-Transport-Security Header Not Set	
11.	Timestamp Disclosure – Unix	
12.	X-Content-Type-Options Header Missing	
13.	Authentication Request Identified	Informational
14.	Information Disclosure - Suspicious Comments	
15.	Modern Web Application	
16.	Re-examine Cache-control Directives	
17.	Retrieved from Cache	
18.	Session Management Response Identified	
19.	User Agent Fuzzer	
20.	User Controllable HTML Element Attribute	

2.5.5 Detail Vulnerability

a. Medium Severity (Tingkat Kerentanan Sedang)

1. Strict-Transport-Security

Tanpa header ini, aplikasi tidak memaksa penggunaan HTTPS, meningkatkan risiko serangan Man-in-the-Middle (MITM).

Solusi: Set header Strict-Transport-Security ke max-age=31536000; includeSubDomains; preload.

2. Absence of Anti-CSRF Tokens

Tanpa token CSRF, aplikasi rentan terhadap serangan Cross-Site Request Forgery (CSRF).

Solusi: Gunakan token CSRF unik pada setiap permintaan form dan validasi di server.

3. Content Security Policy (CSP) Header Not Set

Tanpa header ini, aplikasi rentan terhadap injeksi skrip berbahaya seperti Cross-Site Scripting (XSS).

Solusi: Set header Content-Security-Policy untuk membatasi sumber daya yang dapat dimuat oleh aplikasi.

4. Cross-Domain Misconfiguration

Konfigurasi lintas domain yang salah dapat memungkinkan akses tidak sah ke sumber daya aplikasi.

Solusi: Konfigurasikan header CORS (Cross-Origin Resource Sharing) dengan tepat untuk hanya mengizinkan domain terpercaya.

5. Missing Anti-clickjacking Header

Tanpa header ini, aplikasi dapat dibingkai oleh situs jahat untuk serangan clickjacking.

Solusi: Set header X-Frame-Options ke "DENY" atau "SAMEORIGIN".

6. Vulnerable JS Library

Penggunaan perpustakaan JavaScript yang rentan dapat memungkinkan serangan seperti XSS atau eksploitasi lainnya.

Solusi: Perbarui pustaka JavaScript ke versi terbaru yang sudah diperbaiki keamanannya.

b. Low Severity (Tingkat **Kerentanan** Rendah)

1. **Cookie Without Secure Flag**

Cookie telah ditetapkan tanpa tanda aman (secure flag), sehingga dapat diakses melalui koneksi yang tidak terenkripsi. Hal ini berpotensi mengungkapkan informasi sensitif jika cookie dikirim melalui HTTP.

Solusi: Tetapkan tanda **secure** untuk semua cookie yang berisi informasi sensitif agar hanya dapat dikirim melalui koneksi HTTPS.

2. **Cookie Without SameSite Attribute**

Cookie tidak memiliki atribut SameSite, sehingga dapat dikirim dalam permintaan lintas situs (cross-site). Hal ini meningkatkan risiko serangan CSRF dan penyertaan skrip lintas situs.

Solusi: Tetapkan atribut **SameSite** pada cookie ke 'lax' atau 'strict' untuk mengurangi risiko.

3. **Cross-Domain JavaScript Source File Inclusion**

Halaman memuat file JavaScript dari domain pihak ketiga, yang dapat menjadi risiko jika sumber tidak terpercaya.

Solusi: Pastikan file JavaScript hanya dimuat dari sumber terpercaya, dan sumber tersebut tidak dapat dikontrol oleh pengguna aplikasi.

4. **Strict-Transport-Security Header Not Set**

Server tidak dikonfigurasi untuk menggunakan HTTP Strict Transport Security (HSTS), yang memungkinkan akses melalui koneksi tidak aman.

Solusi: Terapkan header **Strict-Transport-Security** di server untuk memastikan semua komunikasi dilakukan melalui HTTPS.

5. **Timestamp Disclosure – Unix**

Aplikasi/server mengungkapkan data stempel waktu Unix, yang dapat digunakan untuk menganalisis pola aktivitas atau serangan.

Solusi: Konfirmasikan bahwa data stempel waktu tidak sensitif dan tidak dapat digunakan untuk eksploitasi lebih lanjut.

6. **X-Content-Type-Options Header Missing**

Header X-Content-Type-Options tidak disetel, memungkinkan browser untuk melakukan MIME-sniffing pada

konten, yang dapat menyebabkan interpretasi tipe konten yang salah.

Solusi: Atur header **X-Content-Type-Options** ke 'nosniff' untuk memastikan peramban hanya memproses konten sesuai dengan tipe yang dinyatakan.

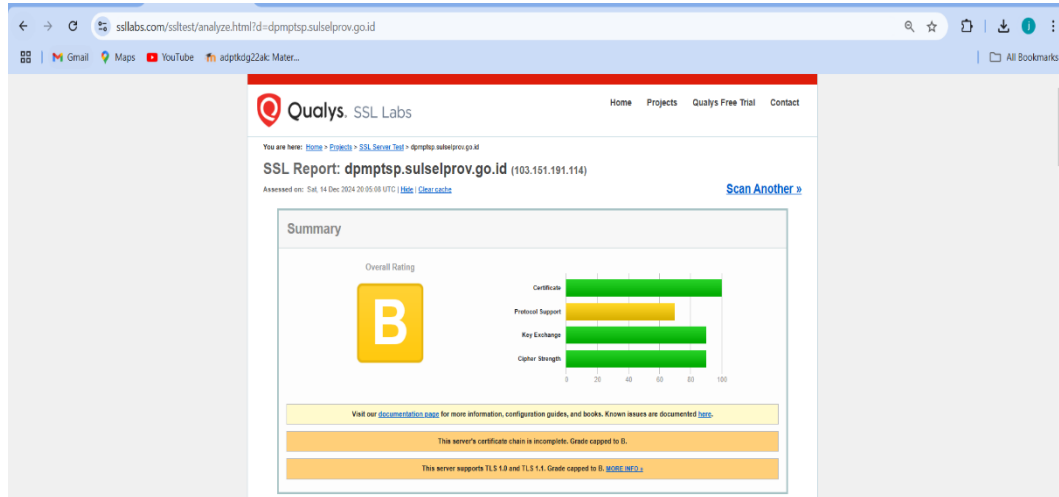
2.5.6 Vulnerability Assessment (Pengujian Kerentanan)

a) *SSL Report*

Berdasarkan gambar di atas, berikut adalah analisis hasil dari laporan SSL menggunakan **Qualys SSL Labs** untuk domain **dpmptsp.sulselprov.go.id**:

1. Ringkasan Penilaian SSL

- **Overall Rating: B**
 - Situs ini mendapatkan skor **B** karena adanya masalah tertentu yang memengaruhi keamanan sertifikat SSL.
- **Detail Penilaian:**
 - **Certificate:** Penilaian untuk sertifikat SSL cukup baik.
 - **Protocol Support:** Mendukung protokol yang memadai, tetapi ada beberapa pembatasan.
 - **Key Exchange:** Proses pertukaran kunci cukup aman.
 - **Cipher Strength:** Kekuatan cipher cukup memadai.
- **Catatan Tambahan:**
 - **The server's certificate chain is incomplete. Grade capped to B.**
 - Masalah ini menunjukkan bahwa rantai sertifikat tidak lengkap, yang menyebabkan nilai akhir dibatasi pada **B**.
 - **This server supports TLS 1.0 and TLS 1.1. Grade capped to B.**
 - Server masih mendukung protokol TLS 1.0 dan TLS 1.1, yang sudah dianggap usang dan tidak aman sehingga menyebabkan nilai akhir dibatasi pada **B**.



2. Detail Sertifikat

- **Jenis Sertifikat:** RSA 2048 bits (SHA256withRSA)
- **Subjek:** *.sulselprov.go.id
- **Common Names:** *.sulselprov.go.id
- **Alternative Names:** *.sulselprov.go.id, sulselprov.go.id
- **Serial Number:** 00998e11b5eec1cd3473ba753d6e2994b
- **Masa Berlaku:**
 - **Valid From:** Senin, 1 April 2024.
 - **Valid Until:** Kamis, 1 Mei 2025 (berlaku selama 1 tahun 1 bulan).
- **Kunci Keamanan:**
 - Ukuran kunci: **RSA 2048 bits** (tidak lemah).
- **Issuer (Penerbit):**
 - Sertifikat diterbitkan oleh **Sectigo RSA Domain Validation Secure Server CA**.
- **Algoritma Tanda Tangan:** SHA256withRSA
- **Certificate Transparency:** **Yes (certificate)**
 - Sertifikat ini mendukung transparansi sertifikat.

3. Masalah yang Ditemukan

- **Chain Issues: Incomplete**
 - Rantai sertifikat tidak lengkap. Hal ini biasanya berarti server tidak menyediakan semua sertifikat intermediate yang

diperlukan untuk membangun kepercayaan penuh pada sertifikat.

- **Protokol yang Didukung:**

- Server mendukung protokol lama (TLS 1.0 dan TLS 1.1), yang sudah dianggap usang dan tidak aman.

- **OCSP Must-Staple:** Tidak diaktifkan.

- Tidak ada mekanisme stapling OCSP untuk memastikan validasi langsung dari status sertifikat.

4. Keamanan & Dukungan

- **Trusted:** Sertifikat dipercaya oleh sebagian besar browser dan platform (Mozilla, Apple, Android, Java, Windows).
- **DNS CAA:** Tidak ada konfigurasi DNS CAA untuk domain ini.

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1 	
Subject	*.sulselprov.go.id Fingerprint SHA256: 321bf77067156df3157be702a171be8599d282d033d3f0b85f26354218b251a Pin SHA256: FUoJDcpFAun9xdvHd/lanGvT+wiPf/3bZ7pzG9a08LU=
Common names	*.sulselprov.go.id
Alternative names	*.sulselprov.go.id sulselprov.go.id
Serial Number	00998e11b5ece1cd3437ba75f3d6e2994b
Valid from	Mon, 01 Apr 2024 00:00:00 UTC
Valid until	Thu, 01 May 2025 23:59:59 UTC (expires in 4 months and 17 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Sectigo RSA Domain Validation Secure Server CA AIA: http://crt.sectigo.com/SectigoRSADomainValidationSecureServerCA.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	OCSP OCSP: http://ocsp.sectigo.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows
 Additional Certificates (if supplied) 	
Certificates provided	1 (1604 bytes)
Chain issues	Incomplete

Rekomendasi Untuk Peningkatan:

1. **Lengkapi Rantai Sertifikat:**

- Pastikan server menyediakan semua sertifikat intermediate untuk membangun rantai kepercayaan penuh.

2. **Nonaktifkan TLS 1.0 dan TLS 1.1:**

- Hanya dukung protokol yang lebih aman seperti **TLS 1.2** dan **TLS 1.3**.

3. **Aktifkan OCSP Stapling:**

- Tambahkan dukungan untuk OCSP Stapling untuk validasi status sertifikat yang lebih cepat dan aman.

4. **Konfigurasi DNS CAA:**

- Tambahkan DNS CAA untuk mengontrol Certificate Authorities (CA) yang diizinkan menerbitkan sertifikat untuk domain Anda.

Penilaian ini menunjukkan bahwa meskipun situs ini memiliki sertifikat SSL yang valid, ada beberapa aspek yang perlu diperbaiki untuk meningkatkan keamanan dan kepercayaan

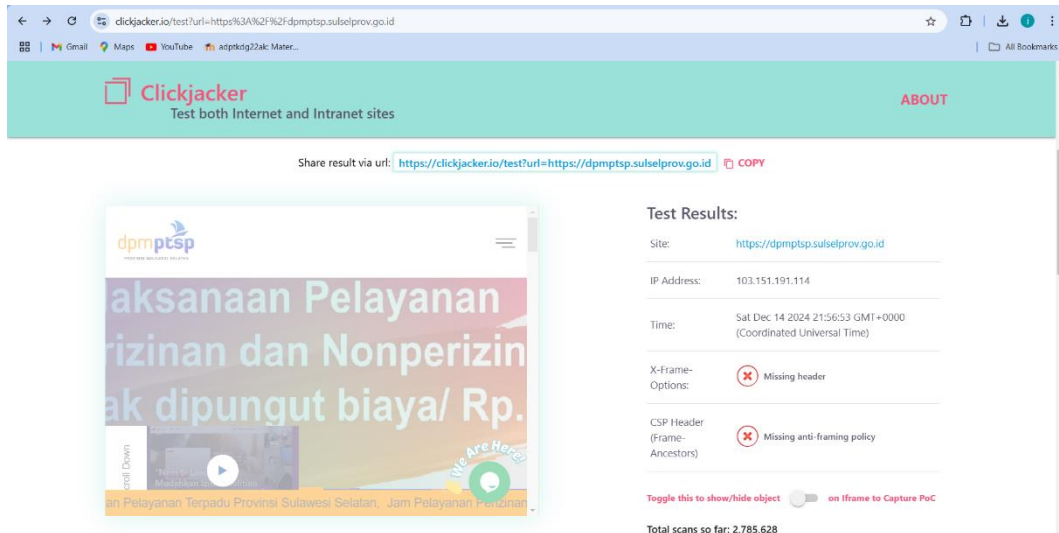
b) ClickJacking

Dari gambar dibawah ini, saya dapat menjelaskan hasil pengujian keamanan website menggunakan tool Clickjacking:

1. Website yang diuji: <https://dpmpstps.sulsel.prov.go.id>
2. IP Address: 103.151.191.114
3. Waktu pengujian: Sat Dec 14 2024 21:56:53 (GMT+0000)

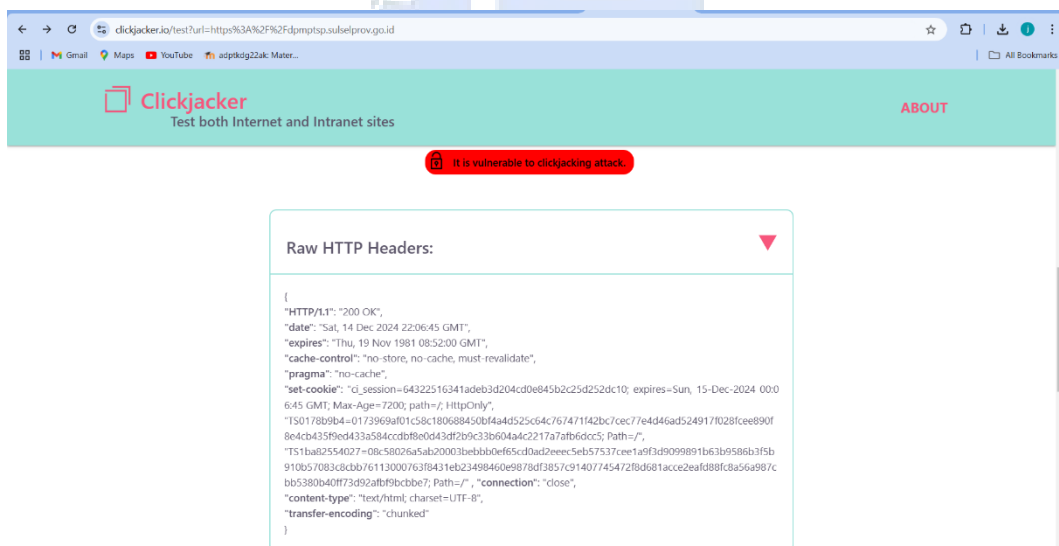
Hasil pengujian menunjukkan beberapa masalah keamanan:

1. X-Frame-Options: Missing header (Header X-Frame-Options tidak ada)
2. CSP Header (Frame-Ancestors): Missing anti-framing policy (Kebijakan anti-framing tidak ada)
3. Status: Website tersebut vulnerable (rentan) terhadap serangan clickjacking



Raw HTTP Headers menunjukkan beberapa informasi response header dari server, termasuk:

- HTTP/1.1 200 OK
- Date dan Expires
- Cache-control settings
- Set-cookie values
- Content-type: text/html



Kesimpulannya, website ini memiliki kerentanan keamanan karena tidak memiliki proteksi yang cukup terhadap serangan clickjacking. Untuk meningkatkan keamanan, sebaiknya:

1. Mengimplementasikan X-Frame-Options header

2. Menambahkan CSP Frame-Ancestors policy
3. Mengkonfigurasi kebijakan framing yang tepat

Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://dpmpts.sulselprov.go.id/site/login</title>
  <script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
      alert("Warning: hak akses dari kelompok 7");
      // Menampilkan pesan di dalam elemen dengan id "warning-message"
      document.getElementById("warning-message").innerText = "Website
ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
  </script>
  <style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
      height: 100%;
      margin: 0;
      padding: 0;
      overflow: hidden;
    }

    /* Menyusun iframe untuk mengisi seluruh layar */
    iframe {
      width: 100%;
```

```

height: 100%;
border: none;
opacity: 15;
}

/* Menyusun pesan peringatan */
#warning-message {
    position: absolute;
    top: 20px;
    left: 20px;
    background-color: rgba(19, 18, 18, 0.7);
    color: white;
    padding: 10px;
    border-radius: 5px;
    z-index: 10;
}

/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
    z-index: 10;
    position: absolute;
    top: 100px;
    left: 20px;
    padding: 10px 20px;
    background-color: #100f0f;
    color: white;
    border: none;
    cursor: pointer;
    font-size: 16px;
}

/* Efek hover pada tombol */

```

```

input[type="button"]:hover {
    background-color: #426043;
}
</style>
</head>

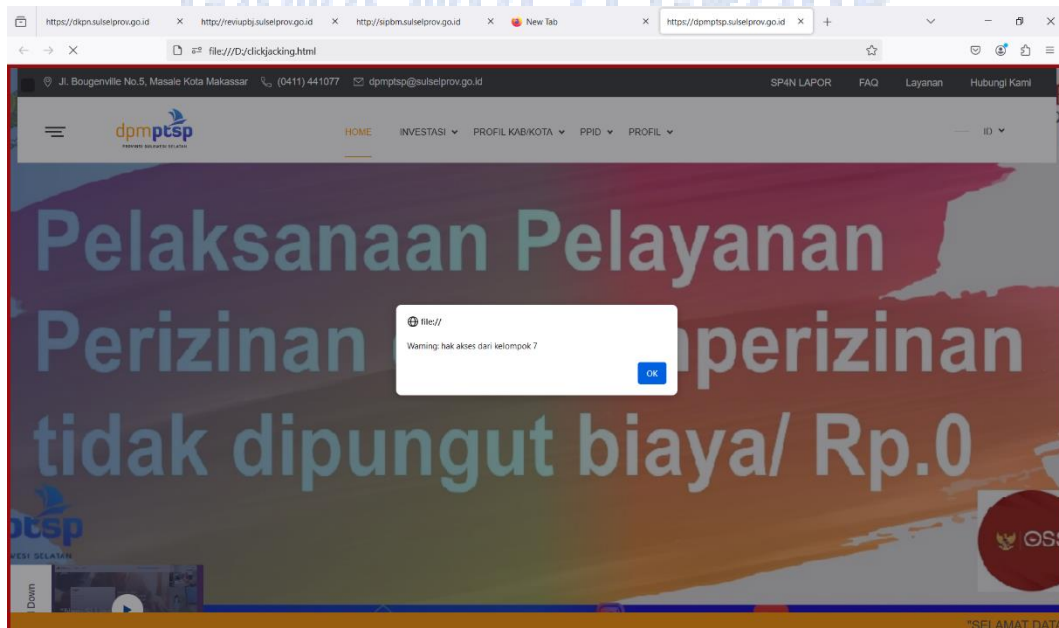
<body>
    <div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->

    <iframe src="https://dpmpts.sulselprov.go.id/"></iframe>
</body>

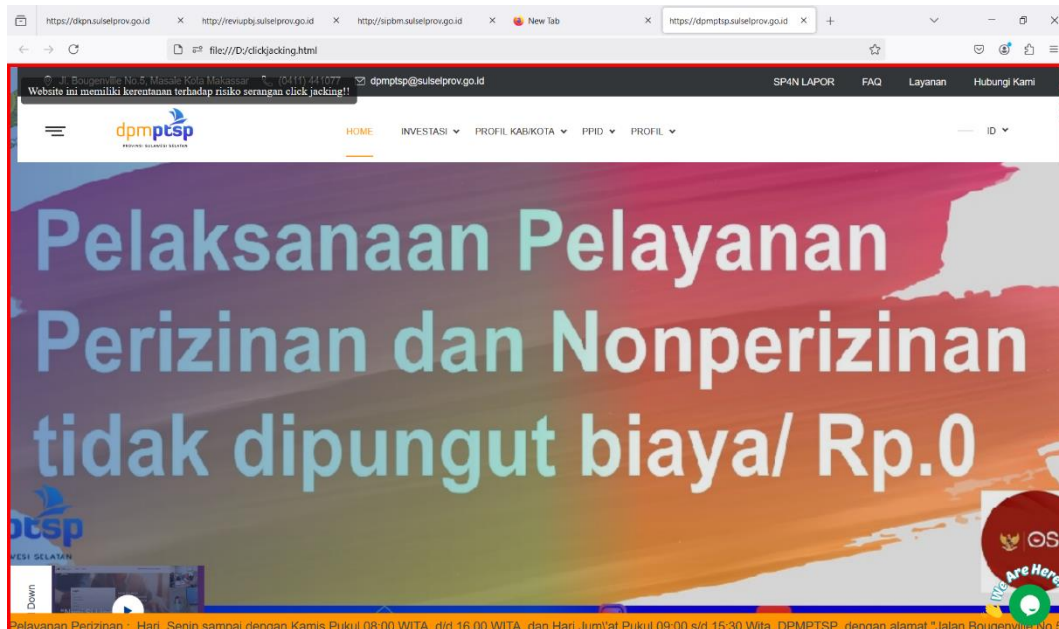
</html>

```

Setelah selesai simpan file di Visual StudioCodanya contoh: **euybhc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul *Warning* dalam bentuk *PopUp* dengan tulisan “**Warning: hak akses dari kelompok 7**”



Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <https://dpmpts.sulselprov.go.id> yang mana pada bagian pojok kiri menunjukkan adanya peringatan : ***“Website ini memiliki kerentanan terhadap risiko serangan click jacking!!”***



c) Wireshark

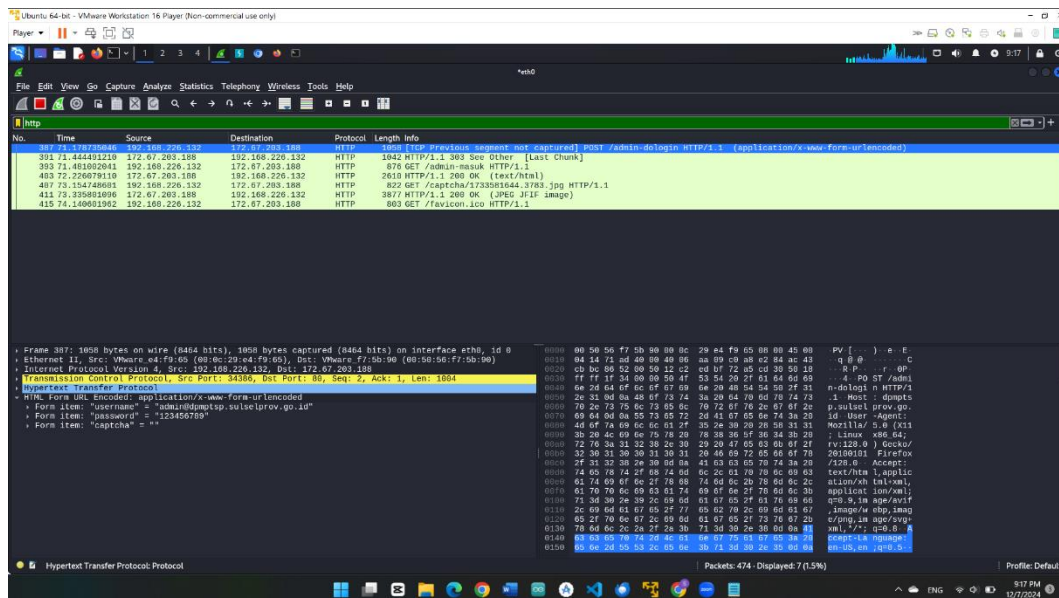
Wireshark adalah network protocol analyzer yang digunakan untuk menangkap, menganalisis, dan memantau lalu lintas jaringan secara real-time. POC kali ini menggunakan teknik Man-in-the-Middle (MITM) adalah jenis serangan siber di mana penyerang menyusup di antara dua pihak yang berkomunikasi, memungkinkan mereka untuk mencegat, memanipulasi, atau mencuri data yang dikirimkan.

Jadi jika user melakukan login yang menggunakan protokol HTTP, maka dapat dilihat User dan Passwordnya. Seperti pada gambar dibawah ini terlihat usernya menggunakan admin@dpmpts.sulselprov.go.id dan passwornya adalah **123456789**. Dari analisis gambar dibawah ini terlihat adanya aktivitas monitoring/sniffing traffic jaringan saat proses login ke sistem DPMPTSP. Ini menunjukkan potensi kerentanan keamanan karena

kredensial login dapat terlihat dalam bentuk plain text melalui packet capture.

Saran keamanan:

1. Sebaiknya sistem menggunakan HTTPS untuk enkripsi data
2. Implementasi metode enkripsi untuk pengiriman kredensial login
3. Penggunaan certificate SSL/TLS yang valid
4. Penerapan additional security layer seperti 2FA

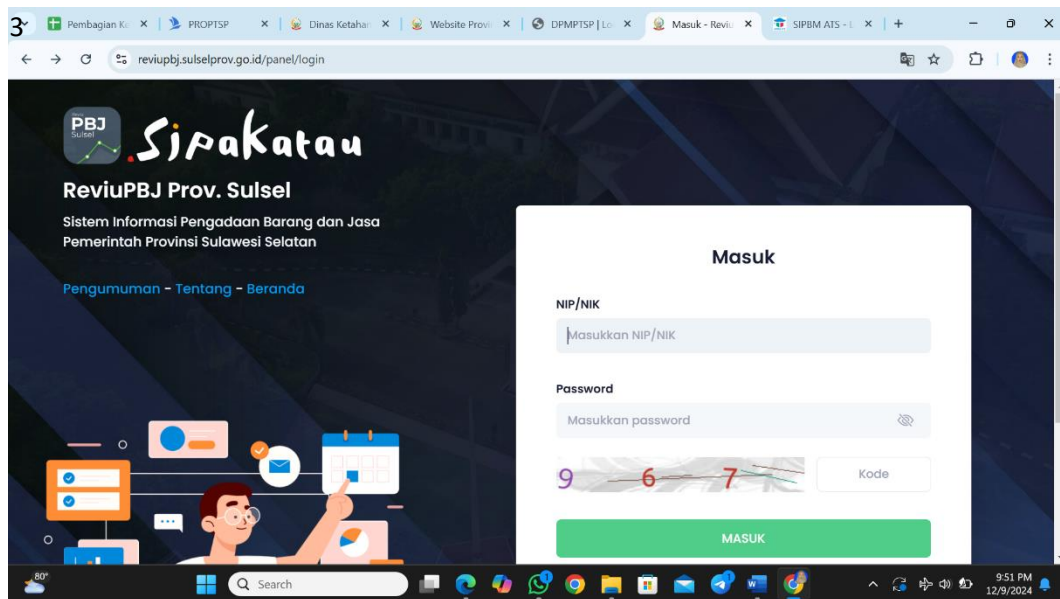


GAMA MULTI GROUP

2.6 Sistem Informasi Pengadaan Barang dan Jasa Pemerintah Provinsi Sulawesi Selatan (<http://reviupbj.sulselprov.go.id>)

2.6.1 Informasi Website

Situs web sistem pengadaan barang dan jasa Pemerintah Provinsi Kepulauan Seribu dapat menjadi platform digital yang bertujuan untuk mendukung pengadaan barang dan jasa dengan cara yang jelas, bertanggung jawab, dan ekonomis. Situs web ini terintegrasi dengan berbagai sistem seperti SPSE (Sistem Pengadaan Secara Elektronik) dan Sirup (Sistem Informasi Pengadaan Secara Umum) untuk memastikan metode pengadaan sesuai dengan hukum dan dapat diakses oleh masyarakat umum, pemasok produk/jasa, dan instansi pemerintah yang terkait.

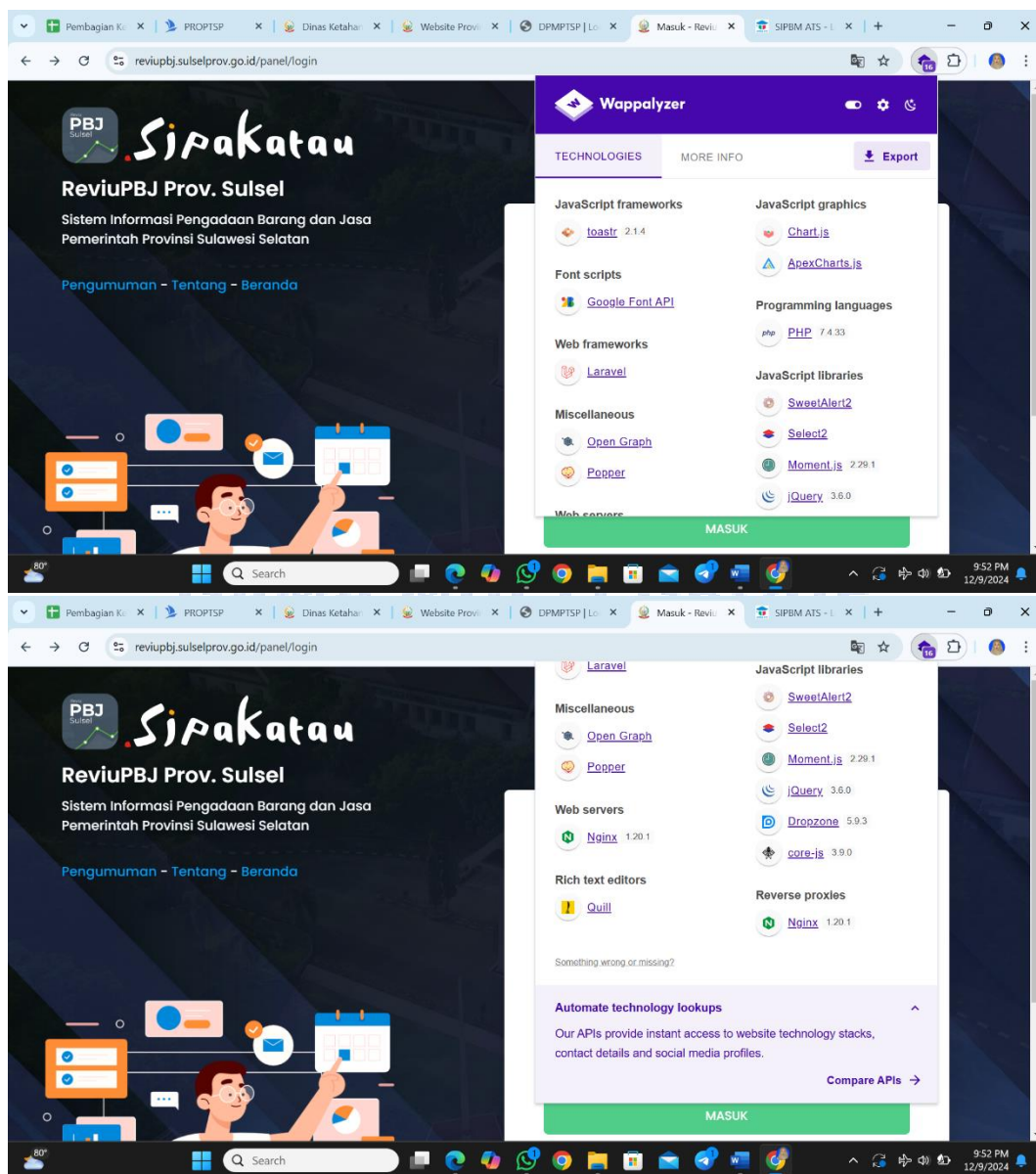


3.1.1 Pengumpulan Informasi Teknologi

Situs web <https://reviupbj.sulselprov.go.id/panel/login> dibangun dengan menggunakan tumpukan teknologi yang solid dan modern. Penggunaan Laravel sebagai framework menunjukkan bahwa situs ini dibangun dengan memperhatikan best practices dalam pengembangan web. Kombinasi berbagai library JavaScript memberikan fitur-fitur yang dinamis dan interaktif pada situs web ini.

Secara keseluruhan, situs ini terlihat cukup baik dari segi teknologi yang digunakan. Namun, untuk mengetahui lebih detail tentang keamanan dan kinerja situs ini, diperlukan analisis yang lebih mendalam, termasuk:

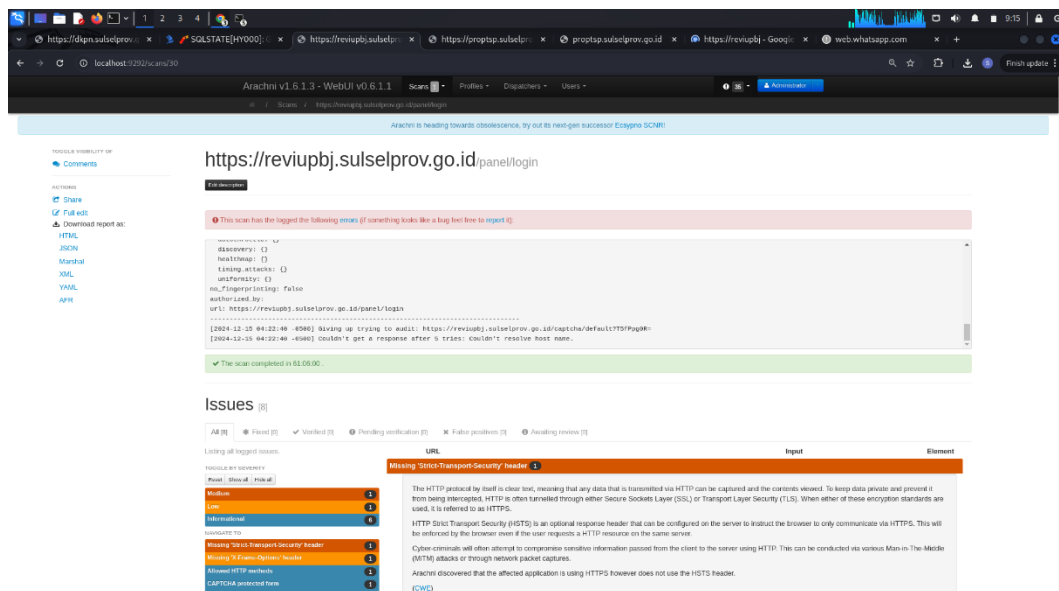
- **Pemeriksaan kode sumber:** Untuk mencari potensi kerentanan keamanan seperti XSS, SQL injection, dan lainnya.
- **Pengujian penetrasi:** Untuk menguji sejauh mana situs web dapat ditembus oleh penyerang.
- **Analisis kinerja:** Untuk mengukur kecepatan loading situs dan responsivitasnya.



3.1.2 Hasil Scanning Web Vulnerability

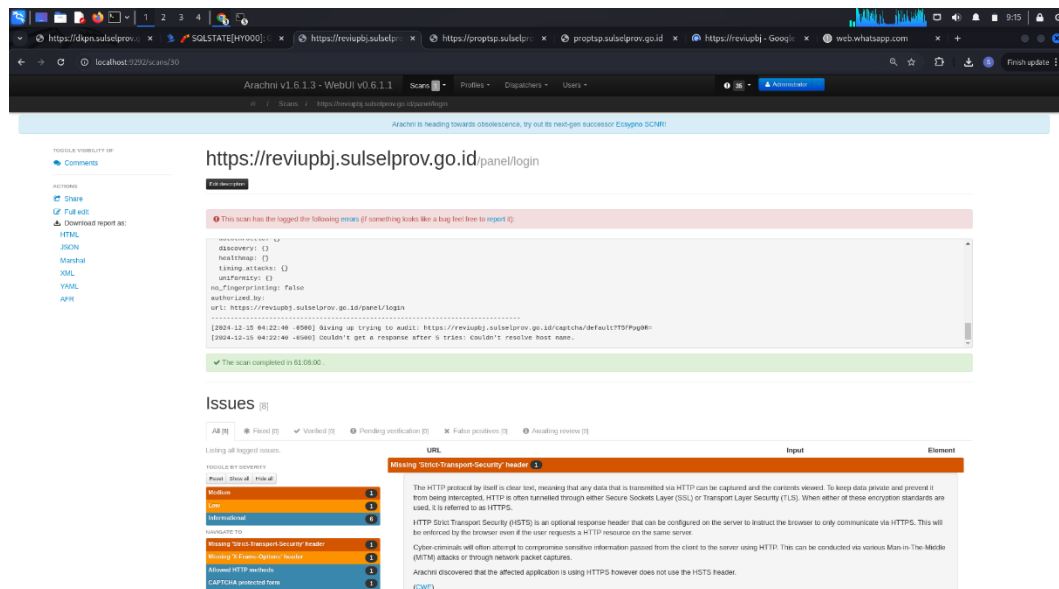
3.1.2.1 Menggunakan Arachni

Pada tampilan dibawah ini menunjukkan bahwa hasil scanning terputus atau telah diblok sehingga tidak dapat menyelesaikan scanning hingga selesai, namun pada tampilan diatas menunjukkan jika sudah terdapat beberapa hal beserta HTML yang dapat dilihat dari hasil proses scanning tersebut.



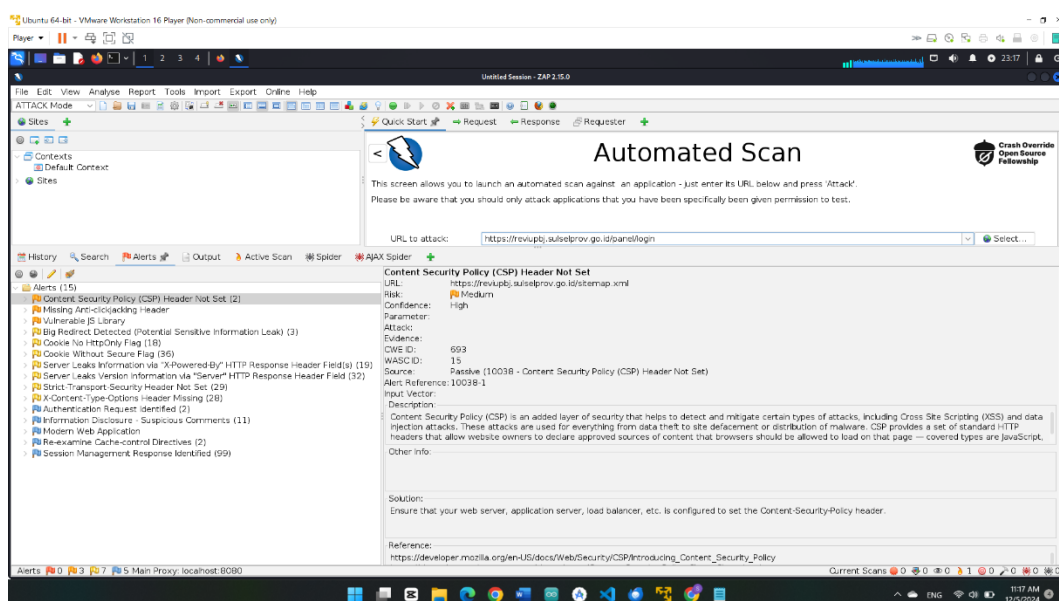
Tampilan dibawah ini merupakan hasil dari scanning domain <http://reviupbj.sulselprov.go.id> berisi: Medium terdapat 1 Missing 'Strict-Transport-Security' header

- Low terdapat 1 dari Missing 'X-Frame-Option' header
- Information 6 yaitu : Allowed HTTP methods, CAPTCHA procted form Insecure cookie, HttpOnly, Interesting response



3.1.2.2 Menggunakan Zap

Pemindaian kerentanan menggunakan ZAP terhadap situs <https://reviupbj.sulselprov.go.id/panel/login> telah mengidentifikasi beberapa masalah keamanan yang serius, terutama terkait dengan kurangnya header Content Security Policy (CSP).

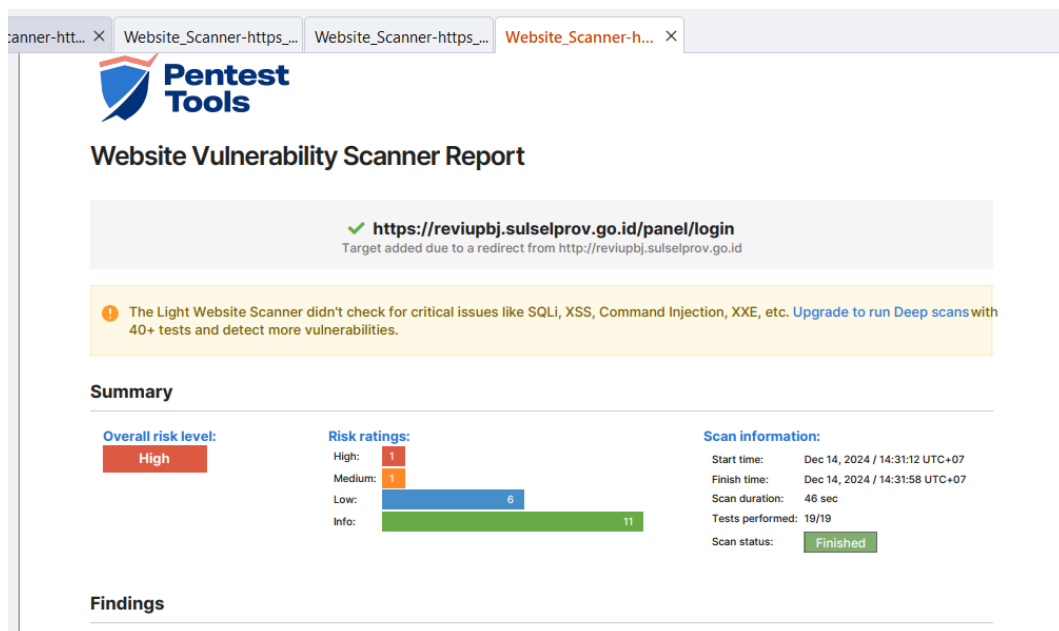


3.1.2.3 Menggunakan Pentest Tools

Berdasarkan hasil pemindaian keamanan website reviupbj.sulselprov.go.id, berikut ringkasan temuan utamanya:

1. Tingkat Risiko Keseluruhan: TINGGI

- Risiko Tinggi: 1 masalah
- Risiko Menengah: 1 masalah
- Risiko Rendah: 6 masalah
- Info: 11 masalah



2. Kerentanan Software Server:

- PHP versi 7.4.33 memiliki beberapa kerentanan serius:
 - CVE-2024-4577 (CVSS 9.8) - Kerentanan dalam PHP-CGI di Windows
 - CVE-2022-4900 (CVSS 5.5) - Buffer overflow
 - CVE-2024-5458 (CVSS 5.3) - Validasi URL yang tidak tepat
- Nginx versi 1.20.1 memiliki beberapa kerentanan:
 - CVE-2022-41741 (CVSS 7.8) - Masalah pada modul MP4
 - CVE-2023-44487 (CVSS 7.5) - Potensi DoS pada HTTP/2

- CVE-2022-41742 (CVSS 7.1) - Crash pada worker process
- CVE-2021-3618 (CVSS 5.8) - Serangan ALPACA

anher-https... Website_Scanner-https... Website_Scanner-https... Website_Scanner-h... X

Vulnerabilities found for server-side software UNCONFIRMED

Risk Level	CVSS	CVE	Summary	Affected software
●	9.8	CVE-2024-4577	In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, when using Apache and PHP-CGI on Windows, if the system is set up to use certain code pages, Windows may use "Best-Fit" behavior to replace characters in command line given to Win32 API functions. PHP CGI module may misinterpret those characters as PHP options, which may allow a malicious user to pass options to PHP binary being run, and thus reveal the source code of scripts, run arbitrary PHP code on the server, etc.	php 7.4.33
●	7.8	CVE-2022-41741	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to corrupt NGINX worker memory, resulting in its termination or potential other impact using a specially crafted audio or video file. The issue affects only NGINX products that are built with the ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.20.1
●	7.5	CVE-2023-44487	The HTTP/2 protocol allows a denial of service (server resource consumption) because request cancellation can reset many streams quickly, as exploited in the wild in August through October 2023.	nginx 1.20.1
●	7.1	CVE-2022-41742	NGINX Open Source before versions 1.23.2 and 1.22.1, NGINX Open Source Subscription before versions R2 P1 and R1 P1, and NGINX Plus before versions R27 P1 and R26 P1 have a vulnerability in the module ngx_http_mp4_module that might allow a local attacker to cause a worker process crash, or might result in worker process memory disclosure by using a specially crafted audio or video file. The issue affects only NGINX products that are built with the module ngx_http_mp4_module, when the mp4 directive is used in the configuration file. Further, the attack is possible only if an attacker can trigger processing of a specially crafted audio or video file with the module ngx_http_mp4_module.	nginx 1.20.1
●	5.8	CVE-2021-3618	ALPACA is an application layer protocol content confusion attack, exploiting TLS servers implementing different protocols but using compatible certificates, such as multi-domain or wildcard certificates. A MITM attacker having access to victim's traffic at the TCP/IP layer can redirect traffic from one subdomain to another, resulting in a valid TLS session. This breaks the authentication of TLS and cross-protocol attacks may be possible where the behavior of one protocol service may compromise the other at the application layer.	nginx 1.20.1

3. Masalah Konfigurasi Keamanan:

- Cookie tidak menggunakan flag Secure
- Header keamanan yang hilang:
 - X-Content-Type-Options
 - Content-Security-Policy
 - Referrer-Policy
 - Strict-Transport-Security

5.5	CVE-2022-4900	A vulnerability was found in PHP where setting the environment variable PHP_CLI_SERVER_WORKERS to a large value leads to a heap buffer overflow.	php 7.4.33
5.3	CVE-2024-5458	In PHP versions 8.1.* before 8.1.29, 8.2.* before 8.2.20, 8.3.* before 8.3.8, due to a code logic error, filtering functions such as filter_var when validating URLs (FILTER_VALIDATE_URL) for certain types of URLs the function will result in invalid user information (username + password part of URLs) being treated as valid user information. This may lead to the downstream code accepting invalid URLs as valid and parsing them incorrectly.	php 7.4.33

Details

Risk description:

The risk is that an attacker could search for an appropriate exploit (or create one himself) for any of these vulnerabilities and use it to attack the system.

Recommendation:

In order to eliminate the risk of these vulnerabilities, we recommend you check the installed software version and upgrade to the latest version.

Classification:

CWE : [CWE-1026](#)

OWASP Top 10 - 2017 : [A9 - Using Components with Known Vulnerabilities](#)

OWASP Top 10 - 2021 : [A6 - Vulnerable and Outdated Components](#)

Rekomendasi Utama:

1. Upgrade PHP dan Nginx ke versi terbaru untuk mengatasi kerentanan
2. Implementasi header keamanan yang hilang
3. Tambahkan flag Secure pada cookie
4. Implementasi file security.txt untuk pelaporan masalah keamanan
5. Tinjau konfigurasi HTTP OPTIONS dan nonaktifkan jika tidak diperlukan

3.1.3 List Vulnerability (Daftar Kerentanan)

No	kerentanan	Tingkat kerentanan
1.	Missing 'Strict-Transport-Security' header	Medium
2.	Absence of Anti-CSRF Tokens	
3.	Content Security Policy (CSP) Header Not Set	
4.	Missing Anti-clickjacking Header	
5.	Big Redirect Detected (Potential Sensitive Information Leak)	Low
6.	Cookie No HttpOnly Flag	
7.	Cross-Domain JavaScript Source File Inclusion	

8.	Server Leaks Version Information via "Server" HTTP Response Header Field	
9.	Timestamp Disclosure – Unix	
10.	X-Content-Type-Options Header Missing	
11.	Authentication Request Identified	Informational
12.	Information Disclosure - Suspicious Comments	
13.	Modern Web Application	
14.	Session Management Response Identified	

3.1.4 Detail Vulnerability

a. Medium Severity (Tingkat Kerentanan Rendah)

1. Missing 'Strict-Transport-Security' heade

Tanpa header ini, aplikasi tidak dapat memaksa penggunaan HTTPS, meningkatkan risiko serangan Man-in-the-Middle (MITM).

Solusi: Set header Strict-Transport-Security ke max-age=31536000; includeSubDomains; preload.

2. Absence of Anti-CSRF Tokens

Tanpa token CSRF, aplikasi rentan terhadap serangan Cross-Site Request Forgery (CSRF), yang memungkinkan penyerang melakukan tindakan tidak sah atas nama pengguna

Solusi: Gunakan token CSRF unik pada setiap permintaan form dan validasi di sisi server

3. Content Security Policy (CSP) Header Not Set

Tanpa header CSP, aplikasi rentan terhadap injeksi skrip berbahaya seperti Cross-Site Scripting (XSS).

Solusi: Set header Content-Security-Policy untuk membatasi sumber daya yang dapat dimuat oleh aplikasi.

4. Missing Anti-clickjacking Header

Tanpa header ini, aplikasi dapat dibingkai oleh situs jahat untuk melakukan serangan clickjacking.

Solusi: Set header X-Frame-Options ke "DENY" atau "SAMEORIGIN".

b. *Low Severity* (Tingkat Kerentanan **Rendah**)

1. **Big Redirect Detected (Potential Sensitive Information Leak)**

Server memberikan pengalihan besar yang mungkin mencakup informasi sensitif seperti PII (Personally Identifiable Information). Hal ini dapat mengekspos data yang tidak seharusnya terlihat oleh penyerang.

Solusi: Pastikan respons pengalihan tidak mengandung konten sensitif. Pengalihan seharusnya hanya memuat URL tujuan tanpa menyertakan data tambahan.

2. **Cookie No HttpOnly Flag**

Cookie ditetapkan tanpa flag **HttpOnly**, yang memungkinkan skrip JavaScript untuk mengakses cookie. Ini meningkatkan risiko pembajakan sesi (session hijacking).

Solusi: Tetapkan atribut **HttpOnly** untuk semua cookie agar cookie hanya dapat diakses melalui server, bukan melalui JavaScript.

3. **Cross-Domain JavaScript Source File Inclusion**

Halaman memuat skrip JavaScript dari domain pihak ketiga. Jika sumber tidak terpercaya, ini dapat meningkatkan risiko eksploitasi seperti XSS (Cross-Site Scripting).

Solusi: Pastikan semua file sumber JavaScript hanya dimuat dari sumber yang terpercaya dan valid.

4. **Server Leaks Version Information via "Server" HTTP Response Header Field**

Server memberikan informasi versi melalui header HTTP **"Server"**, yang dapat memudahkan penyerang mengeksploitasi kerentanan yang sudah diketahui.

Solusi: Konfigurasi server untuk menghapus header **"Server"** atau hanya menampilkan informasi umum.

5. Timestamp Disclosure – Unix

Stempel waktu Unix ditampilkan oleh server, yang dapat membantu penyerang mengidentifikasi pola aktivitas pengguna.

Solusi: Pastikan data stempel waktu tidak sensitif dan tidak dapat digunakan untuk membuat pola aktivitas yang dapat mengeksploitasi kerentanan.

6. X-Content-Type-Options Header Missing

Header **X-Content-Type-Options** tidak disetel ke 'nosniff', memungkinkan browser untuk melakukan MIME-sniffing, yang dapat menyebabkan interpretasi tipe konten yang salah.

Solusi: Pastikan header **X-Content-Type-Options** disetel ke 'nosniff' untuk semua respons halaman.

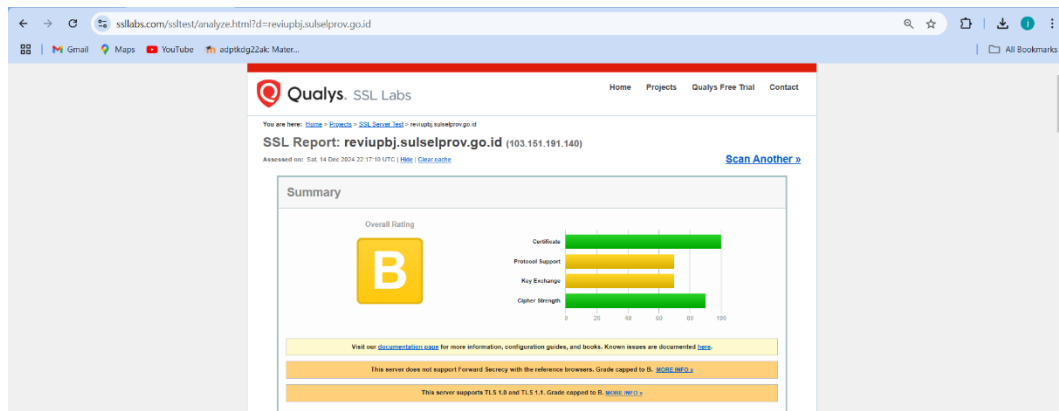
3.1.5 Vulnerability Assessment (Pengujian Kerentanan)

a) SSL Report

Dari gambar dibawah ini, dapat dijelaskan hasil pemeriksaan SSL untuk domain sulselprov.go.id:

1. Overall Rating: B (Grade B)

- Rating ini ditampilkan dalam bentuk diagram bar dengan warna yang berbeda untuk berbagai aspek keamanan



2. Detail Sertifikat #1:

- Menggunakan RSA 2048 bits dengan algoritma SHA256withRSA

- Valid dari 1 April 2024 hingga 1 Mei 2025 (berlaku 4 bulan 17 hari)
- Diterbitkan oleh Sectigo RSA Domain Validation Secure Server CA
- Sertifikat bersifat trusted (dipercaya) oleh Mozilla, Apple, Android, Java, Windows
- Certificate Transparency: Yes
- Status revokasi: Good (tidak dicabut)

3. Sertifikat Tambahan dalam Chain:

- Total 4 sertifikat dalam chain (6554 bytes)
- Sertifikat #2: Sectigo RSA Domain Validation Secure Server CA (berlaku hingga 31 Dec 2030)
- Sertifikat #3: USERTrust RSA Certification Authority (berlaku hingga 31 Dec 2028)
- Sertifikat #4: AAA Certificate Services (berlaku hingga 31 Dec 2028)

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1	
Subject	*.sulselprov.go.id Fingerprint SHA256: 321bf77967156df3157be702a171be8599d282d033d30b85f28354218b251a Pin SHA256: FUoJDopFAun8xdvHd/lanGvT+wIPf/3bZ7pzG9a08LU=
Common names	*.sulselprov.go.id
Alternative names	*.sulselprov.go.id sulselprov.go.id
Serial Number	00998e11b5ece1cd3437ba75f3d6e2994b
Valid from	Mon, 01 Apr 2024 00:00:00 UTC
Valid until	Thu, 01 May 2025 23:59:59 UTC (expires in 4 months and 17 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	Sectigo RSA Domain Validation Secure Server CA AIA: http://crt.sectigo.com/SectigoRSADomainValidationSecureServerCA.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	OCSP OCSP: http://ocsp.sectigo.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows
 Additional Certificates (if supplied)	
Certificates provided	4 (5654 bytes)
Chain issues	Contains anchor
#2	
Subject	Sectigo RSA Domain Validation Secure Server CA Fingerprint SHA256: 7fa4f88ec04a99d7528d5085f9407f4d1dd1c5381bacdc832ed5c90214676 Pin SHA256: 4a8cPehI7OG6cuDZka5NDZ7FR8a80d3auda+sKfg4Ng=

Valid until	Tue, 31 Dec 2030 23:59:59 UTC (expires in 6 years)
Key	RSA 2048 bits (e 65537)
Issuer	USERTrust RSA Certification Authority
Signature algorithm	SHA384withRSA
#3	
Subject	USERTrust RSA Certification Authority Fingerprint SHA256: 88b9c781219a5b1f0131784474985db61bbdb109e00f05ca9f74244ee5f5f52b Pin SHA256: x4QzPSC810K5/cMjb05Qm4k3Bw5zBn4ITdO/nEWITd4=
Valid until	Sun, 31 Dec 2028 23:59:59 UTC (expires in 4 years)
Key	RSA 4096 bits (e 65537)
Issuer	AAA Certificate Services
Signature algorithm	SHA384withRSA
#4	
Subject	AAA Certificate Services In trust store Fingerprint SHA256: d7a7a0fb5d7e2731d771e9494ebcdef71d5f0c3e0a2948782bc83ee0ea899ef4 Pin SHA256: vRU+17BDT2/GsXvOi76E7TQMCTLXAqJ0+GPdW7L1vM=
Valid until	Sun, 31 Dec 2028 23:59:59 UTC (expires in 4 years)
Key	RSA 2048 bits (e 65537)
Issuer	AAA Certificate Services Self-signed
Signature algorithm	SHA1withRSA Weak, but no impact on root certificate
 Certification Paths 	
Click here to expand	

Beberapa catatan penting:

- Server tidak mendukung Forward Secrecy dengan browser terbaru
- Mendukung TLS 1.2 dan 1.1, tidak mendukung TLS 1.0
- Menggunakan kunci RSA 2048 bit yang masih dianggap aman
- Memiliki rantai sertifikat yang lengkap dan valid

Secara keseluruhan, konfigurasi SSL website tersebut cukup baik (Grade B) namun masih ada beberapa aspek yang bisa ditingkatkan, terutama dalam hal dukungan Forward Secrecy.

c) *ClickJacking*

Gambar dibawah ini menunjukkan hasil pengujian keamanan website ReviuPBJ Provinsi Sulawesi Selatan menggunakan tools Clickjacker. Berikut detail hasil pengujiannya:

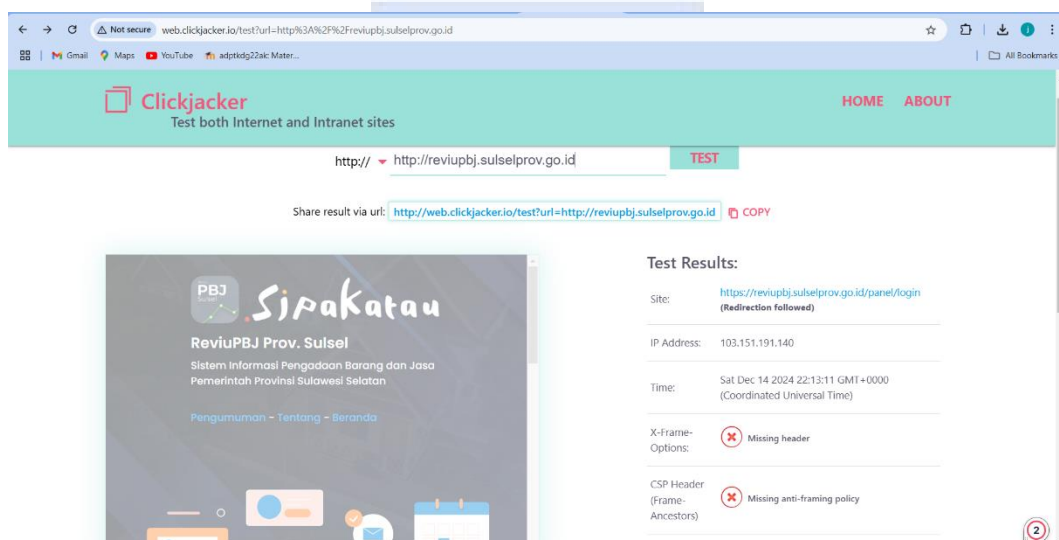
1. Website yang diuji: reviupbj.sulselprov.go.id (diarahkan ke <https://reviupbj.sulselprov.go.id/panel/login>)
2. IP Address server: 103.151.191.140

3. Waktu pengujian: Sat Dec 14 2024 22:13:11 GMT+0000
4. Ditemukan dua masalah keamanan:
 - Missing header: Tidak ada header X-Frame-Options
 - Missing anti-framing policy: Tidak ada kebijakan CSP (Content Security Policy) untuk mencegah framing

Kedua masalah ini berpotensi membuat website rentan terhadap serangan clickjacking, dimana penyerang bisa memanipulasi tampilan website dengan memasukkan konten berbahaya melalui iframe.

Untuk mengamankan website tersebut, administrator perlu:

1. Menambahkan header X-Frame-Options
2. Mengimplementasikan kebijakan CSP yang tepat untuk mencegah framing yang tidak diinginkan



Tampilan dibawah ini merupakan hasil dari poc menggunakan Clickjacking, Dengan menggunakan Visual StudioCode sebagai media editor text:

```
<!DOCTYPE html>
<html>

<head>
  <title>https://reviupbj.sulselprov.go.id/site/login</title>
```

```

<script type="text/javascript">
    // Fungsi untuk menampilkan peringatan saat halaman dimuat
    window.onload = function () {
        alert("Warning: hak akses dari kelompok 7");
        // Menampilkan pesan di dalam elemen dengan id "warning-message"
        document.getElementById("warning-message").innerText = "Website
ini memiliki kerentanan terhadap risiko serangan click jacking!!";
    }
</script>
<style>
    /* Setel margin dan padding agar elemen mengambil seluruh layar */
    html,
    body {
        height: 100%;
        margin: 0;
        padding: 0;
        overflow: hidden;
    }

    /* Menyusun iframe untuk mengisi seluruh layar */
    iframe {
        width: 100%;
        height: 100%;
        border: none;
        opacity: 15;
    }

    /* Menyusun pesan peringatan */
    #warning-message {
        position: absolute;
        top: 20px;
        left: 20px;
    }

```

```

background-color: rgba(19, 18, 18, 0.7);
color: white;
padding: 10px;
border-radius: 5px;
z-index: 10;
}

/* Menyusun tombol agar lebih terlihat */
input[type="button"] {
    z-index: 10;
    position: absolute;
    top: 100px;
    left: 20px;
    padding: 10px 20px;
    background-color: #100f0f;
    color: white;
    border: none;
    cursor: pointer;
    font-size: 16px;
}

/* Efek hover pada tombol */
input[type="button"]:hover {
    background-color: #426043;
}
</style>
</head>

<body>
    <div id="warning-message"></div> <!-- Elemen untuk menampilkan pesan -
->

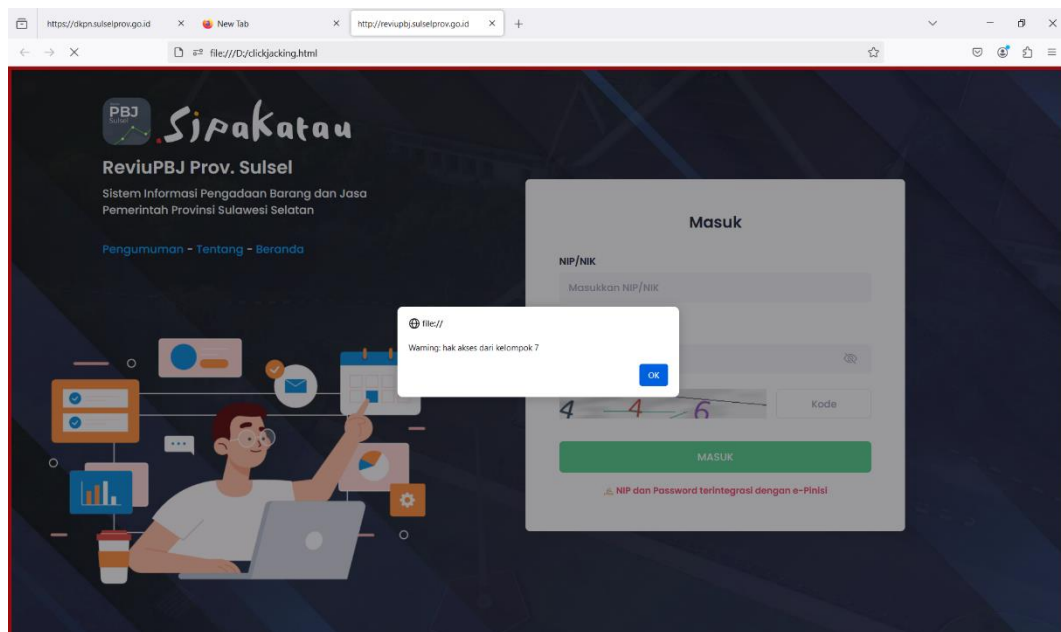
    <iframe src="https://reviupbj.sulselprov.go.id/"></iframe>

```

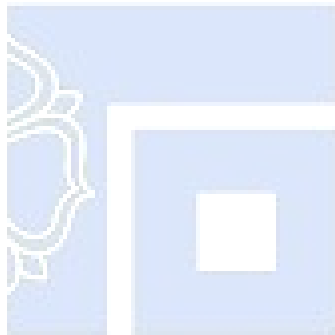
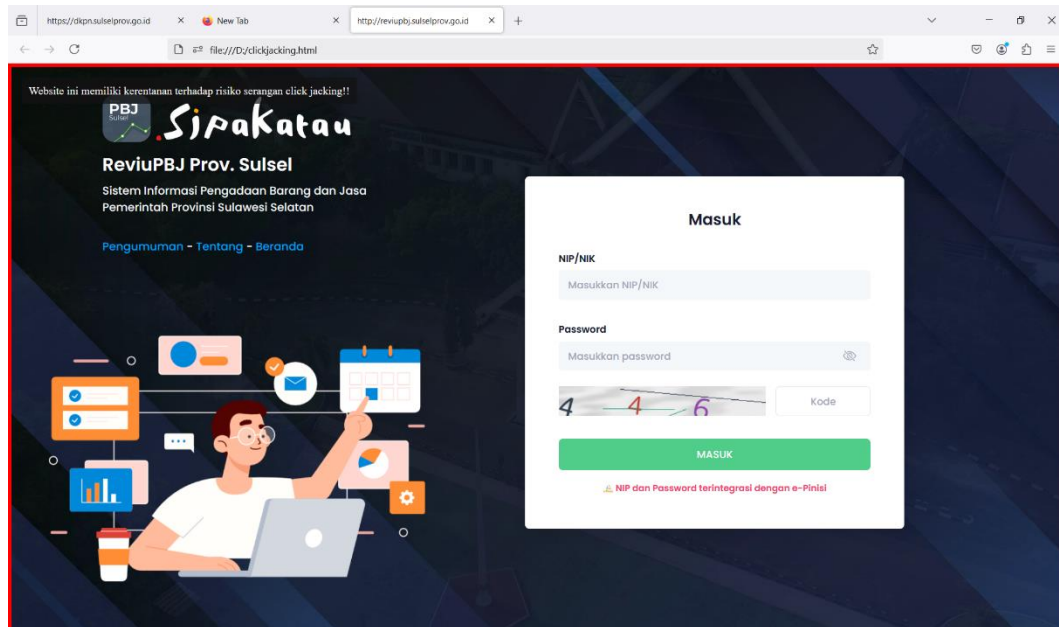
```
</body>
```

```
</html>
```

Setelah selesai simpan file di Visual StudioCode nya contoh: **euybchc**. Buka dengan browser file Visual StudioCode yang sudah disimpan tadi, maka hasilnya akan muncul *Warning* dalam bentuk *PopUp* dengan tulisan **“Warning: hak akses dari kelompok 7”**



Ketika pop up sebelumnya di klik OK, maka tampilan selanjutnya yaitu menampilkan halaman website <http://reviupbj.sulselprov.go.id/> yang mana pada bagian pojok kiri menunjukkan adanya peringatan : ***“Website ini memiliki kerentanan terhadap risiko serangan click jacking!!”***



GAMA MULTI GROUP

BAB III PENUTUP

3.1 Kesimpulan

Keamanan data dapat menjadi aspek penting dalam mengelola teknologi informasi, terutama di instansi pemerintah yang mengelola layanan publik dan badan. Dinas Komunikasi, Informatika, Statistik dan Persandian Provinsi Sulawesi Selatan memiliki tanggung jawab yang besar dalam menjaga tanggung jawab dan keamanan sistem informasi yang digunakan. Namun, peningkatan penggunaan teknologi juga terjadi di tengah-tengah ancaman serangan siber yang akan membahayakan operasi dan kepercayaan.

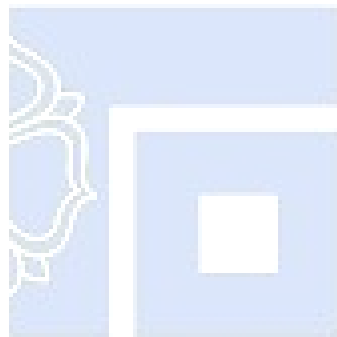
Untuk mengatasi potensi risiko ini, penetration testing diterapkan sebagai langkah analisis keamanan sistem. Pemeriksaan ini bertujuan untuk menemukan kerentanan pada situs web dan aplikasi, serta memberikan rekomendasi peningkatan untuk mengurangi risiko. Dokumentasi hasil pemeriksaan diantisipasi untuk membantu lembaga memahami kondisi keamanan sistem mereka dan mengambil langkah proaktif untuk menjaga pengetahuan dan layanan dari ancaman siber yang terus berkembang.

3.2 Rekomendasi

Rutin melakukan pengujian keamanan dan pemantauan berkala sangat penting untuk menjaga keberlanjutan perlindungan aset digital di era teknologi yang terus berkembang. Dengan menerapkan rekomendasi saran dan perbaikan, seperti menambal kerentanan, memperkuat autentikasi, dan memperbarui teknologi, keamanan sistem dapat ditingkatkan secara signifikan. Langkah-langkah ini akan mendukung website menjadi lebih aman, efisien, dan andal dalam memberikan layanan kepada masyarakat.

- Perbarui Teknologi: Upgrade library seperti Laravel, jQuery, dan Nginx ke versi terbaru.
- Perbaiki Header Keamanan: Tambahkan CSP, HSTS, X-Frame-Options, dan konfigurasi cookie yang aman.
- Proteksi Tambahan: Terapkan HTTPS, firewall (WAF), dan multi-factor authentication (MFA).

- Audit Berkala: Lakukan penetration testing rutin dan pemantauan aktivitas mencurigakan.



GAMA MULTI GROUP